A Quantitative CIE-Informed Change Management Framework for OT Attack Surface Reduction in CNI



Twinkal Sikri

A dissertation submitted for the degree of
Master of Science in Cyber Security

Supervised by *Professor, Paul Smith*

School of Computing and Communications
Lancaster University

August, 2026

Declaration

I declare that the work presented in this dissertation is, to the best of my knowledge and belief, original and my own work. The material has not been submitted, either in whole or in part, for a degree at this, or any other university. The Estimated word count is: **25759**

Student: **Twinkal Sikri**
Date: **August, 2026**

A Quantitative CIE-Informed Change Management Framework for OT Attack Surface Reduction in CNI

Twinkal Sikri
School of Computing and Communications, Lancaster University
A dissertation submitted for the degree of *Master of Science* in Cyber Security.
August, 2026

Abstract

Operational Technology (OT) systems in Critical National Infrastructure (CNI) and High Risk Organizations (HROs) have been reached by the innovation wave and are scheduled to undergo digitalization changes. However, each update can silently erode engineered cybersecurity protections. The Cyber-Informed Engineering (CIE) Implementation Guide provides qualitative Change/Configuration Management (C/CM) but does not define any quantitative scoring mechanism. This dissertation exposes that this gap is shared also across every major IT/OT standard (ISO/IEC 27001, IEC 62443-2-1, NIST SP 800-82r3). To address this gap, an innovative quantitative framework, built on NIST's OT taxonomy, is introduced in this dissertation: the CIE-Informed Change Impact Metric (CCIM). The framework's principal aim is to reduce the Attack Surface providing the tools to assess which is the best solution for a certain OT device change, evaluating trade-offs between security, usability and cost (ROI). Using Design Science (DS) research and a strong theoretical grounding, the CCIM is able to translate qualitative requirements and CIE principles into four measurable risk vectors, combined through a calculation and evaluated against a calibrated decision threshold, ultimately demonstrating its operability applying it on OT change scenarios, extracted from documented incidents or mitigation examples provided by standard bodies. Furthermore, its applicability has been extended to a hypothetical but literature-derived CNI scenario involving Artificial Intelligence (AI) in Cyber-Physical Systems (CPS). Lastly the framework has been evaluated against legacy change strategies that mostly seek compliance. The final product of this dissertation is a reusable, evidence-based support tool for analytical OT management, globally applicable, but in this case specifically calibrated to CNI. Due to its versatile structure, changing the calibration dataset enables the CCIM to be potentially suitable to any environment.

Acknowledgements

First and foremost, I want to sincerely thank my supervisor, Prof. Paul Smith, for guiding me throughout this dissertation. I am really grateful for your patience, kindness and professionalism. Secondly, I want to thank my father, Satish, for supporting me during this journey at Lancaster University. Along with all my family and friends, including my mother Anamika, my brother Minkal, my sister Venus, Amrit, Catia, Luisa and Rocco, you made all of this possible. I also want to thank Claudia, my number one supporter (even from thousands of miles away!).

Without you all I would be nothing!

I am grateful for having had the chance to meet so many wonderful people here at Lancaster and for the opportunity to learn so much about a subject I have always wanted to dive deeper into. This experience will forever be one of my best memories.

May God keep guiding us along the best path.

To conclude, I want to leave a note to **myself**: *Never stop chasing your dreams, Twinkal!*

Contents

1 Introduction **1**
- 1.1 Introduction . . . 1
- 1.2 Research Questions, Aim and Objectives . . . 2
- 1.3 Dissertation Outline . . . 4

2 Background **6**
- 2.1 Operational Technology for CNI . . . 6
  - 2.1.1 Industrial Control Systems . . . 7
  - 2.1.2 Complex Systems Safety (STPA Framework) . . . 7
  - 2.1.3 Industrial Standards . . . 8
  - 2.1.4 Change Management Across Existing Standards . . . 10
- 2.2 Cyber-Informed Engineering . . . 12
  - 2.2.1 Relevant Principles . . . 12
  - 2.2.2 Consequence-driven Cyber-informed Engineering - CCE . . . 13
- 2.3 Formal Parameter Mapping . . . 15
  - 2.3.1 Representational Measurement Theory (RMT) . . . 16

3 Related Work **18**
- 3.1 Papers, Articles and Books . . . 18
- 3.2 Synthesis: The Gap CCIM Addresses . . . 21
  - 3.2.1 Addressing the Gap in Change Management: CCIM . . . 22

4 CCIM Modelling **23**
- 4.1 Introduction to CCIM Development . . . 23
- 4.2 Metric Modelling and Theoretical Grounding . . . 24
  - 4.2.1 Attack Surface Delta Score ($ASDS$) . . . 25
  - 4.2.2 Trade-off Index (T) . . . 42
  - 4.2.3 Threshold Tuning (τ) . . . 47
- 4.3 The CCIM Algorithm: End-to-End Workflow . . . 53
- 4.4 Framework Pipeline Visual . . . 56

5 Framework Application **58**
5.1 Research Methodology: Design Science Research . . . 58
5.2 Purpose and Evaluation Logic . . . 59
5.3 Case-Study Selection . . . 60
5.4 Organizational Risk Appetite . . . 61
5.5 CS1a: PMU Feedback in a Microgrid . . . 62
5.5.1 Calculation Under a Nuclear Weight Profile . . . 65
5.5.2 Calculation Under a Manufacturing Weight Profile . . . 66
5.6 CS1b: Physical and Digital Interlock . . . 67
5.6.1 Calculation . . . 67
5.7 CS2: AI-enabled Control at a CNI Facility . . . 68
5.7.1 Calculation and Verdict . . . 71
5.8 Interpretation and Limitations . . . 74

6 Results Comparison and Evaluation **76**
6.1 Evaluation Method . . . 76
6.2 Legacy vs CCIM . . . 77

7 Conclusions **82**
7.1 Discussion . . . 82
7.1.1 Future Work . . . 83
7.2 Summary and Conclusion . . . 84

Appendix A Generative AI Usage Disclosure **86**

Appendix B Metric Development Details **87**
B.1 OT Change Scenario Data Extraction . . . 87
B.2 Monte Carlo Simulation Details . . . 93
B.3 AHP Questionnaire Template . . . 95
B.4 CR Validation . . . 98

References **101**

List of Figures

1.1 Six-activity DS research process adopted in this dissertation, based on the DSR methodology of Peffers et al. (2007) and Hevner et al. (2004). 5

2.1 Interactions between ISO/IEC 27001-27002, the IEC 62443 series, NIST SP 800-82 Rev. 3, NIST CSF 2.0, and the CCIM framework. Adapted from the ISA Global Cybersecurity Alliance's standard-mapping approach (ISA Global Cybersecurity Alliance, 2025). 10
2.2 CCE 4-phase diagram (Freeman, Hill Johnson, and St. Michel, 2019) 14

4.1 Formalization of the CCIM variables. The arrows denote "*is characterised by,*" not computation: the arithmetic combinations of $\Delta C, \Delta E, \Delta D, \Delta I$ into $ASDS$, and of $ASDS$, US, CB into T, are separate steps defined respectively in Sec. 4.2.1.5 and Sec. 4.2.2.3, and are not represented in this diagram. . . . 25
4.2 PERT-fitted densities for all six CCIM rubric variables (C, E, D, I, US, CB), by scenario class. Note that C, E, D, I separate cleanly between classes, while US overlaps substantially, consistent with US being a business-context modifier rather than a risk indicator. 50
4.3 Simulated distribution of the Trade-off Index T ($N = 20{,}000$ draws), showing the near-complete separation between Acceptable and Unacceptable scenario classes, with the calibrated τ threshold marked. 52
4.4 ROC curve for the simulated Trade-off Index T, with the Youden's J-optimal cut-off marked, yielding $\tau \approx 0.277$. 52
4.5 CCIM Phase 1-2 56
4.6 CCIM Phase 3-4 57

5.1 Simple visual representation of CS1 63
5.2 Simple visual representation of the proposed mitigation on CS1 68
5.3 Simple visual representation of the CS2 adverse change implementation . . . 70

B.1 Sequence diagram of the three-stage τ calibration workflow: scenario extraction, PERT-based Monte Carlo simulation, and final distribution plotting. . 94

List of Tables

2.1 Change management treatment across reviewed standards 11

3.1 Related work evaluated against quantitative, OT change-specific decision capability. 21

4.1 Formalization of Consequence Exposure (ΔC) 30
4.2 Formalization of Engineered Controls (ΔE) 33
4.3 Formalization of Digitalization / Attack Surface (ΔD) 36
4.4 Formalization of Interdependency (ΔI) 38
4.5 Formalization of the Usability Score (US) 44
4.6 Formalization of the Cost-Benefit Score (CB) 46
4.7 Extracted OT change scenarios scored against the CCIM rubric (see Tables 4.1-4.6). Full per-score justification in Appendix B, Table B.1. 49
4.8 Notation used in the PERT probability density function (Eq. 4.10). 50
4.9 Acronyms and notation used in Youden's J optimization (Step 5). 53

5.1 Illustrative AHP-derived risk-appetite vectors for two organisational profiles (both pass $CR < 0.10$ under Phase 1, see App. B.4) 61
5.2 The same two scenarios evaluated under both organisational profiles. The verdict is stable; the absolute margin is not. 62
5.3 CCIM scores for the WAN-routed PMU-feedback scenario. The values match the calibration corpus and Appendix B.1. 65
5.4 CCIM scores for the hypothetical cloud-hosted AI dosing scenario at a CNI water treatment facility. 72

6.1 Structural comparison between prescriptive standards/CIE compliance and CCIM-based change triage. 78

B.1 Full justification of extracted OT change scenarios against CCIM rubric anchors (see Tables see Tables 4.1–4.6) 88
B.2 CCIM ASDS Variable Definitions 96
B.3 Saaty's AHP Scale 96

B.4 Pairwise Comparison Matrix: Nuclear Facility SME 97
B.5 Pairwise Comparison Matrix: Manufacturing Plant SME 97

Chapter 1

Introduction

1.1 Introduction

Operational Technology (OT) devices play a crucial role in modern society, being the tools that constitute the backbone of the infrastructure it relies upon. That is why the deployment of these devices is heavily regulated in each phase of their lifecycle whether in CNI/HRO contexts or otherwise. However, a common but extremely dangerous mistake is thinking that providing enough documents and proofs to the auditing actor is enough to call an infrastructure *secure*, since on paper it results compliant to law-imposed standards. Moreover, heavier resource constraints are limiting the ability of engineers to propose safer or more secure solution prioritising budget-friendly options that are able to pass compliance tests, even slightly. In support to this claim, cybersecurity investment **priority** for business leaders data from Statista shows that Operational Technology security now represents only 10% in 2026, getting reduced significantly from 2025 in which it represented 23% (Statista, 2025).

The compliance-driven superficiality pattern can be spotted more often than it should be and, as a result, many incidents have happened. The cause of those incidents can be associated with several sources of risk, however this dissertation focuses on the *cybersecurity* context. Furthermore, it is worth noting that even though OT has been less prioritized as explained above, experts argue that the attention is shifting more day by day towards cybersecurity in the OT sector because of the new wave of innovation: along with innovation in Information Technology (IT), Industry 4.0 trends are bringing digitalizations where just a decade ago everything was purely analogical and human centric, in this case in OT devices (Statista, 2024). The IT/OT convergence is the main driver of the expansion of the OT owners' attack surface, but fundamentally data reports from 2023 show that main cause of incidents in Industrial Control Systems (ICS) is caused by well-meaning but negligent insiders followed by malicious insiders (Statista, 2024; KPMG International and CS2AI, 2024).

Moreover, current risk assessment methodologies mostly rely on checkbox approaches with the sole aim of reaching compliance level. As a matter of fact, a survey conducted in 2024 in

the United Kingdom shows that the main pressure to improve maturity in cybersecurity (29%) is coming from regulations and the need to meet their changing requirements (Bridewell, 2024).

At this point, it can be understood that the core problem rises from the fact that OT devices are being updated and industries are facing the challenge of evaluating the risks that innovation brings with it, along with searching for the best compromise between budget, usability and compliance. That is why there is an emerging need of a support tool for ***change-management***.

1.2 Research Questions, Aim and Objectives

Primarily, the main driver of the research illustrated in the following chapters is Cyber-Informed Engineering (CIE), presented in Sec. 2.2. CIE is a 12-principle strategy to approach security with a consequence-first mindset, that helps understanding what to prioritize as the main assets/core functions (Robert S. Anderson et al., 2017). Moreover, today's technological landscape makes the cyber domain inherently fragile, requiring both information security and engineered controls, eventually converging and not being mutually exclusive (Lampe, 2026). That is the reason why this dissertation proposes a solution that approaches security with four different risk vectors taken in consideration: consequence exposure, engineered controls, digitalization and interdependency (see Chap. 4). From an holistic point of view, those are the key elements that stood out when considering the *attack surface area expansion* causes. Nevertheless, the framework also includes two more variables that considers the usability and budget constraints. At the end, it outputs an index that is checked against an approval threshold and when the solution does not pass, it encourages a full redesign of the candidate option (device change) via CIE principles.

This dissertation proposes a framework called **CIE-Informed Change Impact Metric** (CCIM), that addresses the gaps exposed by qualitative risk assessments, prescriptive regulations and the lack of evidence to support claims only presented as expert judgement still today (see Sec. 3.2.1). The framework does not aim to completely delete the cyber-related risk of incidents, rather it is a solution corroborated by the scientific grounding of modern risk management, applied to technical concepts of OT in real-world CNI, that proposes a quantitative assessment method that is able to find the most suitable, but secure solution when swapping OT devices[1].

[1]If in doubt about abbreviations used in the following chapters, they are available at `https://www.electropedia.org/` and `https://www.iso.org/obp`. Those are trusted sources maintained by the standard bodies (NIST, 2023; *IEC 62443-2-1:2024* 2024; *ISO/IEC 27001:2022* 2022).

Research Questions The research questions to which this dissertation answers are:

RQ1. What are the core dimensions of OT change impact derived from CIE principles, and how can qualitative change-management criteria be effectively translated into measurable variables?

RQ2. How can a quantitative scoring metric (CCIM) be structured to accurately model an attack surface delta that is calculated combining consequence exposure, engineered-control degradation, asset digitalization and service interdependence?

RQ3. In what ways does the proposed CCIM improve the validity and usability of decision support for OT change approval when compared to existing unstructured approaches?

Aim To design, implement, and evaluate the **CCIM**: a quantitative, CIE-informed scoring framework enabling CNI operators to assess the attack-surface implications of proposed OT changes through measurable cost-risk-usability trade-offs. What this dissertation tries to solve is the lack of quantitative data availability during OT security assessment and decision making.

Objectives The objectives this dissertation wants to achieve are:

O1. Illustrate relevant literature through an in-depth analysis, finally exposing the gap that CCIM addresses;

O2. Map CIE relevant principles and related literature to a set of measurable variables, creating scoring rubrics;

O3. Formulate the CCIM equations as an initial model, keeping it mathematically grounded, and calibrate the decision threshold (τ) using computational simulation over real-world extracted data;

O4. Apply the CCIM to representative OT change scenarios to examine its behaviour across varying impact levels and contexts;

O5. Prove the framework's operational validity and usability through Design Science (DS) Research methodology;

O6. Discuss the contribution and critically evaluate its limitations, suggesting improvements and future work.

1.3 Dissertation Outline

The research methodology used in this thesis is the Design Science Research, ***DSR*** (see Sec. 5.1). It is not a casual choice because CCIM crucially is a designed artefact and DSR's 6-step process is specifically built for this (Hevner et al., 2004; Peffers et al., 2007).

Problem identification and motivation: This dissertation first gives an overview of the research relevant material in the Background chapter (see Chap. 2), spanning through in-depth terminology explanation, relevant literature, technical concepts, industrial standards and measurement theory.

Definition of objectives: The following chapter analyses in depth the related work, explaining what was used to actually inform the *CCIM* and finally exposes the gap the framework is designed to address (see Chap. 3, Sec. 3.2.1).

Design and development: Chapter 4, presents the actual contribution, explaining in detail the building process and theoretical grounding. This chapter represents the aggregation of all the information extrapolated in the previous chapter, informing it to specifically model it to serve as an augmentation tool for device change management, providing information about the thought process that is behind the design structure.

Demonstration: Chapters 4 and 5 contain the demonstration of the applicability of the framework and how it works under the hood. Additional material on the modelling of the *calculations* (either $ASDS$ or T) can be found in the appendix (App. B).

Evaluation: Chapter 6 evaluates the final design of the solution and the outcome of its application on the case studies performed in the previous chapter, comparing it to legacy change management (risk assessment) strategies.

Communication: The final chapter (Chap. 7) contains the critical analysis of the proposed contribution through a discussion about its limitations and how it can be improved/expanded.

Crafting the dissertation included several iterations and refinements, however this submission format includes only the latest iteration. While the diagram in the next page explains the DSR methodology full-step implementation and includes the "iteration and refinement" step as well, the iterative process is not actually shown in the body of the dissertation. It is included in the diagram for completeness (see Fig. 1.1).

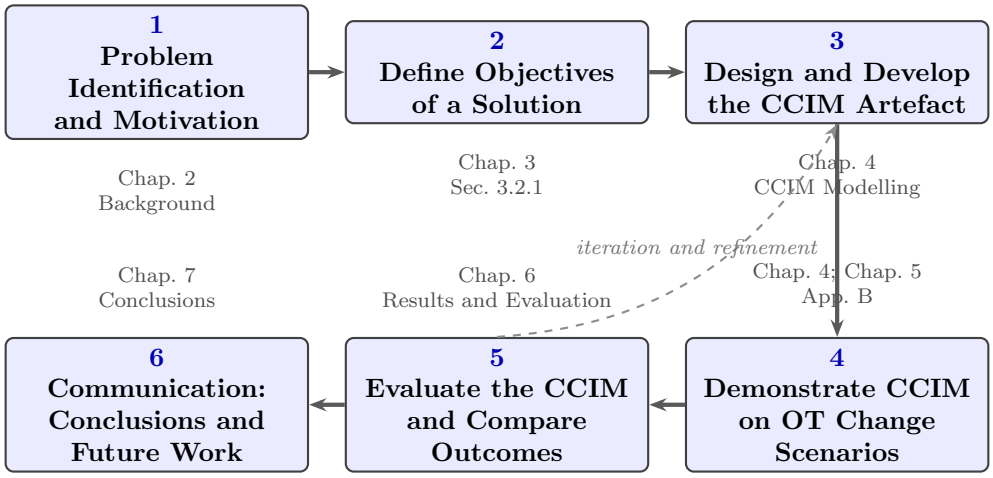


Figure 1.1: Six-activity DS research process adopted in this dissertation, based on the DSR methodology of Peffers et al. (2007) and Hevner et al. (2004).

Chapter 2

Background

This chapter introduces all the concepts that inform this dissertation, beginning from core definitions, going through industrial standards, relevant concepts and concluding with the theoretical grounding of the metric developed in the next chapter.

2.1 Operational Technology for CNI

Operational Technology (OT) has been the main driver of industrial operations during the last century. It is the hardware and embedded software used to control and monitor physical processes and industrial machinery. It offers an interface with physical processes, which often also require extreme precision, enabling action-oriented systems design (NIST, 2023). Over the decades the industry has changed, evolved and adapted with the aim of automating certain tasks reducing the risk that involved manual operations (human intervention). OT has been largely deployed as well in sectors such as manufacturing, energy, logistics and healthcare (NIST, 2023). However, it can be argued that in specific critical operations, machines can be unreliable, also because of the exposure to cyber-risks derived from the transition to interconnected systems (Statista, 2024). Currently, Industry 4.0 is the right wording to describe the modern innovation stage. The peculiarity of the Industry 4.0, also known as the Fourth Industrial Revolution, is that the current trend is the push towards the digitalization of OT devices, more specifically, Industrial Control Systems (ICS) and Cyber-Physical Systems (CPS) (Kagermann, Wahlster, and Helbig, 2013; Statista, 2024). Last but not least, it must be acknowledged that the side effects of this trend are subtle to people who watch this change only as an augmentation in usability and safety in industrial sectors. Nevertheless, from a security point of view, introducing such systems without the right precautions and design guidelines, can have extremely dangerous consequences, caused by the ripple effect that a disruption to CNI would cause. To be understood this risk of collateral damage requires a system examination that later also has to be analysed through a safety-engineering point of view (Rinaldi, Peerenboom, and Kelly, 2001).

2.1.1 Industrial Control Systems

This dissertation follows the taxonomy used by NIST SP 800-82 Rev. 3 and CISA, which list Industrial Control Systems (ICS) as one of several OT categories alongside building automation and transportation systems (NIST, 2023; Cybersecurity and Infrastructure Security Agency, 2025). This taxonomy has been used since it aligns with the standard bodies (see Sec. 2.1.3). ICS are a subset of OT mostly deployed in CNI [1], including: Supervisory Control and Data Acquisition (SCADA) systems, Distributed Control Systems (DCS), and Programmable Logic Controllers (PLCs) that are used to translate digital command inputs into physical actions. Conversely to IT devices, ICS prioritize availability and real-time response over data protection. This means that legacy cybersecurity practices (e.g., Identification Access Management (IAM) overhead) can create an imbalance between ICS core function and its reliability. This unevenness between IT-style security measures and OT's physical process constraints is a recurring pattern that is addressed directly in this dissertation with the illustration of the CCIM framework (see Chap. 4).

2.1.2 Complex Systems Safety (STPA Framework)

Traditional accident models consider failures as linear chains of acknowledged events: the *Domino Chain Model* maps an accident as a sequence of falling dominoes, where the absence of any single link prevents the unwanted outcome (Leveson, 2012). The *Swiss Cheese Model* extended this definition by conceptualizing the defences as layered barriers, each with *holes* (imperfections), where an incident occurs only when the holes of subsequent layers align (Reason, 1990). Although these models are useful for reverse engineer gaps in the defensive strategy, they both assume that accidents stem from component failure or human error alone. That is why they struggle capturing incidents caused by unsafe *interactions* between fully functioning components: a limitation with direct impact on CPS, where a threat actor exploits legitimate system behaviour rather than a vulnerability caused by an error.

Leveson's Systems-Theoretic Accident Model and Processes (STAMP), and its associated System-Theoretic Process Analysis (STPA), shift the safety perspective from a failure-chain problem to a control problem: incidents occur when actuation inputs violate safety constraints, regardless of any individual component breakdown (Leveson, 2012)

Furthermore, in this dissertation the paper taken in consideration as a guideline for STAMP and STPA application on CPS scenarios is the Friedberg et al. (2017) paper in which the STPA model are used to map risk vectors and provide a better systemic understanding. This specific paper is crucial for the empirical mapping of one of the measurements that compose the final calculation of the CCIM framework (see Sec. 4.2).

[1] InfraCritical defines it as complementary, yet unique set of devices, rather than a subset of OT `https://icsmodel.infracritical.com/`

2.1.3 Industrial Standards

Protecting CNI requires the combination of two historically separate governance strategies: on one hand there are Information Technology (IT) security standards, refined overtime in enterprise environments; on the other hand there are Operational Technology (OT) security standards, deployed to preserve availability and safety under strict physical constraints (ISA Global Cybersecurity Alliance, 2025). The following review highlights the gap each standard leaves unaddressed, referring specifically to the lack of quantitative judgement 2.2. The following sections illustrate the standards that inform the CCIM's design.

2.1.3.1 ISO/IEC 27001 and ISO/IEC 27002

ISO/IEC 27001:2023+A1:2024 dictates generic requirements for the lifecycle of an Information Security Management System (ISMS) (*ISO/IEC 27001:2022* 2022). ISO/IEC 27002:2022 complements it by providing a range of security controls for risk-reduction that organizations select to fit their specific needs (*ISO/IEC 27002:2022* 2022). Both standards are tailored for IT infrastructure, and neither natively regulate the physical safety, real-time, and fail-safe constraints typical to OT environments (ISA Global Cybersecurity Alliance, 2025). Still they need to be considered, given the current trend of the IT/OT convergence (Statista, 2024; Kagermann, Wahlster, and Helbig, 2013).

2.1.3.2 The IEC 62443 Series

The IEC 62443 series regulates Industrial Automation and Control Systems (IACS), providing security guidance and covering manufacturing, process, and geographically distributed utility operations (electricity, gas, water, pipelines) (ISA Global Cybersecurity Alliance, 2025). Unlike ISO/IEC 27001/27002, the series provides requirements to satisfy based on the organizational role:

- **IEC 62443-2-1:2024** introduces security program requirements for IACS *asset owners*, modelled around Security Program Elements (SPEs) and specifying a maturity model for evaluating requirement fulfilment (*IEC 62443-2-1:2024* 2024);
- **IEC 62443-2-4:2023** specifies requirements for *integration and maintenance service providers* supporting asset owners (*IEC 62443-2-4:2023* 2023);
- **IEC 62443-3-3:2013** and **IEC 62443-4-2:2018** define system and component level security requirements and consequently introduces Security Levels (SLs) (*IEC 62443-3-3:2013* 2013; *IEC 62443-4-2:2018* 2018);
- **IEC 62443-4-1:2018** lists secure product development lifecycle requirements for *product suppliers* (*IEC 62443-4-1:2018* 2018).

In comparison to ISO/IEC 27001, IEC 62443 does not *itself* define ISMS requirements. 62443-2-1 explicitly dictates that an asset owner's OT security program shall be coordinated with any existing ISMS (ISA Global Cybersecurity Alliance, 2025). Therefore, OT change-management decisions with the scope of updating devices to be digitalized, shall be the result of the fulfilment of 62443 requirements along with an underlying ISO/IEC 27001-based ISMS, if present, and vice versa (ISA Global Cybersecurity Alliance, 2025).

2.1.3.3 NIST SP 800-82 and the NIST Cybersecurity Framework

NIST Special Publication 800-82 Revision 3 (September 2023) is the current U.S. federal guidance for OT security (NIST, 2023). It targets the broader OT category, not only ICS, and now includes an updated threat model to reflect ransomware campaigns involving OT and IT/OT convergence risks, and aligned its control overlay with NIST SP 800-53 Revision 5 (NIST, 2023). Although its scope is the private industry, it is treated as the most important benchmark across most CNI sectors.

The NIST Cybersecurity Framework (CSF) 2.0, released February 2024, is the current version of NIST's overarching risk-management taxonomy (NIST, 2024). It comprises six core functions, including Govern, Identify, Protect, Detect, Respond, and Recover, and places renewed emphasis on organizational governance, supply chain risk management, and continuous, quantifiable risk assessment (NIST, 2024). The calculations proposed in this dissertation (Trade-off Index, T and decision threshold, τ) are conceptually positioned within this Govern function: they represent the "quantifiable risk assessment" that CSF 2.0 requires but does not indicate a method for computing (NIST, 2024).

2.1.3.4 Interaction Between Standards

Figure 2.1 summarizes the relationship between the standards reviewed above. The illustration is inspired from the ISA Global Cybersecurity Alliance's own mapping of ISO/IEC 27001/27002 to the IEC 62443 series (ISA Global Cybersecurity Alliance, 2025), and extended to include NIST SP 800-82r3 and the NIST CSF 2.0.

ISO/IEC 27001 and ISO/IEC 27002 govern the IT Information Security Management System (ISMS) of an organization. The IEC 62443 series regulates OT-facing technical and procedural controls for distinct organizational roles: *asset owners* (62443-2-1), *service providers* (62443-2-4), and *product suppliers* (62443-4-1), supported by *system and component level security requirements* (62443-3-3, 62443-4-2) . These two standard families are complementary rather than hierarchical: IEC 62443-2-1 explicitly requires that an asset owner's OT security program be coordinated with any existing IT ISMS regulated by the ISO/IEC 27001, since IEC 62443 does not itself define ISMS-level requirements.

NIST SP 800-82r3 sits alongside the OT side of this relationship: it acts as a wrapper of NIST SP 800-53r5 and directly cross-references IEC 62443 throughout its OT-specific control guidance, rather than deriving only from ISO/IEC 27001. Instead, NIST CSF 2.0 sits above

both the IT and OT sides providing an overarching governance taxonomy (Govern, Identify, Protect, Detect, Respond, Recover) that applies to either domain without prescribing OT-specific technical controls itself.

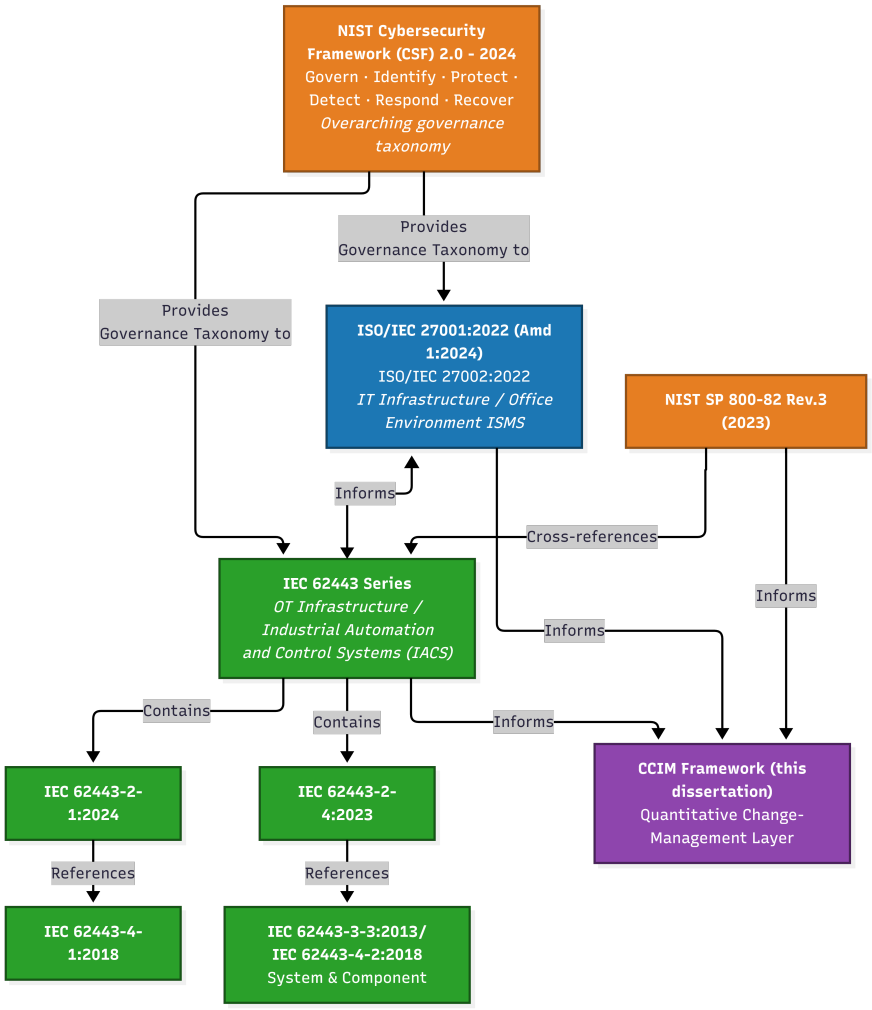


Figure 2.1: Interactions between ISO/IEC 27001-27002, the IEC 62443 series, NIST SP 800-82 Rev. 3, NIST CSF 2.0, and the CCIM framework. Adapted from the ISA Global Cybersecurity Alliance's standard-mapping approach (ISA Global Cybersecurity Alliance, 2025).

2.1.4 Change Management Across Existing Standards

A crucial aspect to analyse for this dissertation is whether any of the afore-mentioned standards already address change management, and if so, to what extent. The review revealed

that they do, but only *procedurally*.

ISO/IEC 27001:2022 Annex A Control 8.32 requires that changes to data processing facilities and systems follow a documented change management procedure including *impact assessment, authorization, testing, communication, and rollback planning*.

IEC 62443-2-1:2024 includes an equivalent OT-specific requirement under Security Program Element CM 1.4 ("Change control"), part of its Configuration Management SPE, dictating that asset owners follow an established change control process for IACS.

NIST SP 800-82r3 imports NIST SP 800-53's CM-3 "Configuration Change Control" guidelines and adds that OT configuration change control "should align with the organization's management of change practices," but does not provide the modality with which this alignment need to be measured.

The most detailed change-management process is found outside the standards already discussed, in **ISO/IEC 20000-1:2018** (Service Management System Requirements) and its guidance document **ISO/IEC TS 20000-11:2021**, which clarifies the connection between ISO/IEC 20000-1 and IT service management frameworks such as ITIL® (*ISO/IEC 20000-1:2018* 2018; *ISO/IEC TS 20000-11:2021* 2021). Clause 8.5.1 of ISO/IEC 20000-1 requires organizations to establish a documented change management policy, decide which Configuration Items fall under change control, and define criteria for determining when a change has the potential for "major impact" (*consequence*) on services, triggering a higher level of scrutiny and approval (*ISO/IEC 20000-1:2018* 2018).

However, this depth is only *apparent* since every one of these treatments shares the same limitation: they require a pre-existing change management *process* and require specific procedural stages, but none of them define *how* to quantitatively assess the impact or the risk of a specific change. ISO/IEC 20000-1's own "criteria to determine changes with potential to have a major impact" is left entirely to the implementing organization to define, with no reference model provided (*ISO/IEC 20000-1:2018* 2018). Table 2.1 summarizes this prescriptive-only treatment across the four standards reviewed.

Standard	**Change Management Reference**	**Nature of Treatment**
ISO/IEC 27001:2022	Annex A Control 8.32	Procedural (assess, approve, test, rollback)
IEC 62443-2-1:2024	SPE 2, CM 1.4 "Change control"	Procedural and maturity level (ML0-ML4)
NIST SP 800-82 Rev.3	Imports SP 800-53 CM-3	Procedural and references org. practices only
ISO/IEC 20000-1:2018	Clause 8.5.1	Procedural and with undefined "major impact" criteria

Table 2.1: Change management treatment across reviewed standards

2.2 Cyber-Informed Engineering

Cyber-Informed Engineering (CIE) is a methodology proposed by the U.S. Department of Energy (DOE), first presented in 2017 by the Idaho National Laboratory (INL) as a "framework for deepening the involvement of engineering staff in understanding and mitigating high-consequence and constantly evolving cyber threat within nuclear and radioactive material facilities (NRMF)" (Robert S. Anderson et al., 2017). Subsequently, in 2023, it was formalized with the CIE Implementation Guide, still illustrated by the INL (Wright et al., 2023). The CIE philosophy proposes a consequence-driven design approach that prioritizes securing main assets, in order to give space to cybersecurity in modern systems, rather than patching them adding a layer of IT controls over the already-designed structure. CIE encourages engineers to make design-level decisions throughout the entire engineering lifecycle from start to end, focusing on the reduction or complete elimination of the consequences a sophisticated cyber attack could have (Freeman, Hill Johnson, and St. Michel, 2019). The proposed methodology revolves around five pillars (Awareness, Education, Development, Current Infrastructure, and Future Infrastructure) and twelve foundational design and operational principles (Wright et al., 2023).

2.2.1 Relevant Principles

The U.S. Department of Energy's Cyber-Informed Engineering (CIE) Implementation Guide defines twelve principles intended to integrate cybersecurity considerations into the engineering lifecycle of critical infrastructure systems (Wright et al., 2023). Rather than reviewing all twelve exhaustively, this section focuses on the four principles that directly ground the CCIM metrics developed in Chapter 4, since a full review would duplicate material presented there in greater depth.

Consequence-driven Cyber-informed Engineering (CCE) is the main philosophy underpinning CIE: it argues that cyber risk in Operational Technology must be measured by physical consequence rather than data confidentiality alone (Wright et al., 2023; Freeman, Hill Johnson, and St. Michel, 2019). This principle, combined with Leveson's STAMP accident model (Leveson, 2012), directly grounds the Consequence Exposure (C) measurement formalized in Sec. 4.2.1.1.

Principle 2, Engineered Controls, holds that the most resilient defence against cyber-physical tampering is the use of physical or analog constraints (e.g., mechanical relief valves, hardwired relays) that are independent of programmable logic (Wright et al., 2023). This principle is the direct theoretical foundation for the Engineered Controls (E) measurement, formalized in Sec. 4.2.1.2.

Principle 7, Interdependency Evaluation, addresses the risk introduced when OT devices rely on external services (e.g., Active Directory, NTP, remote vendor diagnostics) to function, even when those devices are not themselves directly targeted (Wright et al.,

2023). This principle directly grounds the Interdependency (I) measurement, formalized in Sec. 4.2.1.4, and is empirically reinforced by Rinaldi et al.'s critical infrastructure interdependency theory (Rinaldi, Peerenboom, and Kelly, 2001).

Principle 8, Digital Asset Awareness, holds that engineers must understand and consider where digital assets and digitized functions are introduced into a system, what new communication paths and trust boundaries they create, and how what would be the consequence of unexpected behaviour if compromised (Wright et al., 2023). This principle directly grounds the Digitalisation (D) measurement, formalized in Sec. 4.2.1.3, and is further supported by Manadhata and Wing's Attack Surface Metric, which shows that exploitation probability increases with the number of communication channels, ports, and protocol interfaces a device exposes (Manadhata and Wing, 2011).

The remaining CIE principles not detailed here (e.g., Design Simplification, Layered Defences) inform the broader motivation for this dissertation but are not directly formalized into a CCIM rubric variable, and are therefore not elaborated further in this section.

2.2.1.1 CIE Change Management

The Implementation Guide explicitly identifies change and configuration management as one of several "controlling processes", alongside project management and risk management, that engineering teams must apply consistently across the entire project lifecycle, spanning all twelve principles rather than being confined to a single phase (Freeman, Hill Johnson, and St. Michel, 2019). This makes change-management a traversal mechanism through which CIE principles are actually enforced in practice: any proposed engineering change, whether a device update, a network architecture rework, or a software update mechanism, must be evaluated against the same consequence-focused mindset that governs the system's original security-informed design.

However, the Implementation Guide treats change/configuration management (C/CM) descriptively, as a named controlling process that teams are expected to apply, without prescribing a specific method for evaluating whether an individual proposed change is itself compliant with CIE principles or should be rejected. This mirrors the same limitation identified across the industrial standards reviewed earlier in the chapter (see Sec. 2.1.4): CIE, like ISO/IEC 27001, IEC 62443-2-1, and ISO/IEC 20000-1, establishes that engineering changes must be governed and evaluated, but does not itself supply a quantitative, repeatable decision criterion for that evaluation.

2.2.2 Consequence-driven Cyber-informed Engineering - CCE

At its core CIE follows Consequence-driven Cyber-informed Engineering (CCE): a rigorous methodology developed by Idaho National Laboratory that provides the main strategy that enables an effective CIE implementation (Freeman, Hill Johnson, and St. Michel, 2019). CCE begins by asking what catastrophic failure must be prevented at all costs followed by an

iterative process in which organizations are expected to cyclically revisit their assumptions and analysis as operational dependencies and adversary capabilities evolve (Freeman, Hill Johnson, and St. Michel, 2019). The four phases are:

1. **Consequence Prioritization**, in which the organization identifies High Consequence Events (HCEs), pinning the worst-case outcomes that must be prevented regardless of cost, and prioritize protection around them rather than around generic data confidentiality or compliance targets (Freeman, Hill Johnson, and St. Michel, 2019);

2. **System-of-Systems Analysis**, map the digital dependencies of the critical physical functions identified in Phase 1, exposing common-cause failure paths where a single digital compromise could cascade into a physical consequence;

3. **Consequence-Based Targeting**, using the point of view of a sophisticated adversary that is assumed to be already behind the perimeter, identifying how such an adversary would exploit the dependencies mapped in Phase 2 to reach a High Consequence Event;

4. **Mitigation and Protections**, implement engineering controls that "design out" the identified risk, typically through engineered decoupling of critical operational functions from compromisable digital dependencies, rather than relying solely on additive IT security controls.

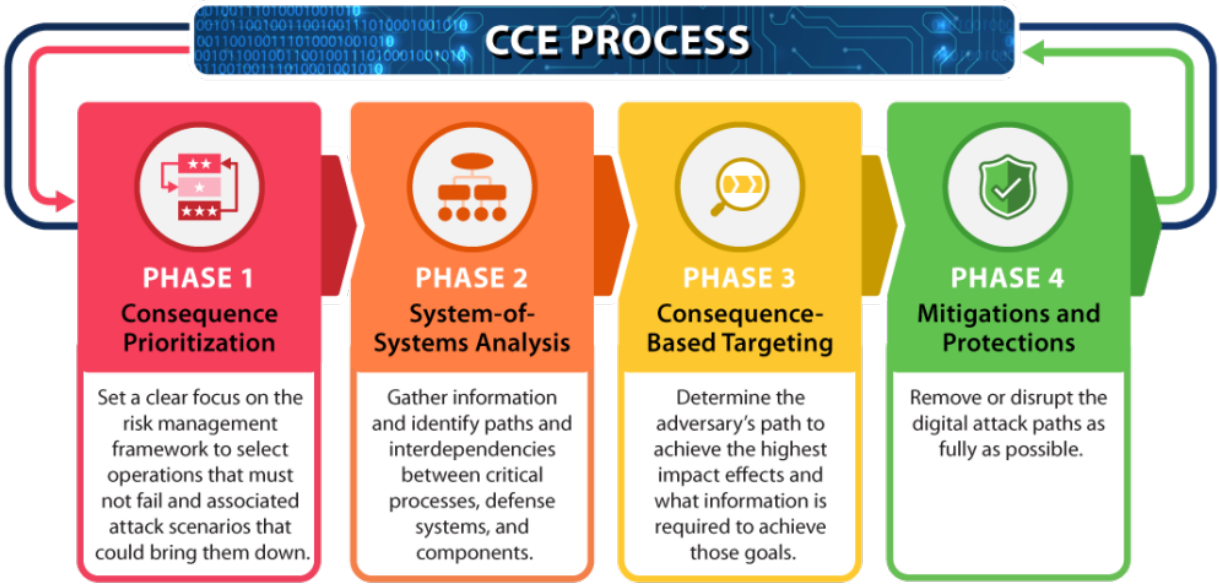


Figure 2.2: CCE 4-phase diagram (Freeman, Hill Johnson, and St. Michel, 2019)

CCE's four-phase structure demonstrates the same underlying logic that motivates this dissertation's own framework: consequence must be identified and prioritized *before* a system is evaluated for risk, and mitigation should be pursued via engineering-level design choices rather than compensating IT controls though patching layers. However, CCE, like the CIE principles, does not provide a quantitative scoring mechanism for evaluating a specific proposed engineering *change*. It is a qualitative, expert-driven strategy for assessing entire systems, not a repeatable, computable decision threshold for individual change proposals. This gap is developed further in Sec. 3.2.1.

2.3 Formal Parameter Mapping

The main concept on which this dissertation relies on is to understand how the digitalization of OT devices can influence the "Attack Surface." To do so there is the need to have something that can quantify the impact of this changes: a **metric**, that can be a measurement or a calculation. Fenton and Bieman (2015), define *measurement* as "the process by which numbers or symbols are assigned to attributes of entities in the real world in such a way so as to describe them according to clearly defined rules." A measure is deployed to frame important information (*attributes*) of a specific *entity* or *event* in the real world. An *attribute* is what helps distinguish an entity, or event, from one another. The main characteristic of a measurement is the capacity to avoid ambiguity when describing a specific attribute of a thing. Unlike common speech, it is unacceptable for scientific purposes to offer a broad description of the observed object (e.g., measuring a room, or telling the weather). The actual characteristic that gets "measured" is the attribute used to describe the entity or event (e.g., length, width, air temperature), and in order to do this, symbols or numbers are used (Fenton and Bieman, 2015). Such symbols or numbers are the abstraction used to describe the perception of the real world, reflecting a common pattern across the various entities or events. This provides a mechanism to empirically assess the comparison (difference or equality) between the subjects whose attributes are being measured, ultimately creating a relation between two or more things. It can be concluded that the accuracy of a measurement depends on the instrument used to perform the measurement or on the measurement itself.

The final aim, on which measurement science folklore also relies, is to gain control and understand things that still have not been conceptualized in a way that enables a measurement through a specific scale (that can also result in the making of a standardized *metric*).

In the context of cybersecurity, it is important to grasp the key implication of a measurement: making tangible what looks intangible, enabling the reduction of aleatoric uncertainty, and keeping the measure grounded and reliable.

Hubbard and Seiersen, experts in the field, wrote in one of their main publications that a measurement is "a quantitatively expressed reduction of uncertainty based on one or more observations." (Hubbard and Seiersen, 2023).

Applying this definition to cybersecurity helps to understand that observations can be translated into quantifiable data, and that the latter can be used to reduce uncertainty. Therefore, this mechanism drastically improves decision making, supporting the process with tangible evidence and a rationale, ultimately avoiding mistakes caused by subjective bias.

Universally, another main distinction can be noted when thinking of kinds of quantification: *measurement* and *calculation*. While *measurement* is the direct quantification of an attribute, *calculation* is indirect, because it takes several measurements as input to describe a specific attribute of an event or entity. To describe a particular scenario quantitatively, different measurements can be required to achieve a useful number that frames the bigger picture, rather than relying solely on qualitative data.

The aim of the dissertation is to create a calculation that involves different measurements based on observations, related to design philosophy concepts (CIE) and peer-reviewed papers (Wright et al., 2023; Friedberg et al., 2017). The measurements are weighted to give each component the right amount of relevance, proportionate to expert opinions and, subjectively, to specific companies' risk appetites. The final result will be a calculation that can be widely accepted as a description within critical OT change management scenarios, providing useful data to produce effective decision-making.

In order to do this, the following section will explain the scientific underpinning on which the development of the different measures that compose the final calculation relies.

2.3.1 Representational Measurement Theory (RMT)

The goal with a measurement is to control and understand a phenomenon perceived in the real world, creating a relationship between the observed events or entities to make them comparable. The creation of a metric involves a meticulous process, specifically applying the scientific method to achieve the versatility that a measurement requires to be widely accepted. The core of this activity is a rule-based approach, derived from physical sciences, that not only describes when and how to measure, but also provides guidance on how to analyse and depict data.

At this point, it is mandatory to explicitly state the measurement theory that will be used in this process. This is the *Representational Theory of Measurement* (RMT), whose objective is to formalize intuitions based on the perception of the *working world* (Krantz and Suppes, 1971). Originally formalized in the behavioural and physical sciences, RMT has become the gold-standard mathematical foundation for software and systems engineering metrics (Fenton and Bieman, 2015).

RMT has been chosen for designing the framework because it directly addresses a documented, recurring weakness in the cybersecurity risk assessment literature. Cherdantseva et al.'s systematic review of twenty-four cyber security risk assessment methods developed specifically for SCADA systems highlights that the quantitative risk, impact or attack surface calculation formulas used across these methods are "typically

not proved in a mathematical sense," with subjective, not globally acceptable, justifications claiming "intuitive meaning" supported by the analyst who designed them, but reviewers argue that "what is intuitive and clear vary from person to person" (Cherdantseva et al., 2016). Their broader conclusion, drawn from the SCADA risk assessment survey, is blunter still: methods for quantifying security risk in this domain are, in general, "weakly justified" (Cherdantseva et al., 2016). This is precisely the failure mode measurement scholars call a lack of *construct validity*: a scale that produces numbers without a demonstrable, principled link between those *numbers* and the real-world *attribute* they claim to represent. RMT specifically closes this gap: rather than leaving the mapping between an observed risk and its assigned score to intuition, it requires that the mapping is proved, not asserted.

RMT is the base on which the development of a measure relies, providing the mathematical opportunity to translate qualitative observations into tangible, computable data. Specifically, RMT dictates that quantifying information is a process that requires a *homomorphism* (a structure-preserving mapping) between two distinct systems: an **Empirical Relational System (ERS)** and a **Numerical Relational System (NRS)** (Krantz and Suppes, 1971).

To fully grasp how RMT operationalizes observations, these systems must be defined:

- **Empirical Relational System (ERS):** This system exists entirely in the real world, independent of numbers. It consists of a set of observable physical entities or events, and the empirical relations that govern them. For example, an engineer can observe that the physical damage caused by a turbine trip is empirically *less severe than* a total reactor shutdown. The relation exists purely through physical observation;

- **Numerical Relational System (NRS):** This system exists in the mathematical domain. It consists of a defined set of numbers (or symbols) and the mathematical relations between them, such as "is greater than" ($>$) or "is less than" ($<$);

The core mechanism of RMT is the *homomorphism*: the mapping function (f) that links the ERS to the NRS. According to measurement theory, if an event x is empirically observed to be less severe than event y (written as $x \prec y$, with "$\prec$" being "precedent", in the ERS), the number assigned to x must be strictly mathematically smaller than the number assigned to y in the NRS (written as $f(x) < f(y)$) (Fenton and Bieman, 2015).

As a result, in order to achieve *construct validity*, qualitative attributes cannot simply be assigned arbitrary scores based on subjective guessing. They must be mathematically operationalised through this strict mapping process. By defining a clear ERS and enforcing a homomorphism to an NRS, the framework guarantees that the resulting Ordinal Scales (Stevens, 1946) are objective, mathematically sound representations of physical engineering realities.

Chapter 3

Related Work

Chapter 2 presented the domain foundations CCIM builds on: systems-safety accident modelling (STAMP/STPA-SafeSec, Sec. 2.1.2), the IT/OT standards landscape (see Sec. 2.1.3.4), Cyber-Informed Engineering and CCE (see Sec. 2.2), and RMT (see Sec. 2.3.1). This chapter does not re-iterate that material, instead its aim is to position each strand of prior work against a single evaluative question: *does this work provide a quantitative OT change management strategy?* Table 3.1 summarizes the answer across five strands, while the discussion below justifies each row without re-introducing content already covered in Chapters 2 and 4.

3.1 Papers, Articles and Books

Systems-Safety and Accident Causation Models Leveson (2012) STAMP and Friedberg et al. (2017) STPA-SafeSec were introduced in Sec. 2.1.2 as they provide the hazard-and-loss taxonomy informing the Consequence Exposure (C) measurement (see Sec. 4.2.1.1). Evaluated against the criterion above, both are diagnostic rather than prescriptive: they identify *what* can go wrong in a cyber-physical system and *why*, at design or analysis time, however neither outputs a numeric score, nor addresses the narrower decision of whether a specific proposed *change* to an already-operating system should proceed. This is the gap CCIM's Attack Surface Delta Score is built to close (see Sec. 4.2.1).

Cyber-Informed Engineering and CCE Guidance Sec. 2.2 detailed the relevant CIE principles and the four-phase CCE methodology, including how Engineered Controls and Interdependency Evaluation underpinning the E, D and I measurements respectively (see Sec. 4.2.1.2, 4.2.1.3 and 4.2.1.4). The relevant observation for this related-work review is narrower: the CIE Implementation Guide is explicit that its principles function as engineering judgment guidelines, not a scoring methodology (Wright et al., 2023). It prescribes *what to consider* when evaluating a change but not *how to compute* whether a specific change

is acceptable, and Sec. 2.2.1.1 already illustrated that CIE's own treatment of change management is descriptive rather than computational. The framework proposed in this dissertation is not competing to CIE; it is the quantitative decision layer CIE's own change-management methodology presupposes but does not supply.

Single-Dimension Quantitative Security Metrics This section explores two papers that differ the qualitative pattern above and provide genuine quantitative models, however each is scoped to a single risk dimension. Manadhata and Wing (2011)'s *Attack Surface Metric* argues that a system's exploitability increases linearly with its count of communication channels, methods, and untrusted data items (Manadhata and Wing, 2011); this result is the direct mathematical grounding for the Digitalization (D) measurement (see Sec. 4.2.1.3).Rinaldi, Peerenboom, and Kelly (2001)'s *critical infrastructure interdependency theory* formally proves how tightly coupled infrastructures propagate cascading failures through shared logical dependencies (Rinaldi, Peerenboom, and Kelly, 2001), grounding the Interdependency (I) measurement (see Sec. 4.2.1.4). Nevertheless, neither paper addresses OT change management specifically proposing a measurement aggregation mechanism to produce a holistic, change-time acceptance or rejection, decision support tool; a function that CCIM's ASDS formula (see Sec. 4.2.1.5) performs.

Security Economics and Human-Centred Security Gordon and Loeb (2002)'s economic model of information security investment establishes that security-delegated budget should be linked to the expected loss it mitigates, formalized as a cost-benefit ratio subject to diminishing marginal returns (Gordon and Loeb, 2002). This ratio is the direct mathematical template for CCIM's Trade-off Index (see Sec. 4.2.2.3). Separately, Human-Computer Interaction in Security (HCISec) literature, Adams and Sasse's foundational study and Beautement et al.'s compliance-budget model, demonstrates that security controls introducing excessive operational friction are actively circumvented by users rather than followed (Adams and Sasse, 1999; Beautement, Sasse, and Wonham, 2008). This literature directly supports the Usability Score (US) variable (see Sec. 4.2.2.1). Both bodies of work are general-purpose decision models applicable to any security investment decision. In comparison to this literature, which is not specific to OT, nor to the moment of evaluating a proposed engineering change and not having models calibrated against real-world OT incident data, CCIM's contribution sits precisely in this spot. It combines these solutions in an holistic OT-specific model.

Standards-Based and Regulatory Change Governance Sec. 2.1.4 already established, with a supporting summary table (see Tab. 2.1), that ISO/IEC 27001, IEC 62443-2-1, NIST SP 800-82r3, and ISO/IEC 20000-1 all mandate a documented change management *process* without prescribing how the risk of an individual change should be quantitatively assessed. The UK Office for Nuclear Regulation's Security Assessment Principles (SyAPs)

reflect the identical pattern in a CNI-specific regulatory context: an outcome-focused framework of ten Fundamental Security Principles used by inspectors to judge the adequacy of a duty holder's security arrangements, including cyber security under FSyP 7 (Office for Nuclear Regulation, 2022). Like the standards reviewed in Chapter 2, SyAPs is deliberately non-prescriptive: adequacy is demonstrated qualitatively through submitted security plans and inspector judgement, not through a repeatable numeric threshold.

SCADA-Specific Risk Assessment Method Reviews Cherdantseva et al.'s systematic review of twenty-four SCADA system cyber risk assessment methods supplies the empirical proof for the gap this dissertation addresses (Cherdantseva et al., 2016). Reviewing methods published between 2004 and 2014 against eight criteria including *aim, application domain, risk-management stages addressed, key concepts covered, impact measurement, sources of probabilistic data, evaluation method, and tool support*, the authors in conclusion argued that the formulas used across these methods to quantify risk, impact, or attack probability are "typically not proved in a mathematical sense."

Evaluated against this chapter's own criterion, none of the twenty-four methods reviewed addresses the narrower, change-specific decision this dissertation targets. The review's own categorisation shows that methods concentrate mostly on the risk identification and risk analysis stages of the generic risk-management process, while risk evaluation receives "little or no attention." Furthermore, the review finds that evaluating a proposed method against real systems and expert judgement is uncommon, concluding that "it is easier to propose a method than to evaluate it in a sustainable rigorous manner." This confirms, from a dedicated systematic review rather than from this dissertation's own reading of the standards landscape, that the absence of a mathematically justified, repeatable decision threshold for OT risk scoring is a documented property of the field as a whole, not an isolated observation drawn from a small or convenient sample of sources.

Quantitative Risk and Measurement-Theoretic Literature Beyond the domain-specific literature above, the design of a defensible quantitative metric required consulting the measurement-science and decision-theory literature. Sec. 2.3.1 already introduced representational measurement theory (RMT) as formalized by Fenton and Bieman (2015) and by Krantz and Suppes (1971), and its role in justifying CCIM's ordinal scales (Fenton and Bieman, 2015; Krantz and Suppes, 1971; Stevens, 1946). Three further contributions from related literature shape specific design decisions elaborated in Chapter 4:

- Hubbard and Seiersen (2023)'s quantitative cybersecurity risk methodology, and Cox (2008)'s critique of risk matrices, jointly argue that ordinal risk-matrix scoring suffers from range compression and rank-order ambiguity, while they support empirical strategies like the Monte Carlo-based quantitative method used in this dissertation (Hubbard and Seiersen, 2023; Cox, 2008). This critique directly motivates CCIM's

decision to calibrate the decision threshold τ via Monte Carlo simulation (see Sec. 4.2.3.5) rather than using an arbitrary cut-off value;

- Saaty (1980)'s Analytic Hierarchy Process, as formalized practically by Kulakowski (2021), supplies the pairwise-comparison and eigenvector method used to derive normalized, consistency-checked weights for aggregating CCIM's four ordinal risk variables into the ASDS score without violating the mathematical limitations of ordinal scales (Saaty, 1980; Kulakowski, 2021) ;
- Fawcett (2006)'s introduction to ROC analysis provides the statistical basis for calibrating τ via Youden's J statistic on the simulated Trade-off Index distribution (Fawcett, 2006) (see Sec. 4.2.3.5).

While none of these three contributions is specific to OT, CPS, or to change management, each supplies a general-purpose mathematical tool that CCIM adapts to this dissertation's specific domain.

3.2 Synthesis: The Gap CCIM Addresses

Strand	**Representative Work(s)**	**Quantitative?**	**OT Change-Specific?**
Systems-safety modelling	STAMP; STPA-SafeSec	No	No
CIE guidance	CIE Implementation Guide; CCE	No	Partially (qualitative)
Single-dimension metrics	Attack Surface Metric; Interdependency Theory	Yes	No
Security economics / HCISec	Gordon-Loeb; Adams & Sasse; Beautement et al.	Yes	No
SCADA risk assessment reviews	Cherdantseva et al. (2016)	Mixed	No
Standards / regulatory guidance	ISO 27001; IEC 62443-2-1; SP 800-82r3; ISO 20000-1; SyAPs	No	Yes (procedurally)

Table 3.1: Related work evaluated against quantitative, OT change-specific decision capability.

No single strand in Table 3.1 satisfies both criteria simultaneously: the strands that are change-specific (standards and regulatory guidance) are procedural and qualitative, while the strands that are genuinely quantitative (single-dimension metrics) are not specific to OT management. CCIM is positioned at the intersection these strands leave unoccupied, synthesizing STAMP-grounded consequence reasoning, CIE-derived risk dimensions, single-dimension quantification methods (Manadhata and Wing, 2011; Rinaldi, Peerenboom, and Kelly, 2001), and Gordon-Loeb-style economic reasoning into a single, change-time, OT-specific decision threshold, calibrated against real incident and mitigation data via the Monte Carlo and Youden's J procedure detailed in Sec. 4.2.3.5. Cherdantseva et al. (2016)'s independent, dedicated review of the SCADA risk assessment literature corroborates this synthesis from within the domain itself: no surveyed combines a mathematically justified scoring procedure with a repeatable, change-specific decision threshold, confirming that the gap identified across the strands above is not an artefact of this dissertation's selection of literature but a documented property of the field (Cherdantseva et al., 2016).

3.2.1 Addressing the Gap in Change Management: CCIM

Sec. 2.1.4 and the paragraph on regulatory change governance (see Sec. 3.1) together establish that change management is a recurring concern, yet none of the reviewed instruments define *how* the impact of an individual proposed change should be quantitatively assessed. Each leaves this determination to the implementing organization, with no reference scoring method or decision threshold supplied.

Critically, this is not merely a limitation of the standards examined in this dissertation. Cherdantseva et al. (2016)'s systematic review showed that the same gap is independently documented within the academic literature itself and after an in-depth analysis of the papers, standards, and guidance documents that inform this domain, the same conclusion emerges from every direction examined: existing instruments either prescribe a change-management *process* without a computable scoring method, or supply a scoring method without a mathematically defensible justification. Neither category provides the OT change-management decision support tool that the gap exposed in this dissertation targets.

CCIM is designed to close this specific gap. The framework does not replace or compete with any standard summarized in Sec. 2.1.3.4, nor with the risk assessment methods catalogued by Cherdantseva et al. (2016); it adds the missing quantitative decision layer that their own change management requirements assume to be available but do not define, and it addresses directly the mathematical-justification weakness the review identifies by grounding every rubric anchor in RMT (see Sec. 2.3.1) rather than subjective intuition.

Instead of proposing another qualitative checklist, this dissertation contributes a quantitative extension of the change management concept already mandated, in skeletal form, across the reviewed standards and CIE. Where these standards require that a change be assessed and approved through a documented process, CCIM provides the computable criteria for that assessment: the Attack Surface Delta Score and the Trade-off Index, with its Monte Carlo-calibrated threshold τ (see Chapter 4). Those calculations are specifically adapted to the safety and availability constraints of OT environments in Critical National Infrastructure.

Chapter 4

CCIM Modelling

4.1 Introduction to CCIM Development

The **CIE-Informed Change Impact Metric** (CCIM) is designed to serve two distinct, yet complementary, audiences within an organization: compliance auditors and security engineers. Rather than replacing either function, CCIM sits between them, translating engineering judgment into evidence that both can use.

For **compliance auditing**, the framework provides a tool to demonstrate, with tangible numerical evidence, that a given system configuration remains compliant with the standard in force after a proposed change to an OT device has been implemented. Where an auditor's current recourse is often a qualitative checklist, confirming that a change management *process* was followed, without verifying the substantive risk of the change itself (see Sec. 2.1.4), CCIM supplies a concrete, calculable value that can be attached to the audit record as evidence, rather than assertion.

For **security engineers**, the framework provides the same numerical grounding to *support proposed changes* when presenting to board members or team leaders. Justifying a design decision on engineering judgment alone is a difficult position to defend under commercial or budgetary pressure (Hopkins, 2011; Bridewell, 2024); backing that judgment with a reproducible number gives the engineer a defensible artifact rather than an opinion. The same output additionally supports estimates made for *insurance* purposes, offering a documented rationale for why one system configuration was adopted in preference to another.

It is important to clarify what gap CCIM is, and is not, addressing. The issue is not that the checkbox, compliance-driven approach fails as a methodology across the board: encouraging a baseline compliance posture remains crucial, since it establishes a universal minimum standard of care, objectively guards against organizational negligence, and ensures that fundamental security hygiene is prioritized even under competing commercial pressures (Hopkins, 2011; Bridewell, 2024). Compliance, in other words, is a necessary pre-requisite, not a flawed concept.

What compliance alone cannot offer, however, is a way to compare quantitatively two equally compliant configurations and determine which one is actually safer. CCIM builds on top of this compliance floor by adding an engineering-focused, dynamic dimension: a metric that reflects the attack surface introduced or removed by a proposed change, evaluated across every relevant scenario in the change phase (e.g., pre-change baseline, post-change with Option 1, post-change with Option 2 etc.). In doing so, CCIM enables context-aware, risk-based decision-making for complex OT environments that a static compliance checklist, by design, cannot provide, even when every option under consideration is independently compliant with the same standard.

This distinction matters because it makes the purpose of the framework clear: CCIM does not exist to prove that a system is compliant, but to show, with tangible evidence, that one engineering choice is quantitively better than another, regardless of whether the first choice was already acceptable on paper. Providing this comparative capability requires first understanding where a system's weaknesses lie and what decisions were made at design time, since the framework can only evaluate a change meaningfully once the wider engineering picture is accounted for, not just the individual device being changed. Operationalizing this comparative capability requires two distinct calculations, developed in the body of this chapter.

The first, the **Attack Surface Delta Score ($ASDS$)**, is introduced in Sec. 4.2.1.5. $ASDS$ quantifies the attack surface of a proposed OT change by empirically combining the four risk-relevant vectors illustrated in the following section (see Sec. 4.2), grounded in the concepts explained in Chap. 2, deliberately preserving as much dimensional detail as possible rather than collapsing them prematurely into a single opaque value.

The second, the **Trade-off Index (T)**, is introduced in Sec. 4.2.2.3. T takes the $ASDS$ as its risk *numerator* and evaluates it against the operational and economic cost of the change, producing the specific figure this dissertation uses to decide whether a given engineering option is better than its alternatives during the change phase (Trade-Off Index).

Together, $ASDS$ and T form the computational core through which CCIM delivers the numerical evidence described above to both compliance auditors and security engineers alike. The remainder of this chapter contains a comprehensive illustration of the steps taken to output the CCIM framework, providing crucial design decision details to support the thought process behind the final product. Figure 4.1 formally shows how the created measurements collaborate through the Use-Factor-Criterion-Metric diagram. The diagram model is adapted from the one presented in Fenton and Bieman (2015)'s book on software metrics.

4.2 Metric Modelling and Theoretical Grounding

This section contains the illustration of the process behind the making of the CCIM framework. The model is composed by two main parts: the Attack Surface Delta Score ($ASDS$) and the Trade-Off Index (T). They are both holistically explored, spanning from

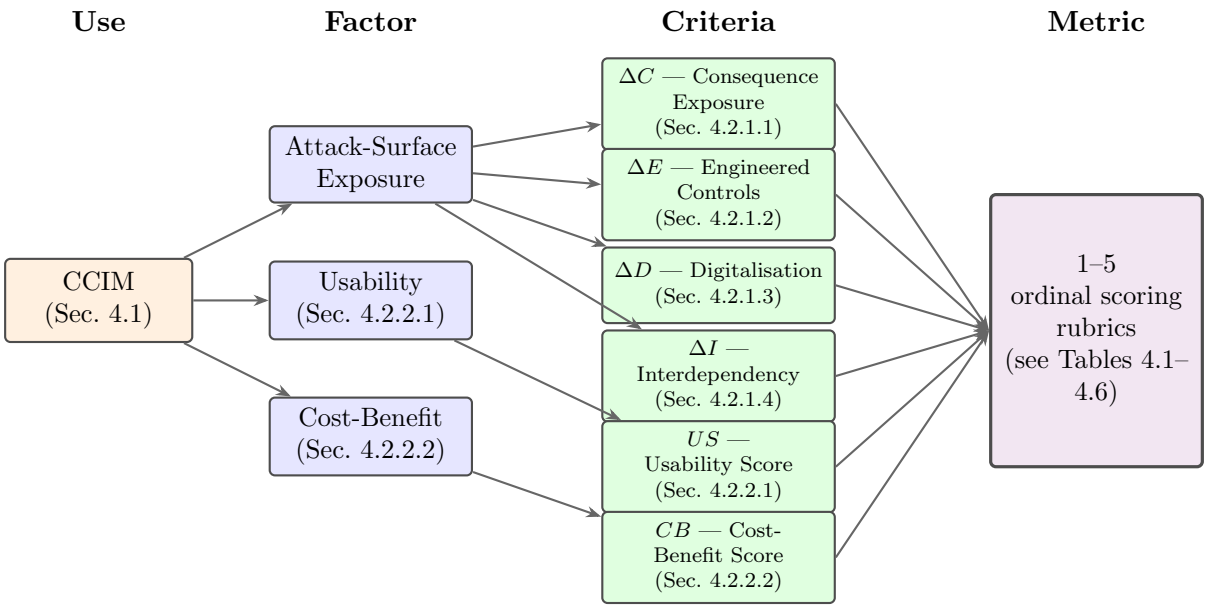


Figure 4.1: Formalization of the CCIM variables. The arrows denote "*is characterised by,*" not computation: the arithmetic combinations of $\Delta C, \Delta E, \Delta D, \Delta I$ into $ASDS$, and of $ASDS, US, CB$ into T, are separate steps defined respectively in Sec. 4.2.1.5 and Sec. 4.2.2.3, and are not represented in this diagram.

the standards that regulate OT management to the mathematical concepts that allow the measurements and calculation to be widely accepted. The foundations of the concept of measurement are explained in the literature background chapter (see Chap. 2 Sec. 2.3), while this section shows only the contribution. The main concept that the CCIM brings together is simply the ambition to be a quantitative tool for OT risk management that considers technical and contextual-specific aspects, enabling Subject Matter Experts (SMEs) to build the best tailored option for them, given the framework's versatility.

4.2.1 Attack Surface Delta Score (*ASDS*)

The ASDS metric derives from a systematic identification of the critical Operational Technology (OT) network dimensions that drive cyber-physical risk. To achieve this, the metric synthesizes system-theoretic models, engineering standards (e.g., NIST SP 800-82), and empirical analyses of real-world attacks (e.g., Stuxnet, NotPetya, the Maroochy Shire spill). By correlating Leveson (2012)'s STAMP hazard analysis with the Department of Energy's CIE Implementation Guide (Wright et al., 2023), four observable OT attributes consistently emerge as the primary risk vectors. To measure these vectors, the framework translates empirical observations of physical events into formal mathematical concepts.

Ultimately, this mapping yields an **Ordinal Scale** (Stevens, 1946; Krantz and Suppes, 1971), which serves as the foundational mechanism that validates the framework's core metric.

The rationale and literature foundations for the formulation of each measurement ($\Delta C, \Delta E, \Delta D, \Delta I$) are detailed in the next paragraphs. For each Δ score, each paragraph explains the reason it has been included in the CCIM, detailing crucial design choices and literature grounding. Subsequently, it shows how the observed entity/event is mapped through RMT, providing an overview of what has been done for each of the measurement in the related sections.

Consequence Exposure (Extended in Sec. 4.2.1.1) Considering the change management context, one of the most overlooked aspects is the consequence that the failure of a single component could have, in terms of physical and operational impact. Therefore this is a must to be included as a risk vector in the framework. The most fundamental shift in modern ICS security is the recognition that cyber risk must be measured by physical consequence, not just data confidentiality. This concept is heavily grounded in Consequence-Driven Cyber-Informed Engineering (CCE/CIE) (Wright et al., 2023; Freeman, Hill Johnson, and St. Michel, 2019) and (Leveson, 2012)'s STAMP framework.

In STAMP, Leveson proved that cyber-physical accidents are not merely IT failures, but "control problems" where a lack of constraints allows hazardous physical states (e.g., a reactor scram or turbine trip). Furthermore, the application of STPA-SafeSec to smart grids illustrated by Friedberg et al. (2017), empirically demonstrated that cyber-attacks translate directly into physical hazards (e.g., out-of-sync circuit breaker reclosure leading to equipment damage).

The natural question at this point is: *"How does this framework plan to measure consequence?"*. The answer to that question relies in the application of the notions from the literature on RMT (see Sec. 2.3.1), which mandates the identification of the three main dimensions that are needed to create a measurement (Krantz and Suppes, 1971). Thus, they can be listed as follows.

- *The Entity/Event*: The device change being evaluated;
- *The Attribute*: The worst-case physical or operational consequence if the component's digital controls are compromised;
- *The Empirical Mapping*: Derived directly from the hazard and loss categories identified in STPA-SafeSec (e.g., localized minor disruption vs. catastrophic loss of critical safety functions).

Engineered Controls (Extended in Sec. 4.2.1.2) Given that budget reduction and operational efficiency are primary drivers for OT modernization (Statista, 2024; Bridewell, 2024), digitalization often strips away traditional physical isolations, introducing collateral

security flaws. According to CIE Principle 2 ("Engineered Controls"), the most effective way to secure a system is to utilize the physical laws of engineering (e.g., mechanical pressure relief valves, hardwired analog relays) to constrain digital capabilities (Wright et al., 2023).

This is supported by empirical evidence from real-world attacks. For example, during the Maroochy Shire water treatment attack, the lack of analog backups allowed a remote attacker to continually dump sewage despite IT efforts to stop it (Slay and Miller, 2007). By definition, analog devices provide absolute network isolation. In the context of risk measurement, the "strength" of an engineered control dictates the difficulty an attacker faces in bypassing it.

As already afore-mentioned, in order to measure the risk vector also in this case, it is necessary to identify the three main dimensions that are needed to create a measurement (Krantz and Suppes, 1971):

- *The Entity/Event*: The safety or operational control protecting the process;
- *The Attribute*: The physical "strength" and isolation level of the control;
- *The Empirical Mapping*: A scale grading controls spanning from purely digital/software-based (easily bypassed remotely) to purely mechanical/analog (impossible to bypass via cyber-attack).

Digitalisation (Extended in Sec. 4.2.1.3) While intrinsically linked to engineered controls, *digitalisation* specifically shifts the focus to the type of network connection a certain OT device has in a segment. According to CIE Principle 8 ("Digital Asset Awareness", Sec.2.2), to manage at best the systemic risk, it is crucial to understand what kind new digital functions or paths are created and if there are any new external trust boundaries (Wright et al., 2023). This rationale is confirmed by the paper presenting the **Attack Surface Metric** authored by Manadhata and Wing (2011), which established that the probability of exploitation increases linearly with the number of communication channels, open ports, and protocol interfaces.

In traditional OT environments, devices were air-gapped. However, the modern push for Industry 4.0 requires bi-directional data flow between untrusted corporate IT networks and trusted OT segments (Statista, 2024; Kagermann, Wahlster, and Helbig, 2013). As highlighted in the analysis of the 2015 Ukraine Power Grid attack (SANS ICS and E-ISAC, 2016), the attackers utilized routable digital pathways from the corporate IT network directly to the SCADA breakers.

For this risk vector as well, the three main characteristics that inform the measurement need to be identified. Keeping the logic the same as the previous paragraphs, according to the RMT notions and observations, the three characteristics have been described as follows:

- *The Entity*: The specific OT device or system undergoing change;
- *The Attribute*: The level of digital connectivity and routability;

- *The Empirical Mapping*: A scale moving from strictly air-gapped serial connections to bi-directional, IP-routable connections spanning across untrusted IT boundaries.

Interdependency (Extended in Sec. 4.2.1.4) The final attribute addresses the logical dependencies of OT devices, grounded in CIE Principle 7 ("Interdependency Evaluation"). Traditional risk metrics often fail to account for how a device relies on external services (e.g., Active Directory, NTP servers, remote vendor diagnostics) to function properly.

The catastrophic impact of interdependencies was empirically demonstrated during the 2017 NotPetya attack on Maersk. As documented in the case study of published by the Columbia University (Steinberg, Stepan, and Neary, 2021), the infection of IT infrastructure (Active Directory) completely paralysed physical OT logistics operations because the OT terminals were logically dependent on IT authentication to function. Critical infrastructure theory (Rinaldi, Peerenboom, and Kelly, 2001), also confirms that logical interdependencies create hidden vectors for cascading failures.

Logically, for this risk vector the same procedure has been adopted, identifying the RMT-dictated three main characteristic to measure it as follows:

- *The Entity*: The OT device or process;
- *The Attribute*: The degree of reliance on external, potentially untrusted services for core functionality;
- *The Empirical Mapping*: A scale grading the system from autonomous, self-sufficient operation to total dependence on continuous external IT/cloud connectivity.

In the following sections each risk vector is extended and mathematically justified, in order to present an accurate and detailed explanation.

4.2.1.1 ΔC - Consequence Exposure

Let E represent the set of observable physical consequences in a Cyber-Physical System (CPS).

Let $\prec$ represent the empirical relation *"is physically and arguably less severe than"*.

The mapping function $f : E \to \mathbb{N}$ strictly preserves *monotonicity* such that for any two physical events $x, y \in E$: $x \prec y \Rightarrow f(x) < f(y)$

Following CCE/CIE Principle 1 Wright et al. (2023) and Freeman, Hill Johnson, and St. Michel (2019) and based on systems-safety theory, STAMP, Leveson (2012), it can be easily understood that the starting point of the analysis must be the physical process, and in this phase the main concept to be considered is that the severity is determined by the consequence caused by the disruption of a physical process. The extent to which the disruption progresses is what the scale represents, spanning from isolated faults (e.g. single sensor malfunction) to systemic catastrophic failures (e.g., loss of main functions, in terms of safety or uptime).

The STPA-SafeSec paper, based on Leveson's work, provides the Hazard and Loss definitions, applied to CPS (Friedberg et al., 2017).

Table 4.1 in the next page, illustrates the formal mapping between the ERS and NRS, also providing an empirical justification and an example, operationalizing the relation into a 1-to-5 ordinal scale, for consequence exposure (ΔC).

There are some details that are recurrent also in the other measurements that will be explored in the following paragraphs, clarifying the choices made until now and providing extra information about the rationale.

Empirical Mapping Calibration: Looking at table 4.1 it can be observed that there are 5 different ranks representing the **NRS** to be mapped to different **ERS**. The **ERS** has this order since the it has been empirically calibrated relying on observed and plausible use cases assigning concrete examples to elaborate on when measuring the event (based on Leveson's STAMP theory of physical constraints). For example, comparing *rank 4* to *rank 5*: the difference is evident, because an event *ranked 4* is equivalent to primary production asset losses (economical loss due to interruption of uptime, e.g., turbine trip) while *rank 5* events are about loss of safety functions that threaten human life or total disruption.

For instance, a turbine trip (*rank 4*, strictly economical loss) is empirically less severe than a reactor scram (*rank 5*, loss of a fundamental safety feature).

Therefore, to satisfy the *homomorphism*: $x \prec y \Rightarrow f(x) < f(y)$, the reactor scram must receive a strictly higher numerical rank on the ordinal scale.

Rank (NRS)	**Event Description (ERS)**	**Empirical Justification (Why is this rank X?)**	**Example**
1	Negligible / Localized IT Impact	The event is strictly confined to the IT boundary. There is no empirical alteration to the OT physical state or process physics.	Corporate email outage; isolated HMI freeze with physical backups intact.
2	Minor OT Disruption (Recoverable)	The event crosses into the OT boundary but is empirically bounded. Redundancy systems handle the fault without interrupting primary process flow.	Loss of a redundant PLC; temporary loss of non-critical telemetry.
3	Moderate Process Degradation	The event empirically degrades process efficiency or quality but remains within safe operational limits. Equipment operates but sub-optimally.	Manipulation of setpoints causing efficiency loss; forced manual override of a valve.
4	High Impact (Equipment Damage)	The event forces the physical process outside of operational limits, resulting in the empirical shutdown or damage of primary production assets.	Turbine trip due to overspeed; destruction of a localized pumping station.
5	Catastrophic (Safety / System Loss)	The event empirically defeats foundational safety functions, threatening human life, environmental containment, or total loss of the facility.	Reactor scram; total loss of ultimate heat sink; bypass of Safety Instrumented Systems (SIS).

Table 4.1: Formalization of Consequence Exposure (ΔC)

Ordinal Scale discussion: Last but not least, another aspect to explore is the ordinal scale debate, since in risk management this type of scale is heavily criticized (Hubbard and Seiersen, 2023; Cox, 2008).

Cox and Hubbard opinions on ordinal scales both converge on the same concept: they are misleading since the *"distance"* between the different ranks is not the same. For instance, the distance between 1 and 2 (e.g., loss of $10 and $100) is different from the distance between 4 and 5 (e.g., loss of $1 million and $1 billion). This characteristic is described as ***range compression*** *(loss of resolution).*

The biggest issue with it eventually arises when using ordinal scales in risk matrices, where different ordinal scales (e.g., likelihood and consequence) are *multiplied*, expanding even more the original error of representation. Finally, it is important to mention that part of the debate on ordinal scales is also caused by the constant presence of **subjective bias**.

It is observable since, typically, the interlocutor when asked to rank something on a scale from 1 to 5 gives an answer based on gut feeling, recency bias, or how much budget they want, rather than a well-reasoned and considered response grounded in objective criteria.

Beginning from the theoretical background of the developed metrics, **RMT** dictates a strict anchoring of the 1-5 scale to physical, verifiable states. That is why, for instance, ΔC's scores are strictly anchored to verifiable (observable) physical states (Friedberg et al., 2017; Leveson, 2012), forcing objective judgment rather than subjective guessing.

Moreover, the final CCIM framework's formula utilizes the ***Analytic Hierarchy Process*** *(AHP)* (Kulakowski, 2021; Saaty, 1980), that also solves the multiplication issue, allowing the aggregation of different ordinal scales through weighted sums. It will be mathematically demonstrated in the following sections (4.2.1.5).

4.2.1.2 ΔE - Engineered Controls

Let E represent the set of security and safety controls applied to an Operational Technology (OT) process.

Let $\prec$ represent the empirical relation *"is physically and arguably less resilient against cyber-attack than"*.

The mapping function $f : E \to \mathbb{N}$ strictly preserves *monotonicity* such that for any two controls $x, y \in E$: $x \prec y \Rightarrow f(x) < f(y)$

The foundation of this measurement relies on the U.S.A. Department of Energy's *Cyber-Informed Engineering (CIE) Implementation Guide* (Wright et al., 2023). Fundamentally, the resilience of a system against cyber threats is dictated by the physical characteristics of the controls, shifting the focus from the IT security aspect towards the robustness a control can offer against CPS manipulation. The CIE Principle 2, "Engineered Controls," dictates that the best defence against cyber-physical tampering is the integration of analog or mechanical protections that are independent from programmable logic (e.g., PLCs, SCADA).

This rationale is heavily supported by the empirical analysis of real world scenarios. For instance, the Maroochy Shire sewage spill is the perfect fit to explain why the lack of engineered controls equipped with physical isolation mechanisms. In 2007, a former employee with an unresolved grievance exploited stolen radio equipment to issue digital SCADA commands that released millions of litres of raw sewage into the city waterways (Slay and Miller, 2007). According to the reports, it can be observed that this catastrophic event was uniquely enabled by the non-existence of analog overrides; the IT centric architecture had inadequate countermeasures against digital commands. On the other hand, mechanical safety mechanisms operate entirely outside the reach of digital derived compromise, enabling absolute network isolation.

Therefore, in this measurement context, the *attribute* being quantified is the "strength" of the engineered control, that spans from purely software-defined configurations (highly susceptible to remote cyber-attacks) to purely physical/mechanical constraints (immune to cyber-attacks).
Table 4.2 in the next page, illustrates the formal mapping between the ERS and NRS, operationalizing the relation into a 1-to-5 ordinal scale for Engineered Controls (ΔE).

Rank (NRS)	**Event Description (ERS)**	**Empirical Justification (Why is this rank X?)**	**Example**
1	Purely Digital / Software Control	The control exists entirely within programmable logic and shares the same execution environment as the threat. It provides negligible physical resilience against a remote attacker.	Logic interlock within a PLC; software-defined alarms in an HMI.
2	Segmented Digital Control	The control relies on digital processing but operates on a physically segregated microcontroller or dedicated Safety Instrumented System (SIS) separate from the primary control loop.	Dedicated SIS PLC; digital out-of-band monitoring node.
3	Hybrid Physical/Digital Redundancy	The control requires both a digital command and a secondary, distinct physical or human action to execute. It forces the attacker to bridge the cyber-physical gap.	"Man-in-the-loop" approval; mechanical key-switch required to upload PLC firmware.
4	Hardwired / Analog Control	The control uses electrical circuits but lacks programmable microprocessors. It cannot be altered via network commands.	Hardwired electromechanical relays; analog thermal trip switches.
5	Purely Mechanical / Passive Physical Dynamics	The control relies entirely on the immutable laws of physics (e.g., thermodynamics, fluid dynamics).	Mechanical pressure relief valves; physical rupture disks; concrete containment walls.

Table 4.2: Formalization of Engineered Controls (ΔE)

As with ΔC (4.2.1.1), the **ERS** ranks for ΔE are derived from verifiable physical realities rather than subjective IT security heuristics. In traditional information security, a firewall might be considered a "strong" control. However, within the CIE framework and the STAMP accident model, a firewall is merely software that can be misconfigured or bypassed by an Advanced Persistent Threat (APT).

The empirical justification for the scale relies on the concept of *attack state-space*. An engineered control is ranked higher because it categorically removes the environment needed for cyber manipulation. For instance, comparing *rank 1* to *rank 5*: a logic interlock written in PLC software (*rank 1*) can be remotely rewritten if an attacker gains engineering workstation access (as demonstrated by the Stuxnet malware). In contrast, a mechanical pressure relief valve (*rank 5*) functions based solely on fluid pressure. To defeat a *rank 5* control, a cyber attacker would have to physically walk into the facility and weld the valve shut.

Therefore, a hardwired relay (*rank 4*, immune to network traffic) is empirically more resilient than a physically segregated digital SIS (*rank 2*, susceptible to specialized network exploitation like the TRITON malware).

To satisfy the *homomorphism*: $x \prec y \Rightarrow f(x) < f(y)$, the physical/analog control must receive a strictly higher numerical rank on the ordinal scale.

It is critical to note that within the final ASDS formula (detailed in Sec. 4.2.1.5), ΔE serves a unique mathematical function: while $\Delta C, \Delta D$, and ΔI represent *risk vectors* that increase the total score, ΔE acts as a dampening coefficient. Because the presence of strong physical controls limits the attack state-space, it is mathematically structured as a denominator, effectively reducing the measurable cyber-physical risk introduced by digitalization (ΔD).

4.2.1.3 ΔD - Digitalization

Let E represent the set of network connectivity architectures and digital communication pathways for an Operational Technology (OT) device or segment.

Let $\prec$ represent the empirical relation *"exposes a mathematically smaller attack surface and fewer exploitation vectors than"*.

The mapping function $f : E \to \mathbb{N}$ strictly preserves *monotonicity* such that for any two network architectures $x, y \in E$: $x \prec y \Rightarrow f(x) < f(y)$

While intrinsically linked to the concept of engineered controls (ΔE), the ΔD metric specifically isolates and quantifies the network connectivity and digital exposure of a system. The theoretical foundation for this metric is the Attack Surface Metric developed by Manadhata and Wing (2011). In their seminal paper in the *IEEE Transactions on Software Engineering*, Manadhata and Wing mathematically demonstrated that a system's vulnerability to compromise increases linearly with its "attack surface"—defined as the sum of its open communication channels, protocol interfaces, and untrusted network access points (Manadhata and Wing, 2011).

In traditional OT environments, industrial control systems were physically isolated ("air-gapped") and communicated via proprietary, un-routable serial protocols (e.g., Modbus RTU). However, the modernization of critical infrastructure (Industry 4.0) has driven a convergence between IT and OT, replacing serial cables with bi-directional, IP-routable connections (e.g., Modbus TCP over Ethernet) to facilitate remote monitoring and corporate data analytics.

This digitalization inherently expands the attack surface, creating direct pathways from untrusted corporate IT networks into trusted physical OT segments. The catastrophic consequences of this architectural shift were empirically demonstrated during the 2015 Ukraine Power Grid attack. Russian state-sponsored actors compromised the corporate IT network and utilized routable digital pathways (VPNs and remote desktop protocols) to directly access the SCADA network, remotely opening circuit breakers and plunging 225,000 customers into darkness (SANS ICS and E-ISAC, 2016). If the SCADA breakers had utilized un-routable serial connections, the remote cyber-attack would have failed at the IT/OT boundary.

Therefore, in this measurement context, the *attribute* being quantified is the level of digital connectivity and IP-routability, scaling from strictly air-gapped, isolated architectures (minimal attack surface) to fully connected, bi-directional cloud/IT integrations (maximum attack surface).
Table 4.3 in the next page, illustrates the formal mapping between the ERS and NRS, operationalizing the relation into a 1-to-5 ordinal scale for Digitalization (ΔD).
As established by Manadhata and Wing (2011), the measurement of an attack surface is objective and independent of the perceived "quality" of the software running on the device. An architecture is ranked higher on the ΔD scale simply because the introduction of bi-directional, IP-based routing empirically provides a cyber adversary with the necessary logical pathways to deliver malicious payloads and execute unauthorized commands.

For example, comparing *rank 2* to *rank 4*: an outbound-only connection via a hardware data diode (*rank 2*) physically drops all incoming TCP/IP packets, meaning a remote attacker cannot send a command to the device, regardless of whether a vulnerability exists in its firmware. Conversely, a bi-directional IT/OT connection (*rank 4*) must accept incoming packets to function, meaning the attacker now has a functional pathway to interact with the device's firmware and exploit vulnerabilities.

Therefore, an air-gapped serial connection (*rank 1*) exposes an empirically smaller attack surface than a cloud-connected Industrial Internet of Things (IIoT) device (*rank 5*). To satisfy the *homomorphism*: $x \prec y \Rightarrow f(x) < f(y)$, the highly connected, routable architecture must receive a strictly higher numerical rank on the ordinal scale, representing a quantitative increase in the inherent cyber-physical risk vector.

Rank (NRS)	**Event Description (ERS)**	**Empirical Justification (Why is this rank X?)**	**Example**
1	Total Air-Gap / Unroutable Serial	The device has zero physical or logical connections to an external network. Communication relies exclusively on localized, non-IP serial protocols.	Standalone Modbus RTU PLC; hardwired analog sensor. The remote attack surface is empirically zero.
2	Unidirectional Outbound (Data Diode)	The device connects to a wider network, but physics-based optical hardware (data diodes) strictly limits communication to outbound telemetry only.	Sensor pushing telemetry to an IT historian via a hardware data diode. Inbound remote commands are physically impossible.
3	Segmented IP / Read-Only Polling	The device utilizes routable IP protocols but is strictly segmented behind strict access control lists (ACLs).	OT historian polling a PLC; Communication is restricted to read-only Modbus TCP queries.
4	Bi-Directional OT/IT Control	The device accepts bi-directional, state-altering commands (read/write) from a higher-tier (less trusted) network segment.	HMI in the DMZ issuing set-point changes to a SCADA controller.
5	Direct External / Cloud Connectivity	The OT device maintains a direct, bi-directional, routable connection to the public Internet, third-party vendor networks, or cloud environments, exposing maximum attack surface.	IoT smart sensor with direct 5G cloud uplink; remote vendor VPN directly to a PLC.

Table 4.3: Formalization of Digitalization / Attack Surface (ΔD)

4.2.1.4 ΔI - Interdependency

Let E represent the set of logical and operational dependencies an Operational Technology (OT) device has on external systems or services to function properly.

Let $\prec$ represent the empirical relation *"is empirically less logically dependent on external, potentially vulnerable services than"*.

The mapping function $f : E \to \mathbb{N}$ strictly preserves *monotonicity* such that for any two operational states $x, y \in E$: $x \prec y \Rightarrow f(x) < f(y)$

It is critical to distinguish Interdependency (ΔI) from Digitalization (ΔD). While ΔD measures the physical or network-level attack surface, ΔI quantifies the *logical reliance* of the system. This metric is grounded in the foundational Critical Infrastructure Interdependency Theory established by Rinaldi, Peerenboom, and Kelly (2001) in the *IEEE Control Systems Magazine*. Rinaldi et al. established that tight logical interdependencies between distinct infrastructures create hidden vectors for *cascading failures*, where an isolated fault in one system propagates unpredictably into another (Rinaldi, Peerenboom, and Kelly, 2001).

This concept is formalized in modern engineering through CIE Principle 7, "Interdependency Evaluation" (Wright et al., 2023). Traditional risk assessments frequently overlook how seemingly isolated OT devices covertly rely on enterprise IT services (e.g., Active Directory (AD), Network Time Protocol (NTP), Domain Name System (DNS), or remote license servers) to execute their physical processes.

The catastrophic potential of these logical interdependencies was empirically highlighted during the 2017 NotPetya attack on the A.P. Moller-Maersk global logistics network (Steinberg, Stepan, and Neary, 2021). The NotPetya malware did not specifically target the physical OT cranes or terminal operating systems; instead, it wiped the corporate IT Active Directory domain controllers. However, because the physical OT logistics systems were *logically dependent* on IT authentication to authorize container movements, the physical ports ceased to function entirely. The attack bypassed OT perimeter security completely by exploiting a shared logical dependency.

Therefore, in this measurement context, the *attribute* being quantified is the degree of functional reliance on external services, scaling from entirely autonomous, self-sufficient operation (immune to cascading failures) to total dependence on continuous external/cloud IT infrastructure.

Table 4.4 illustrates the formal mapping between the ERS and NRS, operationalizing the relation into a 1-to-5 ordinal scale for Interdependency (ΔI).

Rank (NRS)	**Event Description (ERS)**	**Empirical Justification (Why is this rank X?)**	**Example**
1	Autonomous / Fully Self-Sufficient	The physical process requires zero external logical inputs to operate safely.	Standalone PLC with hardcoded local logic; mechanical flow-control loop. Safe local operation.
2	Localized OT Dependency	The device relies on external services, but those services are strictly contained within the same trusted OT segment. Cascading failures are bounded to the local environment.	Dependency on a local OT NTP server for time-sync; local OT historian.
3	Non-Critical IT Dependency	The device connects to higher-tier IT services for auxiliary functions (e.g., logging, remote telemetry), but primary physical operations continue uninterrupted if the IT connection fails.	Pushing diagnostic logs to an enterprise IT SIEM; remote backup servers.
4	Critical IT / Enterprise Dependency	The physical OT process logically requires continuous or frequent validation from enterprise IT services. Loss of IT infrastructure halts or severely degrades the physical process.	OT HMIs requiring IT Active Directory (AD) authentication to operate; IT-hosted DNS/DHCP.
5	External / Cloud / Vendor Dependency	The OT process is entirely dependent on external wide-area network (WAN) connectivity, third-party vendor APIs, or Cloud SaaS environments.	Cloud-hosted SCADA analytics driving live setpoints; vendor-managed IIoT processing. Loss of Internet equals loss of physical control.

Table 4.4: Formalization of Interdependency (ΔI)

By anchoring the ΔI scale to verifiable operational realities, the framework eliminates subjective speculation regarding "how bad" a network outage might be. The metric simply asks: *What happens to the physical process if the external dependency is removed?*

For example, comparing *rank 3* to *rank 4*: if an OT sensor loses its connection to an enterprise logging server (*rank 3*), the engineering process physics remain unaffected. However, if an OT operator workstation relies on an enterprise IT Active Directory server to authenticate safety override commands (*rank 4*), the loss of the IT server actively prevents the operator from intervening in the physical process. This exact cascading failure mechanism was responsible for massive economic losses during the Maersk NotPetya incident.

Therefore, a self-sufficient PLC (*rank 1*) is empirically less susceptible to cascading logical failures than a Cloud-dependent IIoT controller (*rank 5*). To satisfy the *homomorphism*: $x \prec y \Rightarrow f(x) < f(y)$, systems with critical reliance on external infrastructures must receive a strictly higher numerical rank on the ordinal scale, accurately reflecting the increased likelihood of a cascading cyber-physical failure.

4.2.1.5 *ASDS* - Final Formula and Demonstration

Now that the theoretical grounding has been extensively explored to navigate the making process of the various measurements, the final Attack Surface Delta Score formula can be explained:

$$ASDS = w_1\Delta C + w_2\left(\frac{1}{\Delta E + 1}\right) + w_3\Delta D + w_4\Delta I \tag{4.1}$$

The ASDS is a *calculation* that combines together three risk vectors ($\Delta C, \Delta D$, and ΔI) that increase the total score and ΔE which is mathematically inverted to act as a dampening coefficient representing security resilience, but still represents another risk-relevant term in the formula. In order to address the challenge of combining ordinal scales (specifically the "illegal multiplication" and range compression problems) explained in Sec. 4.2.1.1, the values are aggregated together via a *weighted sum*, which is grounded in the **Analytic Hierarchy Process (AHP)** (Kulakowski, 2021; Saaty, 1980).

AHP is a Multi-Criteria Decision Making (MCDM) method designed specifically to evaluate complex, multi-dimensional problems. It mathematically proves that discrete ordinal values can be legitimately aggregated into a continuous ratio-scale vector, provided that the criteria are assigned normalized weights derived from a *pairwise comparison matrix* (Kulakowski, 2021).

In the context of the CCIM framework, not all facilities view risk equally. A nuclear power plant may prioritize Consequence (ΔC) exponentially higher than a commercial manufacturing plant. AHP allows individual OT environments to calibrate the formula to their specific risk appetite by calculating the weights (w_1, w_2, w_3, w_4) through pairwise comparisons.

Demonstration of AHP Weight Derivation: To calculate the weights, the organization's SMEs must compare the relative importance of the four variables against one another using Saaty's Fundamental Scale (typically 1 to 9) (Saaty, 1980).

Let C represent an $n \times n$ reciprocal pairwise comparison matrix (where $n = 4$ for the four ASDS variables).

If an expert determines that Consequence (ΔC) is exactly three times more important than Digitalization (ΔD), the matrix entry $c_{1,3}$ becomes 3, and its reciprocal $c_{3,1}$ automatically becomes 1/3 (Kulakowski, 2021).

An example 4×4 matrix C constructed by an organization might look like this:

$$C = \begin{pmatrix} 1 & c_{1,2} & c_{1,3} & c_{1,4} \\ 1/c_{1,2} & 1 & c_{2,3} & c_{2,4} \\ 1/c_{1,3} & 1/c_{2,3} & 1 & c_{3,4} \\ 1/c_{1,4} & 1/c_{2,4} & 1/c_{3,4} & 1 \end{pmatrix} = \begin{pmatrix} 1 & 2 & 3 & 4 \\ 1/2 & 1 & 2 & 3 \\ 1/3 & 1/2 & 1 & 2 \\ 1/4 & 1/3 & 1/2 & 1 \end{pmatrix} \tag{4.2}$$

According to AHP theory, the optimal priority weights (w) are extracted by calculating the principal right eigenvector (w_{max}) of matrix C, corresponding to its largest eigenvalue (λ_{max}) (Kulakowski, 2021):

$$Cw = \lambda_{max} w \tag{4.3}$$

To extract this eigenvector practically, the AHP methodology utilizes a normalization and row-averaging algorithm. First, the sum of each column j in matrix C is calculated. Then, every entry $c_{i,j}$ is divided by its respective column sum to create a normalized matrix C_{norm}, where every column sums exactly to 1.0.

$$C_{norm} = \begin{pmatrix} 0.480 & 0.522 & 0.462 & 0.400 \\ 0.240 & 0.261 & 0.308 & 0.300 \\ 0.160 & 0.130 & 0.154 & 0.200 \\ 0.120 & 0.087 & 0.077 & 0.100 \end{pmatrix} \tag{4.4}$$

By calculating the arithmetic mean of each row in C_{norm}, we derive the normalized principal eigenvector (where $\sum w_i = 1$). This vector provides the exact fractional weights for the ASDS formula. For the example matrix above, the resulting priority vector w is:

$$w = \begin{pmatrix} w_1(\Delta C) \\ w_2(\Delta E) \\ w_3(\Delta D) \\ w_4(\Delta I) \end{pmatrix} = \begin{pmatrix} \frac{0.480+0.522+0.462+0.400}{4} \\ \frac{0.240+0.261+0.308+0.300}{4} \\ \frac{0.160+0.130+0.154+0.200}{4} \\ \frac{0.120+0.087+0.077+0.100}{4} \end{pmatrix} \approx \begin{pmatrix} 0.467 \\ 0.277 \\ 0.160 \\ 0.095 \end{pmatrix} \tag{4.5}$$

Because these weights sum to exactly 1.0 (with negligible rounding variance), they can be safely injected into the ASDS formula (4.1).

Mathematical Validation and Consistency Ratio (CR): One of the fundamental strengths of AHP is its ability to mathematically identify subjective bias and logical contradictions within the expert's judgments after going through the weight calibration process. If an expert judges A to be strictly more important than B, and B strictly more important than C, logic dictates that A must be significantly more important than C.

Saaty (1980) established that in a perfectly consistent matrix, the largest eigenvalue (λ_{max}) will equal the exact number of criteria (n). Any inconsistencies in human judgment will cause λ_{max} to deviate from n. We can find λ_{max} by calculating the dot product of the original matrix C and the priority vector w, and taking the average of the resulting elements divided by their corresponding w_i:

$$\lambda_{max} = \frac{1}{n}\sum_{i=1}^{n}\frac{(Cw)_i}{w_i} \approx \frac{4.027 + 4.027 + 4.025 + 4.038}{4} = 4.029 \tag{4.6}$$

Using λ_{max}, the framework evaluates the logical validity of the expert's input by calculating the *Consistency Index (CI)*:

$$CI = \frac{\lambda_{max} - n}{n - 1} = \frac{4.029 - 4}{4 - 1} = \frac{0.029}{3} \approx 0.0096 \tag{4.7}$$

Finally, to determine if this error margin is acceptable, the CI is compared against a standard Random Index (RI), that provides the average CI of millions of randomly generated matrices. For $n = 4$, Saaty (1980)'s established RI constant is 0.90. This yields the final *Consistency Ratio (CR)*:

$$CR = \frac{CI}{RI} = \frac{0.0096}{0.90} \approx 0.011 \tag{4.8}$$

The strict mathematical threshold established by AHP theory mandates that the Consistency Ratio must be ≤ 0.10 (10% error tolerance). If the CR exceeds this threshold, the matrix is deemed mathematically contradictory, and the SME must re-evaluate their pairwise judgments (Kulakowski, 2021).

In the demonstrated example, $CR = 0.011$ (1.1%), which is well below the 0.10 threshold. This provides mathematical evidence that the expert's subjective engineering intuition was highly consistent, thereby validating the extracted weights (w) as objective mathematical constants for the ASDS framework.

By utilizing AHP to derive the weights, the ASDS framework achieves several critical mathematical proofs:

Avoidance of Illegal Multiplication: By using a weighted linear combination instead of direct multiplication (e.g., Likelihood × Consequence), the formula strictly respects the mathematical limitations of ordinal scales (Cox, 2008).

Resolution of Subjectivity: The priorities are not arbitrarily guessed. They are derived from the mathematical consistency of the pairwise matrix. AHP allows for the

calculation of a Consistency Ratio (CR); if the CR exceeds 0.10, the expert's judgments are deemed mathematically contradictory and must be re-evaluated (Kulakowski, 2021).

The ASDS is a continuous variable that serves as the precise mathematical input required for the subsequent Gordon-Loeb derived Trade-off Index (T) calculation, successfully bridging the gap between qualitative engineering observations and quantitative risk calculation. The latter calculation is illustrated in the next section.

4.2.2 Trade-off Index (T)

An in-depth analysis of the cyber-physical risk literature reveals that engineering decisions are rarely made based solely upon achieving a theoretical maximum level of security. As established in the economics of information security by Gordon and Loeb (2002), maximizing security is economically irrational; organizations are constrained by diminishing marginal returns, meaning the financial budget assigned by management acts as a primary limiting factor (Gordon and Loeb, 2002). Furthermore, research in Human-Computer Interaction in Security (HCISec) demonstrates that security measures must not disrupt primary tasks. When security introduces prohibitive operational friction to the workforce, operators will actively circumvent the controls to maintain productivity (Adams and Sasse, 1999; Beautement, Sasse, and Wonham, 2008).

Therefore, in critical Operational Technology (OT) environments, where availability and uptime are paramount, security implementations must balance risk reduction against these operational constraints. By reviewing the common decision-making patterns regarding why a specific engineered control is chosen or rejected in practice, two separate non-technical measurements have been identified as the turning points during risk management: the **Usability Score (US)** and the **Cost-Benefit Score (CB)**.

From a change management point of view, these two values can be combined with the ASDS in order to evaluate whether the proposed change of the OT device is effectively secure enough and valuable, thus providing the final verdict. The next sections illustrate the mapping and theoretical grounding of the newly identified values and how they contribute to the final formula.

4.2.2.1 Usability Score (US)

Let E represent the set of observable operational impacts (friction) introduced by a security control into the daily workflow of human operators.

Let $\prec$ represent the empirical relation *"is empirically more disruptive and introduces greater operational friction than"*.

The mapping function $f : E \to \mathbb{N}$ strictly preserves *monotonicity* such that for any two operational states $x, y \in E$: $x \prec y \Rightarrow f(x) < f(y)$

The theoretical foundation for measuring usability in security contexts relies heavily on the field of Human-Computer Interaction in Security (HCISec). Foundational literature, such as the paper made by Adams and Sasse (1999), empirically demonstrates that "users are not the enemy"; rather, when security controls introduce prohibitive friction, operators will actively subvert them to achieve their primary operational goals (e.g., writing passwords on sticky notes, bypassing safety interlocks) (Adams and Sasse, 1999). In an OT environment, operational friction directly translates to safety hazards and decreased uptime. Therefore, a control that is highly secure but operationally unusable is empirically a failed control.

In this measurement context, the *attribute* being quantified is the absence of friction, scaling from 1 (unusable/prohibitive) to 5 (seamless/transparent).

To satisfy the *homomorphism* $x \prec y \Rightarrow f(x) < f(y)$, a highly disruptive control (*rank 1*) receives a strictly lower numerical value than a seamless control (*rank 5*).
Table 4.5 illustrates the formal mapping between the ERS and NRS, operationalizing the relation into a 1-to-5 ordinal scale for usability (US).

Rank (NRS)	**Event Description (ERS)**	**Empirical Justification**	**Example**
1	Severe Operational Friction	The control actively disrupts core engineering tasks. Operators face significant delays, heavily incentivizing the circumvention of the security measure.	Complex multi-factor authentication (MFA) required during a time-critical emergency physical response.
2	High Friction	The control requires workarounds and significant behavioral changes, reducing overall plant efficiency.	Physical air-gapping requiring data to be manually carried via USB drives between facilities.
3	Moderate Friction	The control introduces noticeable but manageable changes to the daily workflow. Requires minor additional training.	Standard login procedures; scheduled maintenance windows for firmware patching.
4	Low Friction	Minimal impact on operations. The control is well-integrated into the existing workflow and accepted by the operators.	Automated background monitoring; single-sign-on (SSO) with proximity badges.
5	Seamless / Transparent	The control introduces zero friction. It is invisible to the operator and requires absolutely no behavioral change to the engineering process.	Passive network traffic analysis; hardware data diodes that automatically route telemetry.

Table 4.5: Formalization of the Usability Score (US)

4.2.2.2 Cost-Benefit Score

Let E represent the set of economic and resource-allocation outcomes associated with implementing an engineering change.

Let $\prec$ represent the empirical relation *"yields a lower return on security investment (ROSI) than"*.

The mapping function $f : E \to \mathbb{N}$ strictly preserves *monotonicity* such that for any two outcomes $x, y \in E$: $x \prec y \Rightarrow f(x) < f(y)$

The justification for the Cost-Benefit variable is strictly rooted in the economics of information security. According to the Gordon and Loeb (2002) model, organizations cannot logically spend infinite resources to secure a system; the cost of implementing a security control must never exceed the expected loss of the vulnerability it mitigates (Gordon and Loeb, 2002). If a proposed OT modernization introduces massive capital expenditure (CAPEX) for a negligible reduction in cyber-physical risk, it is mathematically unjustifiable. The CB metric operationalizes this economic principle, ranking from 1 (economically prohibitive) to 5 (optimal return on investment). Table 4.6 illustrates the formal mapping between the ERS and NRS, operationalizing the relation into a 1-to-5 ordinal scale for cost-benefit ratio (CB).

Rank (NRS)	**Event Description (ERS)**	**Empirical Justification**	**Example**
1	Economically Prohibitive	The cost of the control drastically exceeds the value of the asset or the expected loss from a breach. Violates the Gordon-Loeb principle.	Replacing millions of dollars of functioning legacy OT gear solely to add basic encryption.
2	Marginal ROI	High engineering and financial burden yielding only minimal reduction in the overall attack surface.	Purchasing expensive IT SIEM licenses for a small, isolated OT subsystem.
3	Balanced ROI	The financial cost scales linearly and proportionally with the cyber-physical risk mitigated.	Segmenting an existing network using moderately priced industrial firewalls.
4	High ROI	Highly cost-effective; significant risk reduction achieved through standard capital expenditure.	Implementing Role-Based Access Control (RBAC) on existing hardware.
5	Optimal ROI	Maximum risk mitigation achieved at near-zero or minimal cost, perfectly aligning with optimal security economics.	Removing unnecessary software features (CIE Principle 4: Design Simplification).

Table 4.6: Formalization of the Cost-Benefit Score (CB)

4.2.2.3 The Trade-off Index (T) and Gordon-Loeb Correlation

With the risk numerator (ASDS) and the business denominators (US and CB) defined, the final Trade-off Index (T) is formulated as a ratio:

$$T = \frac{ASDS}{US \times CB} \tag{4.9}$$

This ratio is the core decision-making engine of the framework, and its mathematical structure is a direct operationalization of the **Gordon-Loeb model**. Gordon and Loeb proved that security investment is a ratio between the *Cost of the implementation* and the *Expected Loss* (Gordon and Loeb, 2002). In Equation 4.9, the $ASDS$ represents the "Expected Loss" (the quantified cyber-physical risk), while $US \times CB$ represents the "Cost" (the economic expenditure and the usability friction).

Because empirical datasets of OT cyber-attack frequencies do not exist in the same volume as IT data breaches, defining a static monetary threshold for this ratio is impossible. To solve this, the framework calibrates the decision boundary using a stochastic threshold (τ). The mean value of τ is calculated through Monte Carlo simulations representing thousands of different operational change-phase scenarios.

If the calculated Trade-off Index T of a proposed engineering change is strictly less than the stochastic threshold τ, the change is deemed viable, meaning the risk is balanced efficiently against the cost and usability.

Conversely, if $T > \tau$, the proposed change violates the Gordon-Loeb boundary (e.g., the risk is too high, or the friction/cost is too severe). This triggers a mandatory redesign loop, forcing engineers to reconsider the architecture using the Cyber-Informed Engineering (CIE) principles until the ratio is reasonable according to the empirically calculated threshold.

The redesign logic is formalized in Algorithm 1.

Data: τ = threshold, T = current Trade-off Index
input : τ, T
output: T'
while $T > \tau$ **do**
    Trigger Complete Redesign (CIE Implementation Guide)
    $T' \leftarrow$ Recalculate(T)
    $T \leftarrow T'$
end

Algorithm 1: CIE-Guided Redesign Loop

4.2.3 Threshold Tuning (τ)

The τ threshold mentioned in the previous section is the most crucial value at this point, since it can trigger a whole redesign of the solution. It is important to mention that, even

though it seems a resource-expensive procedure, the ROI in terms of security, and reduction in risk, in a CNI context is much higher than proceeding with a solution that is not approved by this framework. In the next chapter (see Chap. 5) this statement is illustrated via case studies in which the framework is applied.

The τ threshold is extrapolated through a Monte Carlo Simulation: synthetic scenarios are being simulated to produce enough T values to calibrate the upper limit.

4.2.3.1 Step 1: Extracting Real OT Change Scenarios

Rather than relying on anonymized or purely synthetic inputs, the calibration dataset includes twenty-two publicly attributable OT/ICS change scenarios (even from the same context/incident) each scored against the rubric tables established in Sec. 4.2.1.5 (see Tables 4.1–4.6). Fifteen scenarios represent documented adverse conditions or change decisions associated with cyber-physical incidents, including NotPetya's cascading disruption of Maersk operations through dependence on Active Directory (Steinberg, Stepan, and Neary, 2021), the Triton/Trisis compromise of a Triconex Safety Instrumented System (Dragos Inc., 2017), and insecure remote-access conditions associated with the Oldsmar water treatment incident (CISA, FBI, EPA, and MS-ISAC, 2021). Seven scenarios represent CIE-aligned mitigations drawn from the CIE Implementation Guide and related OT security guidance (Wright et al., 2023), including hardwired instrumentation and the maintenance of Safety Instrumented System/Basic Process Control System independence under IEC 61511.

Each scenario is manually scored to produce a tuple $S_i = (C_i, E_i, D_i, I_i, US_i, CB_i, y_i)$, where $y_i \in \{0, 1\}$ is a source-informed analytical class label: $y_i = 1$ denotes an unacceptable scenario, in which a documented architecture, control weakness, or change condition enabled or materially contributed to adverse cyber-physical consequences; and $y_i = 0$ denotes an acceptable mitigation scenario, in which the documented design reduces or constrains a relevant attack path. The labels are therefore not claims that the cited sources themselves applied CCIM; rather, they provide the reference classification required to evaluate whether CCIM separates adverse change conditions from engineered mitigations.

The corpus is designed to maximise traceability and coverage of the CCIM rubric dimensions rather than to constitute a statistically representative incident sample. Consequently, some scenarios describe distinct architectural or control conditions drawn from the same parent incident or case study, for example, the M.E.Doc compromise and Maersk's Active Directory dependency within the NotPetya attack chain. These entries are retained because they exercise different CCIM dimensions; however, their common provenance limits statistical independence. This limitation is carried forward into the interpretation of the PERT-fitted distributions and Monte Carlo calibration results. Table 4.7 presents an overview of the corpus; the complete per-score justification for every scenario, tracing each rank back to the specific anchor definitions in Tables 4.1–4.6, is provided in Appendix B, Table B.1.

Scenario	Source	C	E	D	I	US	CB	Label
NotPetya wipes Maersk AD, halts cranes	Steinberg, Stepan, and Neary (2021)	5	1	4	5	3	1	Unacceptable
M.E.Doc vendor-update backdoor	ESET/Maersk 2017	4	1	4	4	3	1	Unacceptable
Triton/Trisis SIS key in PROGRAM mode	Dragos/CISA 2017	5	2	3	3	2	1	Unacceptable
Oldsmar shared TeamViewer access	FBI/CISA 2021	4	1	4	4	4	1	Unacceptable
Oldsmar shared password, no firewall	CISA 2021	3	2	4	3	3	1	Unacceptable
Stuxnet S7 PLC rootkit	Langner 2011	5	1	3	3	2	1	Unacceptable
German steel mill blast furnace damage	SANS/BSI 2014	4	2	4	3	2	1	Unacceptable
Ukraine 2015 remote breaker trip	SANS/E-ISAC 2016	5	2	4	4	2	1	Unacceptable
Bowman Ave Dam SCADA access	DOJ indictment 2016	3	2	4	3	2	1	Unacceptable
Colonial Pipeline ransomware shutdown	CISA 2021	4	2	3	4	3	1	Unacceptable
WAN-routed PMU feedback, no SLA	Friedberg et al. 2017	4	2	4	3	3	2	Unacceptable
Unauthenticated TriStation UDP protocol	Dragos/Mandiant 2017-18	4	2	3	3	2	1	Unacceptable
AMMD/VFD replacing hardwired starter	CIE Guide, INL 2023	4	2	4	3	3	2	Unacceptable
Legacy Windows 7 HMI, unpatched	Oldsmar/CISA 2021	3	1	4	3	3	1	Unacceptable
Internet-facing PLC, no segmentation	ICS-CERT/Shodan reports	4	1	5	4	3	1	Unacceptable
Hardwired instrumentation replacing sensor	CIE Guide, INL 2023	1	4	1	1	3	4	Acceptable
Physical + digital interlock	Friedberg et al. 2017	1	3	2	1	3	3	Acceptable
NGFW + DMZ segmentation	CIE Guide/NIST SP800-82	2	2	3	2	3	3	Acceptable
Managed switch replacing legacy hub	CIE Guide, INL 2023	2	2	3	2	3	3	Acceptable
Read-only data diode for HMI	CIE Guide, INL 2023	1	5	2	1	4	4	Acceptable
SIS/BPCS independence (IEC 61511)	IEC 61511/Triton lessons	1	4	2	1	3	4	Acceptable
MFA + RBAC on engineering workstation	NIST SP800-82/Oldsmar 2021	2	2	3	2	4	4	Acceptable

Table 4.7: Extracted OT change scenarios scored against the CCIM rubric (see Tables 4.1-4.6). Full per-score justification in Appendix B, Table B.1.

4.2.3.2 Step 2: Calibrating AHP Weights Before Simulation

Before any Monte Carlo run, the adopting organization's SMEs must complete the AHP pairwise-comparison process described in Sec. 4.2.1.5 (Eq. 4.2-4.5) operationalised in the appendix (App. B.3), producing weights w_1, w_2, w_3, w_4 that reflect that specific facility's risk appetite, and the resulting Consistency Ratio must be verified below the 0.10 threshold (Eq. 4.8) before the weights are accepted. This sequencing is not optional: the weights encode organizational policy, whereas C, E, D, I, US, CB encode the uncertainty of the specific change under evaluation, and conflating the two during simulation would produce a τ that does not correspond to any real decision-maker's stated risk tolerance. Once validated, $w_1, \ldots, w_4$ are held constant as scalars for every subsequent Monte Carlo draw.

4.2.3.3 Step 3: Fitting PERT Distributions per Class

For each variable $v \in \{C, E, D, I, US, CB\}$ and each ground-truth class $y \in \{0, 1\}$, a PERT distribution is fitted from the extracted scenario corpus using the observed minimum, median (as mode), and maximum, extended by ± 0.5 at the bounds:

$$f(x \mid a, m, b) = \frac{(x-a)^{\alpha-1}(b-x)^{\beta-1}}{B(\alpha,\beta)(b-a)^{\alpha+\beta-1}}, \quad \alpha = 1 + \lambda\frac{m-a}{b-a}, \quad \beta = 1 + \lambda\frac{b-m}{b-a} \tag{4.10}$$

with $\lambda = 4$.

Symbol	Meaning	Source / Role in Eq.
x	Candidate value of the rubric variable v on its 1–5 ordinal scale	Independent variable of the density
a	Lower bound of the fitted range	Observed minimum score for variable v, class y, extended by -0.5
m	Mode of the fitted distribution	Observed median score for variable v, class y (treated as most likely value)
b	Upper bound of the fitted range	Observed maximum score for variable v, class y, extended by $+0.5$
λ	Shape/concentration parameter	Fixed at $\lambda = 4$, the standard PERT convention
$\alpha,\ \beta$	Shape parameters of the underlying Beta distribution	Derived from a, m, b, λ via the equations shown
$B(\alpha, \beta)$	Beta function, $B(\alpha,\beta) = \frac{\Gamma(\alpha)\Gamma(\beta)}{\Gamma(\alpha+\beta)}$	Normalizing constant ensuring $f(x)$ integrates to 1 over $[a, b]$
$f(x \mid a, m, b)$	Resulting probability density at x	Output: likelihood of variable v taking value x, given class y

Table 4.8: Notation used in the PERT probability density function (Eq. 4.10).

Unlike a uniform distribution, PERT concentrates probability mass around the empirically observed median score for each class, consistent with the rubric's design intent that scores cluster near physically verifiable anchor states rather than spreading uniformly across the ordinal scale. Figure 4.2 shows the resulting fitted densities for all six rubric variables, comparing the Acceptable and Unacceptable classes side by side.

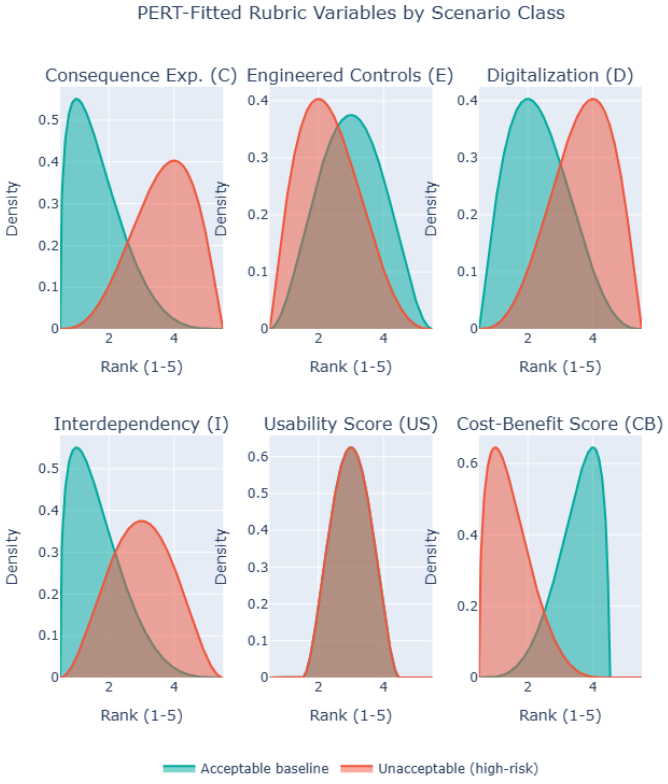


Figure 4.2: PERT-fitted densities for all six CCIM rubric variables (C, E, D, I, US, CB), by scenario class. Note that C, E, D, I separate cleanly between classes, while US overlaps substantially, consistent with US being a business-context modifier rather than a risk indicator.

4.2.3.4 Step 4: Monte Carlo Algorithm

Input : Fixed AHP weights w_1, w_2, w_3, w_4 (see Sec. 4.2.3.2, CR < 0.10); PERT parameter sets $\{(a_{v,y}, m_{v,y}, b_{v,y})\}$ for $v \in \{C, E, D, I, US, CB\}$, $y \in \{0, 1\}$; iterations per class N

Output: Labeled simulated dataset $\{(T_j, y_j)\}_{j=1}^{2N}$

foreach $y \in \{0, 1\}$ **do**

  for $k \leftarrow 1$ **to** N **do**

    foreach $v \in \{C, E, D, I, US, CB\}$ **do**

      Sample $x_{v,k} \sim \text{PERT}(a_{v,y}, m_{v,y}, b_{v,y})$

    end

    $ASDS_k \leftarrow w_1 x_{C,k} + w_2 \left(\dfrac{1}{x_{E,k} + 1} \right) + w_3 x_{D,k} + w_4 x_{I,k}$ `// Eq. 4.1`

    $T_k \leftarrow \dfrac{ASDS_k}{x_{US,k} \cdot x_{CB,k}}$ `// Eq. 4.9`

    Store (T_k, y)

  end

end

return $\{(T_j, y_j)\}_{j=1}^{2N}$

Algorithm 2: Monte Carlo Calibration of the Threshold τ

Running Algorithm 2 with $N = 10{,}000$ draws per class and the weight profile $w_1 = 0.467, w_2 = 0.277, w_3 = 0.160, w_4 = 0.095$ (derived from the worked AHP example in Sec. 4.2.1.5) produces mean $ASDS \approx 1.378$ and mean $T \approx 0.142$ for the Acceptable class, versus mean $ASDS \approx 2.677$ and mean $T \approx 0.748$ for the Unacceptable class. The resulting empirical distribution of T is shown in Figure 4.3. Additional details about the Python-based MC simulation can be found in Appendix B.2.

4.2.3.5 Step 5: Youden's J Optimization

Youden's J statistic identifies the classification cutoff that jointly maximizes sensitivity and specificity across a Receiver Operating Characteristic (ROC) curve swept over all candidate values of T (Fawcett, 2006):

$$J = \text{TPR} - \text{FPR} \tag{4.11}$$

Applying this to the simulated distribution yields:

$$\tau \approx 0.277 \tag{4.12}$$

with AUC ≈ 0.993 and $J \approx 0.915$ at the optimum, as shown in Figure 4.4, reflecting that the rubric-anchored scoring corpus discriminates almost perfectly between documented incidents and documented mitigations under this organization's calibrated weight profile.

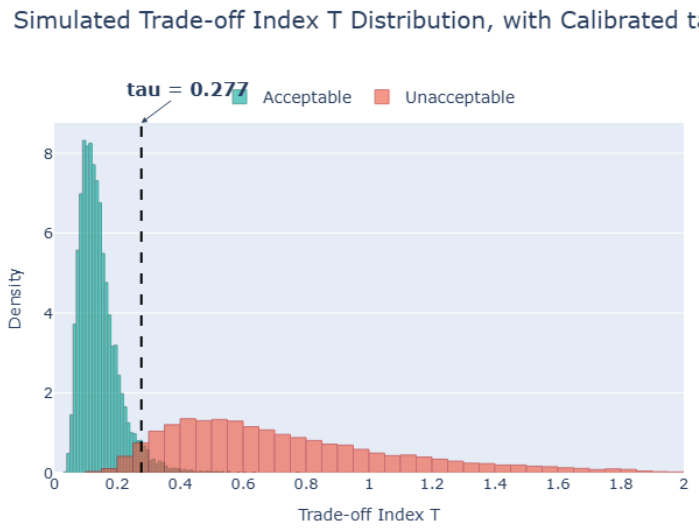


Figure 4.3: Simulated distribution of the Trade-off Index T (N = 20,000 draws), showing the near-complete separation between Acceptable and Unacceptable scenario classes, with the calibrated τ threshold marked.

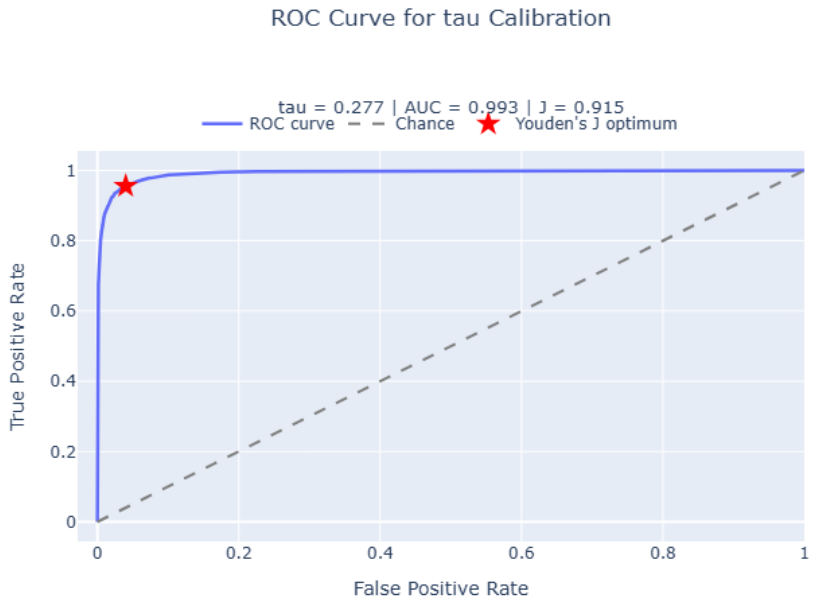


Figure 4.4: ROC curve for the simulated Trade-off Index T, with the Youden's J-optimal cut-off marked, yielding $\tau \approx 0.277$.

Acronym	Definition
TPR	True Positive Rate (Sensitivity): proportion of truly Unacceptable scenarios correctly classified as Unacceptable
FPR	False Positive Rate: proportion of truly Acceptable scenarios incorrectly classified as Unacceptable
ROC	Receiver Operating Characteristic: curve plotting TPR vs. FPR across all candidate threshold values
AUC	Area Under the (ROC) Curve: summary measure of overall classification performance (1.0 = perfect, 0.5 = random)
J	Youden's J statistic: $J = \text{TPR} - \text{FPR}$, maximized to find the optimal classification threshold
τ	Decision threshold: the value of T at which J is maximized; scenarios with $T > \tau$ are classified as Unacceptable

Table 4.9: Acronyms and notation used in Youden's J optimization (Step 5).

This means that any proposed engineering change whose computed Trade-off Index T (Eq. 4.9) exceeds $T > 0.277$ is classified as Unacceptable under this specific weight configuration, triggering the CIE-Guided Redesign Loop (Algorithm 1, Sec. 4.2.2.3). Because τ is derived from real, cited incidents and real, cited mitigations rather than an arbitrary cut-off, and because the weights driving the calculation were themselves calibrated and consistency-checked before simulation, the resulting threshold is both statistically defensible and organizationally meaningful for the adopting facility.

4.3 The CCIM Algorithm: End-to-End Workflow

Before applying CCIM to specific scenarios, this section states the complete algorithm as a single, explicit sequence. Each stage below corresponds to a subsection already developed in Chapter 2/4; here they are assembled into the order in which a practitioner actually executes them. The overall workflow is visualised in two companion flowcharts: Phase 1 (AHP weight calibration) and Phase 2 (threshold tuning) are shown in Fig. 4.5, while Phase 3 (baseline assessment) and Phase 4 (candidate option evaluation) are shown in Fig. 4.6.

Phase 1: One-Time Organisational Calibration (per facility/SME)

1. Administer the AHP pairwise-comparison questionnaire to the facility's SME(s) (App. B.3)
2. Construct the 4×4 reciprocal comparison matrix C from SME responses (Eq. 4.2)
3. **AHP – Normalisation:** divide each entry $c_{i,j}$ by its column sum to obtain C_{norm}
4. **AHP – Priority Vector Extraction:** average each row of C_{norm} to obtain $w = (w_1, w_2, w_3, w_4)$
5. **Consistency Check:** compute λ_{max} by taking Cw, dividing each resulting entry by its corresponding w_i, and averaging (Eq. 4.6)
6. Compute $CI = \dfrac{\lambda_{max} - n}{n-1}$ and $CR = \dfrac{CI}{RI}$

if $CR > 0.10$ **then**
| Reject weights; return to Step 1 and re-elicit SME judgements
else
| Accept w as the facility's fixed risk-appetite vector
end

Algorithm 3: CCIM Framework: Phase 1 – AHP Weight Calibration

Phase 2: Threshold Calibration (per weight vector w)

7. Extract/reuse the documented change-scenario corpus and fit PERT distributions per class ($y = 0, 1$) for each of C, E, D, I, US, CB – the **ECSPFD** (Extracted Change-Scenario PERT-Fitted Distributions), Sec. 4.2.3.3
8. **for** $k \leftarrow 1$ **to** N *(each class)* **do**
| Draw $(C_k, E_k, D_k, I_k, US_k, CB_k) \sim$ ECSPFD
| $ASDS_k \leftarrow w_1 C_k + w_2 \left(\frac{1}{E_k+1}\right) + w_3 D_k + w_4 I_k$
| $T_k \leftarrow \dfrac{ASDS_k}{US_k \cdot CB_k}$
end
9. **Youden's J / ROC:** sweep candidate thresholds over the simulated $\{T_k\}$; compute $\mathrm{TPR}(t)$, $\mathrm{FPR}(t)$, and $J(t) = \mathrm{TPR}(t) - \mathrm{FPR}(t)$ for each
10. Set $\tau \leftarrow \arg\max_t J(t)$; record AUC as a global goodness-of-separation check

if *AUC is unacceptably low (e.g.,* < 0.8*)* **then**
| Rubric or corpus revision required before τ is trustworthy
else
| Proceed to Phase 3
end

Algorithm 4: CCIM Framework: Phase 2 – Threshold Tuning (τ)

The sequence diagram in Appendix B.2 visualises Phase 2, Steps 7–10: SME-approved weights enter as a fixed parameter; the PERT fitter and Monte Carlo engine iterate N

times per class; the ROC/Youden module consumes the resulting $\{T_k, y_k\}$ pairs and outputs a single scalar τ, which Phase 3 and Phase 4 later read.

Phase 3: Baseline Assessment of the Current, As-Built System

11. **Identify affected OT assets:** define the system boundary and enumerate the OT assets whose configuration, connectivity, or control logic will be touched by the proposed change
12. **Document engineered controls:** record the physical and digital safety/security controls currently protecting those assets (e.g., hardwired interlocks, SIS/BPCS independence, network segmentation)
13. Score the *current, as-built* system state against the rubric anchors (see Tables 4.1–4.6) to obtain $(C_{pre}, E_{pre}, D_{pre}, I_{pre}, US_{pre}, CB_{pre})$
14. Compute $ASDS_{pre}$ and T_{pre} for the baseline using the facility's fixed w (Eq. 4.1, 4.9)

if $T_{pre} > \tau$ **then**
| **Trigger CIE-Guided Redesign** for the existing baseline **before** any new change is considered
else
| Proceed to Phase 4 (candidate option evaluation)
end

Algorithm 5: CCIM Framework: Phase 3 – Baseline Assessment (Pre-Change)

Phase 4: Evaluate the Candidate OT Change Option

15. **Define candidate option:** specify the proposed engineering change (e.g., new device, new communication pathway, new control logic) and its intended operational benefit
16. Score the *candidate change* against the rubric anchors (see Tables 4.1–4.6) to obtain $(C_{opt}, E_{opt}, D_{opt}, I_{opt}, US_{opt}, CB_{opt})$
17. Compute $ASDS_{opt}$ and T_{opt} for the candidate using the facility's fixed w (Eq. 4.1, 4.9)

if $T_{opt} < \tau$ **then**
| **Pass:** proceed with implementation of the change
else
| **Trigger CIE-Guided Redesign Loop** (Algorithm 1); re-score the revised option and repeat Step 17
end

Algorithm 6: CCIM Framework: Phase 4 – Candidate Option Evaluation

The distinction between Phase 1/2 and Phase 3/4 is the single most important operational property of CCIM: **Phase 1 and 2 happen once per organisational risk-appetite profile; Phase 3 and 4 happen once per proposed engineering change.**

4.4 Framework Pipeline Visual

This section contains the visual representation of the chain of steps presented in the previous sections, aggregated and illustrated in a two-part flowchart.

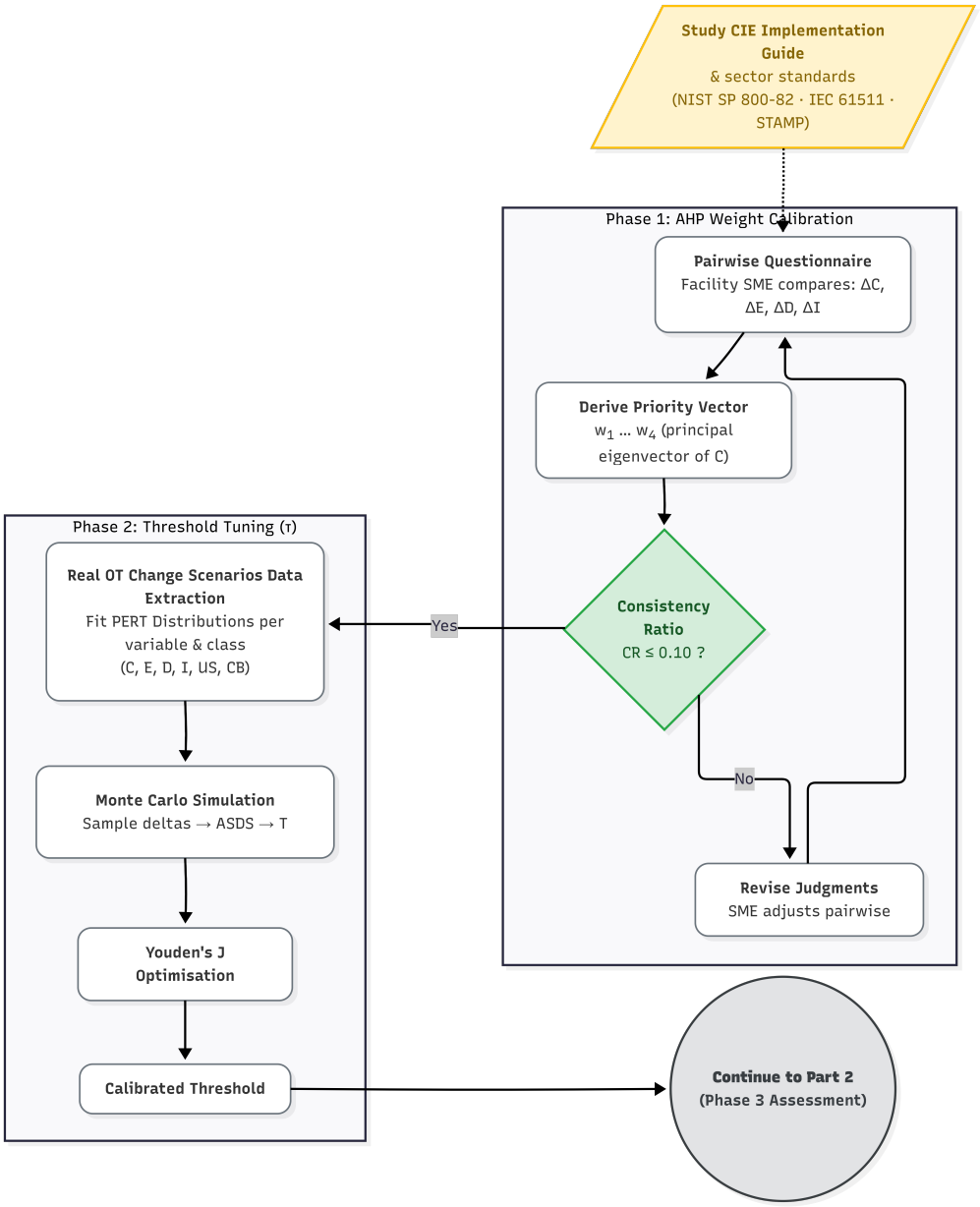


Figure 4.5: CCIM Phase 1-2

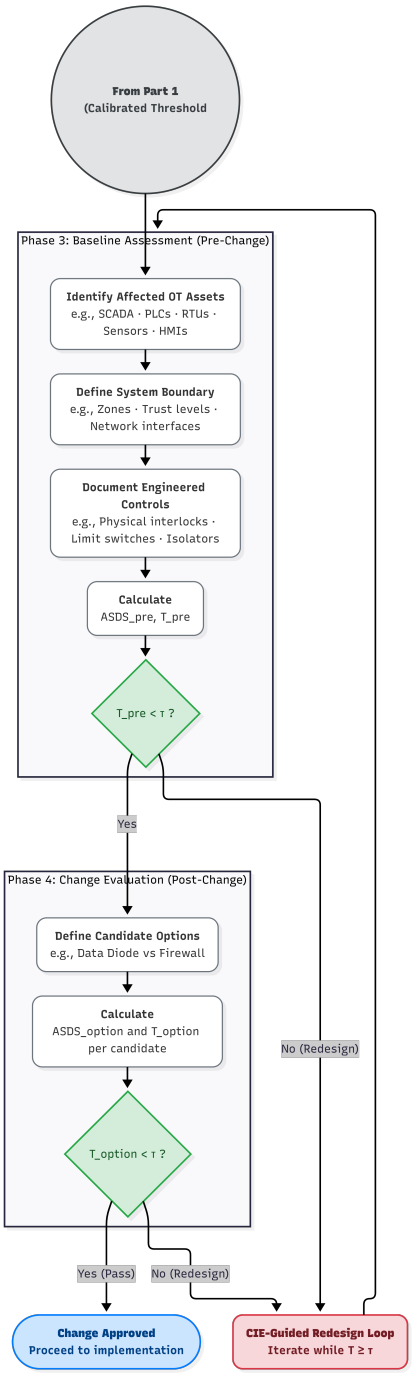


Figure 4.6: CCIM Phase 3-4

Chapter 5

Framework Application

5.1 Research Methodology: Design Science Research

This dissertation uses **Design Science (DS) Research** as its governing methodology. This choice is not arbitrary because CCIM is not a hypothesis to be tested against a population of independent observations neither a phenomenon to be described. It is a *designed artefact*: a measurement procedure, a set of ordinal scale rubrics, and a decision system, built to solve a specific problem in OT change management. DS research is the methodology purpose-built for exactly this situation (Hevner et al., 2004; Peffers et al., 2007).

Why DS Research Fits This Research

Hevner et al. (2004) frame Information System (IS) research as operating across three linked cycles, and CCIM maps onto all three directly as follows:

- **Relevance Cycle:** The identified problem is in a real environment, not an abstract idea. Chapter 3 reviews the state of cyber security risk assessment and change governance across systems-safety models, CIE guidance, single-dimension quantitative metrics, security economics, and standards/regulatory instruments. After this in-depth analysis of the domain's papers, standards, and guidance documents, a single consistent pattern emerges (see Sec. 3.2.1): no reviewed strand provides both a mathematically justified scoring method and a decision threshold specific to evaluating a proposed OT change. Cherdantseva et al. (2016)'s SCADA-specific risk assessment methods review provides the most valuable empirical statement of this gap: across the methods surveyed, risk and impact scoring formulas are "typically not proved in a mathematical sense," and are, "weakly justified"(Cherdantseva et al., 2016). This represents a documented, field-level gap, that validates the need for practitioners in OT change management to have a repeatable way to compare engineering options that current tools arguably do not provide;

- **Rigour Cycle:** CCIM is not invented from nothing. It is explicitly grounded in an existing knowledge base, Representational Measurement Theory (Stevens, 1946; Krantz and Suppes, 1971; Fenton and Bieman, 2015), the Analytic Hierarchy Process (Saaty, 1980; Kulakowski, 2021), STAMP/STPA-SafeSec (Leveson, 2012; Friedberg et al., 2017), Cyber-Informed Engineering (Wright et al., 2023), and the Gordon-Loeb security economics' model (Gordon and Loeb, 2002). Every rubric anchor and every formula component is traceable to this base, rather than to intuition;
- **Design Cycle:** The final output is produced and refined through iterative build-evaluate loops: define the rubric → formalise the ERS/NRS homomorphism → aggregate via AHP → calibrate τ via Monte Carlo → apply to case studies → observe whether the result is coherent → refine if needed.

Peffers' Process Model as the Chapter Structure

Peffers et al. (2007), operationalise DS research into six sequential activities: *(1) Problem identification and motivation, (2) Definition of objectives, (3) Design and development, (4) Demonstration, (5) Evaluation, (6) Communication.* Steps 1-3 were addressed in the previous chapters (the literature gap, the theoretical grounding, and the $ASDS/T$ formulation). **This and the next chapter (see Chap. 6) correspond to Steps 4 and 5**: they *demonstrate* that CCIM can be executed end-to-end on realistic scenarios, and it *evaluates* whether the resulting scores behave the way the design intends, discriminating adverse configurations from engineered mitigations sometimes missed by prescriptive regulation or qualitative assessments, and remaining coherent when an organisation's risk appetite changes.

Two clarifications matter for how the rest of this chapter should be read. First, it needs to be cleared that the Step 5 here, "evaluation", means comparing the artefact's behaviour against its own design objectives (does T separate the two classes it was built to separate?), not a claim of statistically generalisable predictive validity over the population of all possible OT changes. The verification of CCIM's behaviour is done in this chapter, while the validity checked though comparison to standards and literature, critically analysed in Chap. 3, is done in the next Chapter (6). Second, DS research explicitly permits, and expects, the use of illustrative, worked, or synthetic instantiations at the demonstration stage (Peffers et al., 2007); this justifies the hypothetical-but-realistic second case study introduced in Sec. 5.7.

5.2 Purpose and Evaluation Logic

This chapter applies the CIE-Informed Change Impact Metric (CCIM) to documented/hypothetical-but-realistic OT/ICS scenarios in order to demonstrate how the framework converts a qualitative engineering situation into a reproducible quantitative assessment. The purpose is not to claim that the CCIM can reconstruct the complete risk of a historical incident.

Instead, the application evaluates whether the proposed measurement procedure outputs scores that are consistent with the rubric definitions, reflects the consequence-oriented logic of CIE, and distinguishes adverse cyber-physical configurations from engineered mitigations. The next chapter, instead checks if the framework successfully addresses the gap exposed in Chapter 3, informing its verdict with the results obtained through the application of CCIM on selected case studies (see Chap. 6).

Consistent with the DS research framing established in Sec. 5.1, the evaluation in this chapter has four linked purposes:

1. Demonstrate that the CCIM can be applied to a concrete OT change or configuration;
2. Show how each input score is justified against the operational anchors in Tables 4.1–4.6;
3. Recalculate the ASDS and Trade-off Index (T) using weights calibrated for the relevant organisational context;
4. Compare the resulting T value with the threshold τ produced by a Monte Carlo/Youden calibration using the same weight vector.

This sequencing is important. The rubric scores describe the scenario, the AHP weights represent the organisation's risk appetite, and the Monte Carlo procedure calibrates the decision boundary strictly coupled to that weight vector. Consequently, τ is not treated as a universal constant: changing the weight vector requires recalibration..

5.3 Case-Study Selection

The case studies are selected from the documented calibration corpus introduced in Sec. 4.2.3.5. The corpus contains twenty-two publicly attributable scenarios: fifteen adverse scenarios associated with documented incidents or insecure OT configurations and seven acceptable scenarios representing engineered mitigations. The corpus is not intended to be a statistically representative sample of all OT changes. It is a traceable proof-of-concept corpus designed to exercise the rubric dimensions and provide source-informed classes for the threshold demonstration. Several rows describe different architectural features of the same parent incident; this increases coverage of the CCIM dimensions but limits statistical independence.

For this chapter, the primary worked example is the *Friedberg microgrid: WAN-routed remote PMU feedback without a service-level agreement*. The scenario is suitable because it links a cyber or communication condition to a concrete physical consequence through the STPA-SafeSec control structure, while also directly exercising consequence, engineered-control, digitalisation, and interdependency reasoning. The scenario is treated as a worked

application of the CCIM rather than as an independent test of the threshold, because the row is already part of the calibration corpus.

A second comparison is provided by the corresponding mitigation row, *physical and digital interlock on a circuit breaker*. This pairing allows the same general control context to be examined in an adverse configuration and in an engineered mitigation configuration. It also demonstrates the intended CIE redesign logic: a change that permits a hazardous path is contrasted with a design that adds an independent constraint.

A third, fictitious-but-realistic scenario is added in Sec. 5.7 to demonstrate that the rubric generalises to AI-integrated OT changes, a domain not represented in the original calibration corpus.

5.4 Organizational Risk Appetite

A recurring source of confusion in risk frameworks is treating the decision threshold as if it was a property of the *scenario* being assessed. In CCIM τ is a property of the *organisation's calibrated risk appetite*, fixed once per weight vector w (Phase 1-2), while $ASDS$ and T are recomputed fresh for every scenario (Phase 3-4). This section makes that distinction concrete by contrasting two organisational profiles evaluated against the *same* candidate scenarios.

Two Illustrative SME Profiles

Table 5.1 summarises two AHP outputs, produced by executing Phase 1 (Algorithm 3) with two different sets of SME pairwise judgements: a nuclear-facility profile, in which an SME would judge Consequence (ΔC) to dominate the other three criteria (reflecting the catastrophic, safety-critical framing of CIE in nuclear contexts) (Eggers and Robert S. Anderson, 2022), and a manufacturing profile, in which Digitalisation (ΔD) receives comparatively more weight (reflecting a facility more concerned with production-line connectivity and uptime than with worst-case safety consequence).

Profile	w_C	w_E	w_D	w_I
Nuclear (N)	0.570	0.224	0.125	0.080
Manufacturing (M)	0.423	0.144	0.271	0.162

Table 5.1: Illustrative AHP-derived risk-appetite vectors for two organisational profiles (both pass $CR < 0.10$ under Phase 1, see App. B.4)

Each profile, once calibrated via Phase 2 of the algorithm, produces its own fixed threshold: $\tau_N \approx 0.286$ and $\tau_M \approx 0.318$ (see Sec. 5.5.1-5.5.2). These two numbers are now organisational constants. They do not change scenario to scenario; only re-running Phase 1-2 (e.g., because the SME's priorities changed) would revise them.

The Same Scenarios, Two Verdicts, One Consistent Logic

Table 5.2 reprises the WAN-routed PMU feedback scenario (see Sec. 5.5) and the physical/digital interlock mitigation (see Sec. 5.6) under both profiles.

Scenario	$ASDS_N$	T_N vs $\tau_N = 0.286$	$ASDS_M$	T_M vs $\tau_M = 0.318$
WAN-routed PMU feedback	3.095	$0.516 > \tau_N$ (**Fail**)	3.310	$0.552 > \tau_M$ (**Fail**)
Physical/digital interlock	0.828	$0.092 < \tau_N$ (**Pass**)	1.014	$0.113 < \tau_M$ (**Pass**)

Table 5.2: The same two scenarios evaluated under both organisational profiles. The verdict is stable; the absolute margin is not.

The result illustrates precisely the property the framework is designed to exhibit: the *underlying rubric scores* (C, E, D, I, US, CB) describing the physical scenario do not change between organisations, because they describe the engineering reality, not subjective opinion. What changes is how those scores are weighted and the threshold they are judged against. In this particular pair of scenarios the result happens to be stable across both profiles, both organisations would reject the WAN-routed feedback and accept the interlock, but this is a property of this specific pair, not a guarantee. A scenario scoring more heavily on ΔD than ΔC could plausibly pass under the nuclear profile (which weights ΔD lightly) while failing under the manufacturing profile (which weights it more heavily), or vice versa. This is the intended behaviour: **CCIM externalises risk appetite as an explicit, auditable, SME-calibrated parameter, rather than allowing it to silently bias the scoring of the scenario itself.**

5.5 CS1a: PMU Feedback in a Microgrid

Background: What a Microgrid and a PMU Actually Are

Before working through the scenario, two pieces of domain vocabulary are worth making explicit, since they are load-bearing for the rubric justification and easy to gloss over.

A **microgrid** is a localised electrical grid, serving, for example, a single industrial site, a campus, or a remote community, that is capable of operating in two modes: *grid-connected*, drawing on and feeding into the wider utility grid, and *islanded*, disconnected and self-sufficient, balancing its own local generation against its own local demand. The transition between these two modes ("islanding" and "resynchronisation") is the single most safety-critical control action a microgrid performs, because getting it wrong, reconnecting to the grid while out of phase, for instance, can physically damage generation equipment.

A **Phasor Measurement Unit (PMU)** is a sensor that measures the magnitude and phase angle of the AC voltage or current waveform at a specific point in the grid, timestamped

against a common GPS clock so that measurements from geographically distant points can be compared instant-for-instant (Friedberg et al., 2017; Menezes et al., 2023). In a microgrid, PMUs are what allow the control system to know, in near real time, whether the local generator's phase is synchronised with the grid it is about to reconnect to. If PMU data is delayed, corrupted, or simply unavailable, the controller is making a resynchronisation decision: a decision with direct physical consequences, based on stale or absent information.

This is why the scenario evaluated below is not a generic "network security" concern. It is a case where a specific communication design decision (routing PMU feedback over a WAN rather than a local, deterministic link) directly degrades the timeliness and trustworthiness of the data a safety-critical physical control action depends on.

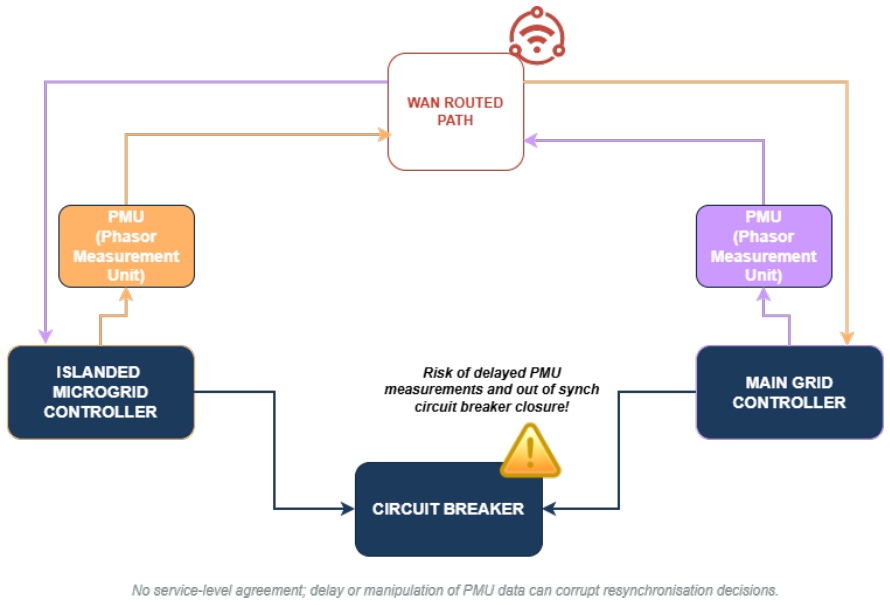


Figure 5.1: Simple visual representation of CS1

Is the Physical Interlock Actually Necessary?

The comparison mitigation in this case study, a physical/digital interlock on the circuit breaker, is not an arbitrary alternative; it directly targets the specific failure mode above. A physical interlock enforces the constraint ("do not close this breaker unless synchronism is physically confirmed") using a mechanism: a mechanical linkage, a hardwired relay, a physically separate synchro-check device, that does not depend on the same communication path that could be delayed or manipulated. This is precisely CIE Principle 2's logic (Wright et al., 2023): the control that matters most should not share a single point of failure with the digital pathway being protected against. A purely software-based interlock (e.g., a check

implemented only in PLC logic) would not have this property, because an attacker or a fault that compromises the digital path could plausibly compromise the check too. This is why ΔE scores the interlock as a hybrid engineered control (rank 3, Sec. 5.6) rather than the maximum: it is a meaningful independent constraint, but it is not a purely mechanical one, so it does not receive the highest resilience rank on the ordinal scale.

System and Scenario

Friedberg et al. apply STPA-SafeSec to a synchronous-islanding microgrid containing a generator, phasor measurement units (PMUs), a controller, and communication links between the sensing and control functions (Friedberg et al., 2017). The analysis identifies system losses and hazards associated with unsafe control actions, including hazards involving circuit-breaker reclosure, generator operating limits, incorrect islanding, and incorrect or unavailable measurements.

The scenario evaluated here is the introduction or retention of WAN-routed PMU feedback without a defined service-level agreement. The change is represented as a communication pathway that allows PMU-derived information to reach a control function across a network outside the immediate local control boundary. The scenario does not assert that the original paper conducted a CCIM, instead the published control structure and hazard logic are used as the source context for applying the CCIM rubric.

The relevant concern is that delayed, unavailable, manipulated, or inconsistent measurement data could contribute to an unsafe control decision. In the STPA-SafeSec framing, an inappropriate reclosure or loss of synchronisation may lead to equipment damage and further operational losses. The absence of a defined availability or performance guarantee is therefore treated as an interdependency and digitalisation concern, not merely as a network-management detail.

Rubric-Based Scoring

Table 5.3 records the scores already defined in the calibration corpus. The values are not inferred from the final T result; they are assigned first from the physical scenario and then processed by the CCIM equations.

The scores should be read as ordinal rubric positions, not as physical probabilities. In particular, $\Delta C = 4$ does not mean that equipment damage is four times more likely than a score of one. It states that the scenario occupies the fourth ordered consequence category defined by Table 4.1. Similarly, $\Delta D = 4$ identifies a high digital-exposure category; it is not a count of four vulnerabilities.

Criterion	Score	Application of rubric anchor	Grounding
ΔC	4/5	A loss of synchronised control can result in equipment damage to the generator set; this is a high operational consequence but is not scored as the highest safety category in the corpus.	STPA-SafeSec hazards/losses
ΔE	2/5	The relevant control remains digitally implemented and is reachable through the communication architecture; no independent physical constraint is assumed in this scenario.	CIE Principle 2
ΔD	4/5	The PMU feedback path is WAN-routed and bidirectional, creating a substantial digital pathway beyond the local control boundary.	CIE Principle 8; STPA-SafeSec architecture
ΔI	3/5	Normal operation retains a dependency on remote measurement availability and performance, although local control is assumed to provide some fallback.	CIE Principle 7
US	3/5	The connection provides useful remote measurement but does not remove all operator or engineering burden.	Usability rubric
CB	2/5	The operational benefit is limited relative to changes that provide major cost or maintenance savings.	Cost-benefit rubric

Table 5.3: CCIM scores for the WAN-routed PMU-feedback scenario. The values match the calibration corpus and Appendix B.1.

5.5.1 Calculation Under a Nuclear Weight Profile

For the nuclear organisational profile, the illustrative AHP weight vector (produced by Phase 1 of the algorithm) is:

$$\mathbf{w}_N = (w_C, w_E, w_D, w_I) = (0.570, 0.224, 0.125, 0.080). \tag{5.1}$$

Using the CCIM formulation from Eq. 4.1:

$$\begin{aligned} ASDS_N &= 0.570(4) + 0.224\left(\frac{1}{2+1}\right) + 0.125(4) + 0.080(3) \\ &= 2.280 + 0.0747 + 0.500 + 0.240 \\ &= 3.0947. \end{aligned} \tag{5.2}$$

The scenario has $US = 3$ and $CB = 2$. Therefore:

$$T_N = \frac{3.0947}{3 \times 2} = 0.5158. \tag{5.3}$$

The PERT parameters can be reused because they are derived from the scenario scores and class labels, not from the weights. However, Phase 2 (the Monte Carlo simulation) must be rerun with $\mathbf{w}_N$, because the weights change every simulated ASDS and therefore change the simulated T distribution. Using the same PERT parameterisation and the nuclear weight vector, the illustrative calibration produced:

$$\tau_N \approx 0.286. \tag{5.4}$$

Since $T_N = 0.5158 > \tau_N$, the scenario is escalated for a full CIE-guided review. This result does not mean that the CCIM automatically rejects the communication design. It means that the scenario crosses the triage boundary and requires examination of the consequences, engineered controls, secure architecture, and interdependencies before approval.

5.5.2 Calculation Under a Manufacturing Weight Profile

For comparison, the illustrative manufacturing profile is:

$$\mathbf{w}_M = (w_C, w_E, w_D, w_I) = (0.423, 0.144, 0.271, 0.162). \tag{5.5}$$

The corresponding score is:

$$\begin{aligned} ASDS_M &= 0.423(4) + 0.144\left(\frac{1}{2+1}\right) + 0.271(4) + 0.162(3) \\ &= 1.692 + 0.048 + 1.084 + 0.486 \\ &= 3.310. \end{aligned} \tag{5.6}$$

Consequently:

$$T_M = \frac{3.310}{3 \times 2} = 0.5517. \tag{5.7}$$

The same PERT distributions, with the manufacturing weight vector substituted into the ASDS calculation, produced an illustrative calibrated value of:

$$\tau_M \approx 0.318. \tag{5.8}$$

Thus, $T_M = 0.5517 > \tau_M$, and the scenario is also escalated. The absolute threshold differs between profiles, but the decision is stable for this particular scenario. This illustrates the intended distinction between risk appetite and risk outcome, developed further in Sec. 5.4: the organisation changes the weighting and threshold, while the underlying scenario scores remain unchanged.

5.6 CS1b: Physical and Digital Interlock

Mitigation Scenario

The second scenario represents a physical and digital interlock applied to a circuit-breaker control function. It is classified as an acceptable mitigation in the calibration corpus. The scenario is not treated as evidence that every interlock is automatically safe. Its score assumes that the physical element is independent enough from the digital command path to constrain the hazardous action described by the STPA-SafeSec analysis.

The rubric scores are $\Delta C = 1$, $\Delta E = 3$, $\Delta D = 2$, $\Delta I = 1$, $US = 3$, and $CB = 3$. These values correspond to a localized consequence category, a hybrid engineered-control category, limited digital exposure, and autonomous local operation. The scores match the appendix and the CSV used by the simulation.

5.6.1 Calculation

Under the nuclear weight vector:

$$ASDS_{N,int} = 0.570(1) + 0.224\left(\frac{1}{3+1}\right) + 0.125(2) + 0.080(1) = 0.828. \tag{5.9}$$

Therefore:

$$T_{N,int} = \frac{0.828}{3 \times 3} = 0.0920. \tag{5.10}$$

Since $T_{N,int} < \tau_N$, the mitigation remains below the nuclear escalation threshold. Under the manufacturing profile:

$$ASDS_{M,int} = 0.423(1) + 0.144\left(\frac{1}{3+1}\right) + 0.271(2) + 0.162(1) = 1.014. \tag{5.11}$$

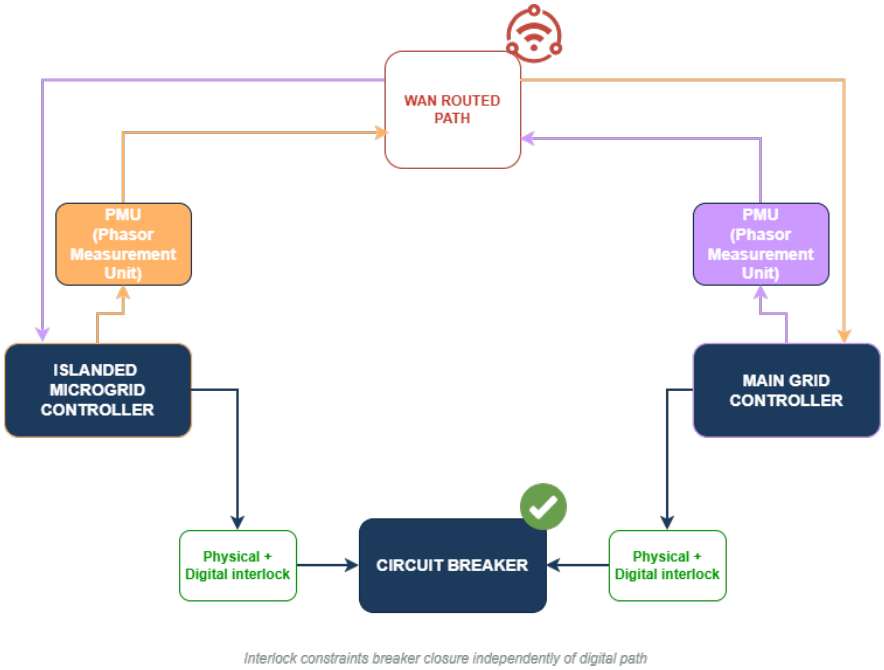


Figure 5.2: Simple visual representation of the proposed mitigation on CS1

$$T_{M,int} = \frac{1.014}{3 \times 3} = 0.1127. \tag{5.12}$$

Since $T_{M,int} < \tau_M$, the mitigation also remains below the manufacturing escalation threshold. The paired examples therefore show the intended direction of the framework: the adverse WAN-routed configuration produces a high T value, while the engineered interlock produces a lower value under both organisational profiles.

5.7 CS2: AI-enabled Control at a CNI Facility

Rationale for a Hypothetical, AI-Grounded Scenario

The first case study is drawn from a documented, publicly attributable analysis. This second case study is deliberately **hypothetical but realistic**, and is deliberately situated in Critical National Infrastructure (CNI) rather than general manufacturing, since CCIM's rubric anchors, weight profiles, and calibration corpus (see Sec. 5.3) are all designed around the safety, availability, and public-consequence constraints of CNI operators. No single published incident maps as cleanly onto CCIM's four risk vectors for an Artificial Intelligence (AI)-integrated CNI change as the PMU scenario does for a communications-architecture

change, so a constructed scenario is used instead. Its design follows the same methodological logic Devarajan et al. (2026) use in their own review of AI-induced risk in safety-critical process industries: rather than requiring a real AI-caused accident to exist before AI-specific risk can be analysed, they explicitly map recognised, non-AI accident archetypes (Bhopal, Texas City, Buncefield, Tianjin) onto how an AI-enabled version of the same safety function could fail, "not as AI-caused events" but as structured illustrations of "how similar modern AI-enabled cyber-physical process systems could be assessed". This dissertation adopts the identical logic, consistent with DS research's demonstration stage, which accommodates illustrative scenarios to exercise an artefact's behaviour (Peffers et al., 2007).

Devarajan et al. (2026) reviewed and classified 125 studies (2015-2025) into a seven-category taxonomy of AI-induced hazard pathways in safety-critical process systems: model uncertainty risk, data risk, model risk, operational risk, human risk, cyber-physical risk, and governance risk. Three of these categories map directly onto the CCIM risk vectors this scenario is designed to exercise:

- **Model risk (maps to ΔE):** defined as hazards arising from "hidden correlations, overfitting, black-box logic, misleading confidence behaviour," with representative failure modes including "unsafe anomaly thresholds" and "poor extrapolation under abnormal conditions," escalating into "unsafe advisory outputs" and "failure to trigger mitigation" (Devarajan et al., 2026). This is a sharper, process-safety-specific restatement of the general "black box problem" Lee, Su, Macchi, et al. (2026) identify in AI-driven industrial systems more broadly;

- **Cyber-physical risk (maps to $\Delta D/\Delta I$):** defined as vulnerability arising from "spoofing, poisoning, adversarial perturbation, compromised digital interfaces," where manipulated signals can "substantially distort inference without necessarily triggering obvious alarms in conventional monitoring layers" (Devarajan et al., 2026). Zhao et al. (2025)'s independent observation that ML-based control components structurally depend on continuous access to remote computation, since on-site hardware is often too resource-constrained to host the full model, explains *why* this attack surface exists in the first place;

- **Governance risk (reinforces ΔI):** defined as hazards from "unclear ownership, insufficient lifecycle testing, weak update control, proprietary opacity," leading to "certification gaps, unverified updates and unreliable safety claims" (Devarajan et al., 2026). This is the mechanism by which a vendor-controlled cloud dependency becomes a safety issue, not merely an availability one: the facility does not control when or how the model it depends on changes.

Devarajan et al. (2026)'s own accident-archetype table provides the direct analogue for this scenario's consequence framing. Their *Bhopal-type toxic release* archetype maps an

AI safety function of "leak detection, toxic dispersion forecasting" onto a risk pathway of "missing abnormal-release data, poor sensor integrity, weak uncertainty calibration and delayed alert," spanning their data risk, model uncertainty, and governance risk categories, with major accident hazard (MAH) relevance of "toxic release, delayed emergency response" (Devarajan et al., 2026). A chlorine over-dosing event at a drinking-water facility is the water-sector equivalent of this archetype: a toxic substance entering a distribution network because a safety-relevant AI function failed to recognise or arrest an abnormal condition in time.

Scenario: Cloud-Hosted AI Dosing Optimiser at a Drinking-Water Treatment Plant

Consider a hypothetical municipal drinking-water treatment facility, a CNI asset under the water sector, in the same operational category as the real Oldsmar and Maroochy Shire incidents already discussed in this dissertation (CISA, FBI, EPA, and MS-ISAC, 2021; Slay and Miller, 2007), that performs chlorine disinfection dosing as a final treatment stage before water enters the public distribution network. The facility's original configuration uses a fixed-setpoint chlorine dosing pump, manually tuned by operators against periodic residual-chlorine lab samples, with an independent, hardwired high-residual alarm relay that cuts pump power if an in-line chlorine analyser detects an out-of-range reading, typically a control path that does not pass through the plant's PLC or SCADA network.

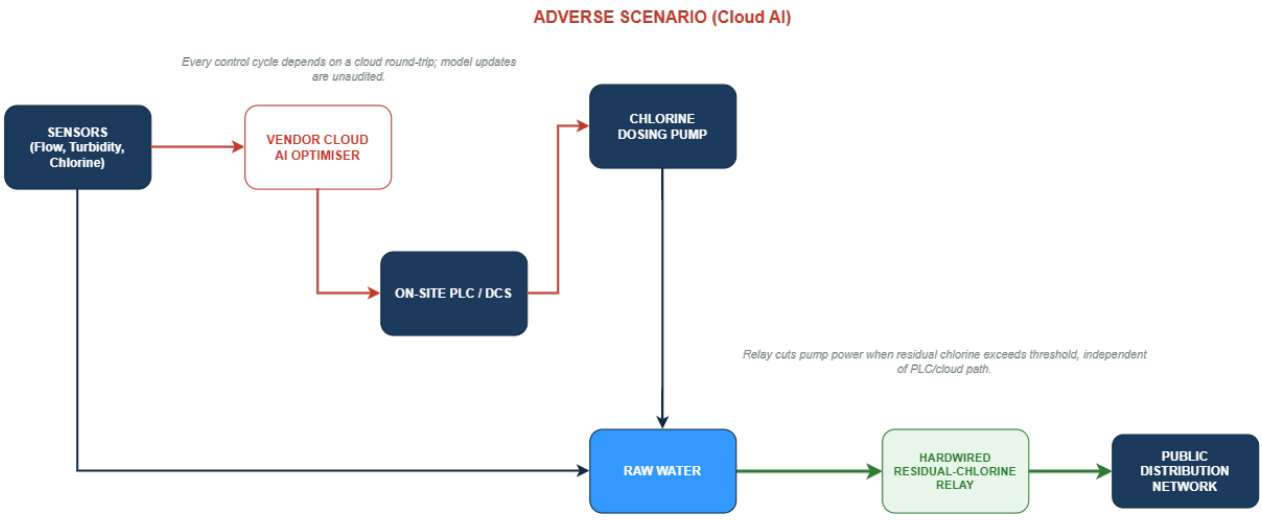


Figure 5.3: Simple visual representation of the CS2 adverse change implementation

The proposed change replaces the fixed-setpoint dosing logic with a vendor-supplied AI dosing optimiser, architected as a cloud-hosted inference service: live turbidity, flow, and

residual-chlorine sensor readings are streamed continuously from the plant to the vendor's cloud platform, which computes an updated dosing setpoint every control cycle and returns it to the on-site PLC. This design choice reflects the documented pattern that resource-constrained on-site hardware often cannot host a full model locally, making continuous cloud connectivity a structural dependency of the control loop itself (Zhao et al., 2025). Framed against Devarajan et al. (2026)'s taxonomy, this scenario combines model risk (the optimiser's internal reasoning is not interpretable, and a subtly miscalibrated model could produce a plausible-looking but incorrect dosing recommendation without triggering the alarm) with cyber-physical and governance risk (the model's behaviour depends on a continuous connection to, and periodic silent updates from, infrastructure the facility neither owns nor can independently audit).

Rubric-Based Scoring

A score needs to be justified justification beyond Table 5.4. $\Delta I = 5$ is now supported by two independent mechanisms rather than one because this is a case where every control cycle's output depends on a live round-trip to infrastructure the facility does not own, *and* where that infrastructure's model can change without the facility's knowledge or approval (Devarajan et al., 2026). This combines Devarajan et al. (2026)'s cyber-physical risk (compromised digital interface) with governance risk (weak update control, proprietary opacity): two independent, compounding reasons for the rubric's maximum category, "total dependence on continuous external/cloud IT infrastructure" (see Sec. 4.2.1.4).

5.7.1 Calculation and Verdict

This scenario is evaluated under the nuclear/CNI weight profile established in Table 5.1, since a CNI water treatment facility, like a nuclear facility, weights Consequence (ΔC) most heavily among the four risk vectors, reflecting the safety and public-health critical framing of CIE in CNI contexts generally:

$$\mathbf{w}_N = (w_C, w_E, w_D, w_I) = (0.570, 0.224, 0.125, 0.080). \tag{5.13}$$

$$\begin{aligned} ASDS_{AI,N} &= 0.570(4) + 0.224\left(\frac{1}{2+1}\right) + 0.125(4) + 0.080(5) \\ &= 2.280 + 0.0747 + 0.500 + 0.400 \\ &= 3.2547. \end{aligned} \tag{5.14}$$

With $US = 4$ and $CB = 3$:

Criterion	Score	Application of rubric anchor	Grounding
ΔC	4/5	An undetected dosing error creates a direct public-health toxic-exposure pathway, the water-sector analogue of Devarajan et al.'s Bhopal-type toxic release archetype; scored consistently with the corpus's existing water-treatment rows (Oldsmar) rather than escalated to the maximum category, since the hardwired residual alarm provides a final, independent backstop against the most extreme excursions.	Bhopal-type toxic release archetype (Devarajan et al., 2026); STAMP-style public-consequence category (Leveson, 2012)
ΔE	2/5	The day-to-day dosing decision is made entirely by an uninterpretable cloud model exhibiting the failure signature Devarajan et al. term *model risk*. Moreover, the hardwired relay, in place as a backstop, cannot detect when the AI model's output drifts due to miscalbration, because the relay reacts only to a fixed physical threshold, risking to miss potentially long-term harmful chlorine dosage	Model risk (Devarajan et al., 2026); CIE Principle 2 (Wright et al., 2023)
ΔD	4/5	The control loop requires a continuous, bidirectional, IP-routed path from the OT dosing controller to a vendor cloud service, crossing the IT/OT boundary on every control cycle rather than periodically	Compromised-digital-interface pathway, Cyber-physical risk (Devarajan et al., 2026); Attack Surface Metric logic (Manadhata and Wing, 2011)
ΔI	**5/5**	The control loop's ongoing correctness depends on continuous availability of, and unaudited update control by, an external cloud vendor; the on-site system retains no independently-computed setpoint.	Cyber-physical and governance risk (Devarajan et al., 2026); cascading dependency logic (Rinaldi, Peerenboom, and Kelly, 2001)
US	4/5	The system removes the operator burden of manual setpoint tuning and reduces reliance on periodic lab sampling.	Usability rubric
CB	3/5	Continuous optimisation offers a plausible reduction in both chemical cost and dosing variance, but the benefit is not yet demonstrated against the specific new cloud-dependency risk introduced.	Cost-benefit rubric; Gordon-Loeb framing (Gordon and Loeb, 2002)

Table 5.4: CCIM scores for the hypothetical cloud-hosted AI dosing scenario at a CNI water treatment facility.

$$T_{AI,N} = \frac{3.2547}{4 \times 3} = 0.2712. \tag{5.15}$$

Comparing against the CNI threshold $\tau_N \approx 0.286$: $T_{AI,N} = 0.2712 < \tau_N$, so the scenario **passes**, but the margin is only $\tau_N - T_{AI,N} \approx 0.015$, roughly five percent of τ_N itself. This is a materially narrow pass, and it is important to be precise about what that narrowness means. **CCIM's decision rule is a threshold, not a continuum**: a T value of 0.271 and a T value of 0.05 are both formally "Pass," but they do not represent the same level of confidence in that verdict. The closer T sits to τ, the smaller the scoring error required to flip the outcome, and therefore the more scrutiny the underlying rubric scores deserve before the result is treated as a comfortable approval rather than a conditional one.

This scenario demonstrates that sensitivity directly. Raising ΔC from 4 to 5, a single rank, and one a more conservative SME might reasonably argue for given the direct public-health exposure pathway, raises $T_{AI,N}$ to approximately 0.319, exceeding τ_N and flipping the verdict to a mandatory CIE-guided redesign. The same flip occurs if the cost-benefit judgement is revised from $CB = 3$ to $CB = 2$ ($T_{AI,N} \approx 0.407$), or the usability benefit from $US = 4$ to $US = 3$ ($T_{AI,N} \approx 0.362$). Because ΔI is already at the rubric's ceiling, it cannot itself act as the swing variable here, but three of the remaining five variables independently determine whether this cloud-dependent architecture is triaged as acceptable or escalated.

This narrow-margin behaviour is not a weakness unique to CCIM, rather it echoes a principle from Devarajan et al. (2026)'s own proposed AI Safety Integrity Level (AI-SIL) framework. They explicitly reject pure aggregate scoring, stipulating that "a high integrity claim should not be based on compensating for a critical weakness with unrelated strengths," and require minimum *gating* thresholds on specific evidence dimensions (independent validation, rare-event behaviour, uncertainty performance) regardless of how strong the overall composite score is.

CCIM's aggregation via AHP-weighted sum (see Sec. 4.2.1.5) does not currently implement an equivalent gating rule: a very strong US or CB score can numerically offset a weak ΔI, provided the weighted sum stays under τ. This scenario is a direct illustration of that structural property: a maximal, ceiling-level dependency risk ($\Delta I = 5$) surviving triage because it is balanced in the aggregate by comparatively favourable usability and cost-benefit scores.

The result should therefore be read as a conditional pass rather than a comfortable one. A T value sitting this close to τ, driven by a rubric variable already at its ceiling, should prompt independent review of the specific assumptions that produced the narrow margin, rather than treating the "Pass" verdict as license to proceed without further scrutiny. This is the intended triage behaviour of CCIM, since it does not merely sort scenarios into binary bins, instead it surfaces *how much interpretive latitude* separates a pass from a redesign trigger, which is precisely what unweighted scoring schemes documented in Sec. 5.1 do not do (Cherdantseva et al., 2016).

5.8 Interpretation and Limitations

The case studies illustrate the application sequence of CCIM rather than proving universal validity. First, the analyst defines the relevant system boundary and identifies the physical consequence (Phase 3, Step 11). Second, each criterion is assigned an ordinal score using the rubric anchors. Third, the organisation supplies an AHP-derived weight vector (Phase 1). Fourth, the Monte Carlo process generates the corresponding threshold for that weight vector (Phase 2). Finally, the observed scenario score is compared with its matching threshold (Phase 4).

The threshold must not be transferred between organisational profiles. In particular, τ_N is valid only for the simulation performed with $\mathbf{w}_N$, and τ_M is valid only for the simulation performed with $\mathbf{w}_M$, while reusing the PERT parameters in multiple scenarios and profile is appropriate because they describe the empirical score distributions in the calibration corpus (not weight-dependent).

The evaluation also has important limitations. The labels are source-informed analytical classes assigned by this study, not labels supplied by the original incident reports. The corpus is traceable but small and contains multiple scenario rows derived from related parent incidents. The PERT distributions are therefore modelling assumptions used to create a repeatable simulation, not estimates of the prevalence of OT incidents in the world.

The AHP profiles used here are worked examples unless completed by identifiable, suitably qualified SMEs. Finally, a threshold crossing is a triage signal, not an automatic safety or security approval decision. The output should trigger a documented engineering review, not replace CIE, STPA, regulatory analysis, or competent human judgement.

The second case study (see Sec. 5.7) carries a distinct claim-supporting status from the first. It is a fictitious, illustrative scenario constructed to exercise the rubric against literature-documented AI failure modes, consistent with the demonstration stage of DS research (Peffers et al., 2007); it is not a validated historical case, and its scores are a first-pass judgement rather than an SME-consensus result. It should be read as evidence for CCIM's four risk vectors versatility and capacity to generalise structurally to AI-integrated OT changes, not as evidence about the real-world prevalence or severity of AI-related OT risk.

Summary

This chapter demonstrated the complete CCIM operational sequence (Algorithms 3–6) end to end: SME-driven AHP calibration with a consistency check (Phase 1), Monte Carlo threshold calibration via Youden's J and ROC analysis (Phase 2), and rubric-based scoring of a baseline and a candidate change (Phase 3-4), applied to both a documented OT/ICS scenario and an illustrative AI-integrated scenario. The paired nuclear/manufacturing comparison (see Sec. 5.4) showed that risk appetite is an organisational constant, fixed once via Phase 1-2 calibration, while $ASDS$ and T are recomputed for every scenario in Phase 3-4, the framework's central design property. The adverse PMU-feedback scenario exceeded both illustrative thresholds, whereas the physical-and-digital interlock remained below both, and the hypothetical AI-integrated scenario passed the nuclear SME-calibrated threshold narrowly, illustrating CCIM's intended triage behaviour on a borderline case. The AI case study extended this demonstration into a domain CCIM was not originally scoped for, showing that its four risk vectors ($\Delta C, \Delta E, \Delta D, \Delta I$) generalise to AI-integrated OT changes without modification, provided the rubric anchors are grounded in the specific, literature-documented failure modes of that domain rather than generic "AI risk" intuition. These results demonstrate the intended use of CCIM as a repeatable change-governance and triage mechanism; they do not establish population-level predictive validity, which would require a larger, independently sourced corpus and expert or operational validation.

Chapter 6

Results Comparison and Evaluation

This chapter evaluates whether CCIM closes the gap identified in Chapter 3: existing OT and CNI security guidance can identify relevant controls and prescribe desirable engineering practice, but does not generally provide a quantitative methodology for judging the overall impact of a proposed change. The purpose is therefore not to claim that compliance with established standards is ineffective neither that CCIM replaces industrial standards, implementation guides, academic literature, or competent engineering judgement. Instead, the comparative evaluation makes visible what changes when the same scenarios are assessed through two different decision processes.

The comparison directly challenges the gap established in Sec. 3.2.1. The results below do not claim to resolve all limitations of OT risk assessment. They demonstrate, however, that CCIM is a solution that accounts for trade-offs, risk appetite, and threshold proximity which a standards-compliance verdict alone cannot produce.

6.1 Evaluation Method

The evaluation uses a structured paired comparison. Each case study already analysed in Chapter 5 is considered first as it would be considered through a conventional compliance-based/prescriptive review: relevant standards, CIE principles, safety controls, and architecture requirements are identified, and as an output the proposed configuration is evaluated through expert engineering judgment, determining if it is compliant or acceptable. The same scenario is then compared to the quantitative evaluation done using the CCIM framework in the previous chapter.

The comparison is **not** framed as a competition between standards and CCIM. Standards and CIE provide the substantive engineering basis from which the assessment must begin. For example, CIE Principle 2 motivates independent constraints on hazardous control actions, and *specifically for the second case study* IEC 61508 provides a functional-safety integrity framework for deterministic electrical, electronic, and programmable electronic

safety functions (Wright et al., 2023; *IEC 61508:2010* 2010). CCIM instead supplies a measurement mechanism and a structured decision layer: it records how the implementation scores according to the defined rubrics, makes the organisation's priorities explicit through AHP weights (risk-appetite), and compares the resulting Trade-off Index against a calibrated escalation threshold.

For each scenario, the following questions are asked:

1. What would a review, led through standards and CIE, identify as the relevant safeguards, requirements, and residual concerns?
2. Could that review reach a defensible compliance or engineering-acceptance verdict without producing a transparent, comparable aggregate decision measure?
3. What rubric values does CCIM assign when the same facts are evaluated against the defined anchors?
4. Does the resulting Trade-off Index T pass or exceed the calibrated threshold τ?
5. If the scenario passes, how close is T to τ, and therefore how robust is the apparent pass to a reasonable change in an SME judgement?

The final question is important. A classic binary compliance outcome does not normally distinguish a configuration that comfortably satisfies its controls from one that narrowly sits below the escalation boundary. CCIM does not alter its formal decision rule for a near-threshold case: a value below τ remains a pass. However, the distance $\tau - T$ is decision-relevant evidence. A narrow margin indicates that a small, plausible revision to an ordinal score or benefit estimate can change the decision. Therefore, it requires greater scrutiny before approval.

The evaluation is analytical and illustrative, rather than a claim of predictive or statistical validation. The case-study scores are source-informed analytical judgements, while the AHP profiles are illustrative. Consequently, the results show whether the artefact behaves coherently against its stated design objectives, consistent with DS research evaluation, rather than proving that CCIM predicts real-world incident occurrence or severity (Hevner et al., 2004; Peffers et al., 2007).

6.2 Legacy vs CCIM

Table 6.1 summarises the central result. In every case, a review led through standards and CIE can identify meaningful engineering observations. Its limitation is that the resulting decision can remain prescriptive, qualitative, and difficult to compare across changes. CCIM preserves those observations but converts them into a traceable measurement procedure and a threshold-based triage verdict.

Evaluation property	**Legacy standards/CIE compliance review**	**CCIM evaluation**	**Implication demonstrated by the case studies**
Decision boundary	May recommend controls or record compliance, but normally has no decision threshold for a proposed OT change.	Calculates T and compares it with a calibrated threshold τ.	The WAN-routed PMU configuration is explicitly escalated because $T > \tau$; the interlock is below the same decision boundary.
Disagreement resolution	Different practitioners may emphasise consequence, connectivity, usability, or cost differently without making those priorities explicit.	AHP weights externalise risk appetite, and the consistency ratio tests whether SME pairwise judgements are sufficiently coherent.	The same scenario can be assessed under distinct organisational profiles without silently changing the underlying engineering facts.
Novel threat models	At the moment, in an industrial context requirements may be applicable only indirectly where a change introduces non-regulated behaviour (e.g., AI).	The rubric scores consequence, engineered controls, digitalisation, and interdependency even where no prescriptive standard gives a complete decision procedure.	The AI water-treatment scenario records cloud dependence as $\Delta I = 5$, while IEC 61508 does not provide an appropriate assessment for the AI model.
Borderline cases	A compliant or acceptable conclusion can overlook how close the configuration is to becoming unacceptable.	The margin $\tau - T$ reveals whether a formal pass is robust or sensitive to plausible changes in expert judgement.	The AI dosing scenario passes under the illustrative CNI profile, but only narrowly. A one-rank increase in consequence, or a lower usability or cost-benefit judgement, changes the verdict.
Auditability	The evidence is distributed across documents including checklists, standards clauses, etc.	Each scenario full quantitative assessment and final decision can be retained as a single auditable decision record.	A reviewer can reproduce why a scenario passed, failed, or required escalation, and can identify the assumptions responsible for the result.

Table 6.1: Structural comparison between prescriptive standards/CIE compliance and CCIM-based change triage.

CS1a: WAN-Routed PMU Feedback

A traditional review of the WAN-routed PMU-feedback configuration would identify significant concerns. STPA-SafeSec establishes that reliable PMU measurements are integral to safe synchronisation and circuit-breaker reclosure, while CIE would challenge dependence on a communication path that is external to the immediate control boundary and lacks a defined service-level agreement (Friedberg et al., 2017; Wright et al., 2023). A competent review could therefore recommend local deterministic communications, explicit availability requirements, network segmentation, redundancy, or an independent synchronism check.

However, those prescriptions do not producing a clear comparable aggregate decision boundary. An auditor may describe the WAN path as undesirable, insufficiently resilient, or inconsistent with defence-in-depth, yet no standard or CIE principle alone produces a *numerical* statement to assess whether the proposed configuration needs to be escalated (redesign).

CCIM makes that judgement explicit. Under the nuclear/CNI profile, the configuration produces $ASDS_N = 3.0947$ and $T_N = 0.5158$, exceeding $\tau_N \approx 0.286$. Under the manufacturing profile, it produces $ASDS_M = 3.310$ and $T_M = 0.5517$, exceeding $\tau_M \approx 0.318$. The configuration therefore fails under both illustrative profiles and is escalated for a full CIE-oriented engineering review. The important result is not that CCIM "discovers" something that CIE could not spot before, rather it is that CCIM makes the escalation decision reproducible and shows that the verdict is robust across two distinct, explicit risk-appetite profiles. This significantly augments the qualitative documents supporting an engineering choice.

CS1b: Physical and Digital Interlock

The physical-and-digital interlock represents the type of mitigation that prescriptive safety and CIE guidance would normally favour. It constrains a hazardous circuit-breaker action through a physical element that is independent enough from the digital control path, reflecting CIE Principle 2's requirement to engineer consequences out of the system instead of exclusively relying on cyber protection (Wright et al., 2023). A legacy review would therefore likely describe the configuration as a strong or acceptable mitigation, subject to normal engineering assurance of the interlock itself.

CCIM supports that direction but adds two pieces of information absent from the qualitative verdict. Under the nuclear profile, the mitigation produces $T_{N,int} = 0.0920$, substantially below $\tau_N \approx 0.286$ and under the manufacturing profile, it produces $T_{M,int} = 0.1127$, substantially below $\tau_M \approx 0.318$. First, the framework demonstrates the grade of separation between the adverse WAN-routed configuration and the engineered mitigation. Second, it shows that the mitigation is a comfortable technical pass: its distance from the decision threshold is much greater than that of the AI case below.

This distinction matters in change governance because, although compliance or prescription checklist may record that an independent interlock is present, it does not generally quantify the combined change in consequence, control resilience, digitalisation, and dependency introduced by that design choice. CCIM does not replace the requirement to test and assure the interlock, rather it provides an auditable proof for prioritising the mitigation as lower-risk than the original communication configuration.

CS2: Cloud-Hosted AI Dosing Optimiser

Before applying it to this case, it is worth briefly situating IEC 61508 itself, since the standard has not been introduced elsewhere in this dissertation. IEC 61508 is the principal international standard for the functional safety of electrical, electronic, and programmable electronic (E/E/PE) safety-related systems. It assigns a Safety Integrity Level (SIL) to a given safety function and ties that level to a quantified reliability target, expressed as a probability of failure on demand for low-demand functions (*IEC 61508:2010* 2010). This structure is well matched to components whose failure behaviour is deterministic and can be characterised through component reliability data, proof-test intervals, and architectural constraints, such as a hardwired relay. It is introduced here, rather than in Chap.2 or 3, because it is specifically relevant to this case study: it is the standard against which the case's deterministic safety function can be assessed, and its scope-limitation is precisely what motivates comparing it against CCIM below.

That scope-limitation matters for CS2. IEC 61508 does not regulate the routine use of non-deterministic, stochastic or learning-based components in cyber-physical safety functions, and it does not itself regulate how a model whose behaviour depends on training data, calibration, or continued retraining should be validated or assigned an integrity claim. Devarajan et al. make this gap explicit, characterising IEC 61508 as a regulatory framework built for deterministic behaviour that offers no direct route to validating machine-learning components under epistemic uncertainty, rare-event conditions, or dynamic retraining (Devarajan et al., 2026). In other words, the standard represents a genuine and useful attempt at safety regulation, but one that was not built to reach non-deterministic functions, and it does not claim to. The comparison below is therefore not that IEC 61508 fails at something it set out to do, but its scope leaves the AI-enabled function unregulated by any equivalent instrument, which is exactly the condition under which CCIM's rubric-grounded scoring is intended to remain useful. Because CCIM's ordinal anchors are defined against the change's own consequence, exposure, digitalisation, and dependency characteristics rather than against a standard's applicability boundary, the framework is able to generalise into this gap and still produce a comparable, decision-relevant score, even in the absence of a governing regulatory instrument for the component in question.

The AI-enabled water-treatment case most clearly demonstrates the gap between deterministic compliance regimes and the CCIM. The retained hardwired high-residual

chlorine relay is a deterministic safety-related function. In principle, it could be specified under IEC 61508 with a Safety Integrity Level and a low-demand probability-of-failure-on-demand (PFD) target. For example, SIL 2 corresponds to a PFD_{avg} band from 10^{-3} to less than 10^{-2} for a low-demand safety function (*IEC 61508:2010* 2010). A conventional compliance review could therefore inspect the relay's safety function, proof-test arrangements, reliability evidence, and claimed integrity level.

The cloud-hosted AI optimiser is different. Its failures can arise from model uncertainty, data drift, hidden correlations, poor calibration under abnormal water conditions, cyber-physical manipulation of sensor data, cloud-service disruption, or unaudited vendor updates. These are not equivalent to a deterministic relay fault with a readily calculated PFD_{avg}, and they fall squarely within the validation gap identified above. Consequently, a conventional standards review can identify governance and assurance questions, but it cannot derive a PFD for the AI function by applying IEC 61508.

CCIM does not claim to supply such a claim. Instead, it makes the change-governance concern visible before an organisation accepts the new architecture. The scenario receives $\Delta C = 4$, $\Delta E = 2$, $\Delta D = 4$, and $\Delta I = 5$, with the final score reflecting a direct pathway that could potentially harm public-health, limited independent mitigation, continuous cloud-mediated digital exposure, and total dependence on external cloud infrastructure for data analysis and chlorine dosage calibration. Under the illustrative nuclear CNI profile, this produces $ASDS_{AI,N} = 3.2547$ and $T_{AI,N} = 0.2712$, which formally passes below $\tau_N \approx 0.286$.

The pass should not be interpreted as an approval of the AI system's safety. The margin is only approximately 0.015, or roughly five percent of τ_N. A simple change from $\Delta C = 4$ to $\Delta C = 5$ produces $T_{AI,N} \approx 0.319$, exceeding the threshold. Similarly, changing CB from 3 to 2 produces $T_{AI,N} \approx 0.407$, while changing US from 4 to 3 produces $T_{AI,N} \approx 0.362$. Thus, the standards-led result might be "the deterministic relay is compliant, however you shall obtain appropriate assurance for the AI supplier," whereas CCIM adds the more operationally useful result: the architecture is a conditional, near-threshold pass whose acceptability depends on scoring assumptions that require independent expert revision before approval.

This outcome also exposes a limitation of CCIM rather than concealing one. The framework uses weighted aggregation: a high score in one risk vector can be outweighed by favourable values elsewhere. Devarajan et al.'s proposed AI-SIL framework proposes minimum evidence gates (ceiling values) for uncertainty performance, rare-event behaviour, and independent validation (Devarajan et al., 2026). CCIM does not presently implement such numerical gate. The maximum dependency score, $\Delta I = 5$, therefore does not automatically force escalation. This is not a reason to disregard the result, however it is a specific, actionable limitation that supports the recommendation for expert review and future work proposed in the following chapter.

The next chapter discusses the results of the application of CCIM, re-iterating what has been done so far, exposing the limitations of the framework and illustrating what are some improvements and ideas that could be implemented in the future.

Chapter 7

Conclusions

7.1 Discussion

In Chapter 5 CCIM has been applied to different case study to observe, according to DS research (Hevner et al., 2004; Peffers et al., 2007), whether the framework can be applied end-to-end on real or pseudo-real scenarios and evaluate if the results match the expected output at design-time. Furthermore, Chapter 6 shows the case study results-informed evaluation of the application of CCIM to verify if the literature and regulation gap is actually addressed.

However, the latter's structured paired comparison demonstrates the internal coherence and practical distinction of CCIM, but it does not constitute formal verification or external validation. First, the scenario classifications and ordinal scores are source-informed analytical judgements produced within this dissertation. Although each score is traceable to a rubric anchor and published scenario evidence, inter-rater reliability has not yet been measured. Second, the AHP vectors used in the worked examples are illustrative. They demonstrate how risk appetite can be externalised and tested for consistency, but they are not a substitute for elicitation from recognised CNI engineers, operational technology security specialists, functional-safety professionals, and risk or quality-assurance practitioners. Finally, it must be acknowledged that the calibration data could be biased, since the scoring has been made through objective and rubric-informed judgment, yet there could be information bias, since the author can be assumed to be emotionally linked with the contribution. This does not mean that what has been discussed about the **subjective bias** in Sec. 4.2.1.1 is false, but the possibility of a bias has been mentioned for academic honesty and it is has been largely demonstrated that decision making can be influenced due to emotional involvement (Davies and Turnbull, 2011). Thus, in order to address these limitations, the next section shows future work to be done in order to make the CCIM globally accepted.

7.1.1 Future Work

The immediate next step should therefore be a **structured expert validation**. A suitable study would involve qualified participants across CNI engineering, OT security, process safety, assurance, and quality functions. Participants should independently score the same change scenarios using the CCIM rubrics, complete the AHP questionnaire (App. B.3), and assess the resulting decision records. The evaluation should measure agreement between assessors, identify ambiguous rubric anchors, assess AHP consistency ratios, and record whether the CCIM verdicts actually supports the decisions that participants would make using standards compliance alone.

Thus, **formal method verification** is a later and distinct activity. The mathematical formulation can be checked for correct implementation, scale admissibility, monotonicity, boundary behaviour, and reproducibility of the Monte-Carlo threshold-calibration procedure. Such verification would confirm that the implemented metric behaves as specified, nevertheless it would not by itself establish that the rubric encodes the correct engineering judgement. Expert validation is therefore logically prior because the design and its anchors must first be challenged by practitioners before stronger claims about applicability can be made.

Still, there are several development opportunities that can be implemented in the future:

- **Non-compensatory gate value escalation rule**: The AI case shows that a scenario may formally pass despite a ceiling-level interdependency score, $\Delta I = 5$, because the present aggregation permits compensation by other dimensions. Future work should test whether CCIM should include a mandatory-review gate for one or more extreme conditions, for example a maximum ΔC or ΔI score, or whether such a gate should remain a configurable organisational policy layered above the metric. This decision should be made through expert elicitation and scenario testing, rather than added post hoc to force a preferred result. For example, a honeypot OT device put in place to check who is trying to attack the infrastructure in order to investigate and prevent through early mitigation. It will for sure have $\Delta D = 5$, but $\Delta I = 2$ and $\Delta C = 1$. It is not mandatory that ceiling values need to trigger a re-design, it depends on the organization's risk appetite and the change-context. It is obvious that a ceiling value asks for greater scrutiny and expert judgement. Moreover, a close T to the τ threshold reflects the organization's risk appetite, usability, budget constraints or aims;

- **Calibration corpus expansion**: Larger independent dataset, expert-labelled cases, actual anonymised CNI data, prospective application to live change proposals, and comparison with actual governance outcomes would be required to assess predictive validity, threshold stability, and generalisability. The present results support the narrower but defensible conclusion that CCIM is a promising decision-support tool for OT/CNI change management, since it preserves the engineering content of standards and CIE while making trade-offs, uncertainty, and escalation thresholds explicit.

Thus, an innovative solution to the limited data corpus problem can be an AI-enabled data extractor. Looking at the current technological landscape, rather than manually searching and evaluating relevant OT change scenarios, incidents or guidelines, an AI agent trained and tested (using specific design patterns) to extract data from provided documents and evaluate the scenario against the designed rubrics would be an efficient tool for time saving and data pool expansion. Nevertheless, in order to assess the model robustness and reliability there is still the need for expert documented framework application and legacy governance comparison;

- **Weights Fragmentation**: A further implementation can involve the subdivision of a weight value in smaller fragments for scenario-specific needs. For example, in an AI related case application, scenario specific measurement can be formalized, following RMT (see Sec. 2.3.1), into a rubric that is grounded in relevant literature and real world incidents. The eventual sub-rubrics could, for instance, be evaluating the AI chain of trust, dependencies under various measurements (e.g., ΔI for the hosting platform, ΔC for consequences related to eventual observation-informed AI tools,ΔE for the sensors deployed in the AI-enabled OT device, etc..), splitting the weights and selecting the final number on the original rubric calculating the average of the values assigned with the sub-rubrics. Another example can be two different candidate options for the same problem, that might have the same score, but if a a measurement gets split in sub-measurements, an additional layer can be added to help finding the best fit;

- **Change-management data**: The last idea that would eventually help the global OT community is to standardize a method (even the CCIM or something similar) to describe the change of OT devices in industrial contexts. For example, the CCIM could be a reasonable fit because it provides rubrics that can be associated with almost any scenario, while the organization describing an hypothetical OT change does not have to be specific about every detail in the change process, preserving its anonymity. Therefore, they could share what they are doing without actually going in depth (keeping their information private) using CCIM, providing simple descriptions, but enriching a data set that could be used to calibrate more accurately the τ threshold and, as a consequence, helping the global OT risk management audience.

7.2 Summary and Conclusion

The research questions and objectives of this dissertation have been satisfied. The research questions presented in the introduction (see Chap. 1) were designed specifically to achieve this result and they implicitly asked for an in-depth analysis of CIE, relevant literature and standards (see Chap. 2 and 3). Then they required theoretical grounding and requirements elicitation to understand how to model the framework in order to obtain a coherent metric

to map the Attack Surface, based on the CIE guidance and related papers (see Chap. 4). After the design of the CCIM, it has been tested against relevant scenarios and evaluated based on the DS research methodology (see Chap. 5 and 6). The results obtained show that CCIM can be operationalised and it produces valid outputs and conceptually, if compliant to this quantitative assessment framework (with $T < \tau$), it could potentially be compliant to standards, since it is verifiably stricter than prescriptive strategies. That is why it is a potent tool for security engineers to utilize during audits and decision challenging. However, as explained in the section above, its calibration data pool needs to be expanded and it needs to be formally verified, both mathematically and through expert opinion. Those last two steps can allow CCIM to be globally accepted as a CIE-informed contribution on OT change-management (Fenton and Bieman, 2015; Krantz and Suppes, 1971; Hubbard and Seiersen, 2023). Moreover, the paper mentioned in the AI case study of Devarajan et al. (2026), illustrates a quantitative formula close to the *ASDS* formula this dissertation is proposing (see Page 15, Sec. 6.4 in that paper), therefore it could have an actual impact in the OT landscape and have a chance to be accepted globally as a *metric*.

The CCIM aims to have an attack surface reduction as a consequence of its application to the specific scenario, allowing the SME to decide the organizations' risk appetite and to have a methodology tailored to subjective needs, but still providing the right scrutiny.

To conclude, it can be said that given the IT/OT convergence dictated by the innovation brought by the Industry 4.0, OT security is a serious matter that lately is getting overlooked, and this dissertation aims to help understanding the trade-offs during change-management.

The next emerging paradigm in the industrial environment (Industry 5.0) aims to bring back the human-in-the-loop oversight, reinforcing its critical need for resilience, particularly within CNI (European Commission, 2026). CCIM precisely positions itself within this shift providing a shared quantitative language that, instead of replacing engineering judgement with a black-box automated decision maker (Lee, Su, Macchi, et al., 2026; Zhao et al., 2025), it structures and makes auditable the same human decision-making that Industry 5.0 seeks to reinforce, allowing engineers and auditors to negotiate the trade-off between security, usability, and cost during OT change management.

Appendix A

Generative AI Usage Disclosure

- **Name and version**: Perplexity (Pro Version)
- **LLM Hub**: Perplexity acts as a LLM hub, which allows the communication with different LLMs, including Gemini 3.1 Pro (Google) and Claude Sonnet 5 (Anthropic)
- **Publisher**: Perplexity AI (Perplexity, Inc.)
- **URL**: https://www.perplexity.ai./
- **Usage description**: I used Perplexity for:
  - Feedback on tone;
  - Feedback on readability;
  - Sentence polishing;
  - Grammar and spelling check;
  - Searching articles and papers, along with Scopus, OneSearch and IEEE Xplore.

Appendix B

Metric Development Details

B.1 OT Change Scenario Data Extraction

Table B.1 presents the complete per-score justification for all twenty-two OT change scenarios used to calibrate the τ threshold in Sec. 4.2.3.5, tracing each rubric score back to the specific rank anchors defined in Tables 4.1-4.6.

Table B.1: Full justification of extracted OT change scenarios against CCIM rubric anchors (see Tables see Tables 4.1–4.6)

Scenario	**Source**	**C**	**E**	**D**	**I**	**US**	**CB**	**Label**	**Justification**
NotPetya wipes Maersk AD, halts port cranes	Steinberg, Stepan, and Neary (2021)	5	1	4	5	3	1	Unacceptable	C=5: total loss of terminal safety/ops function (catastrophic). E=1: no physical control existed independent of IT auth. D=4: bi-directional IT-OT auth dependency. I=5: OT cranes fully dependent on external AD/cloud auth for physical operation.
M.E.Doc vendor-update supply-chain backdoor	ESET/Maersk case study 2017	4	1	4	4	3	1	Unacceptable	C=4: forced shutdown of production/logistics assets. E=1: trust placed entirely in unverified vendor software update mechanism. D=4: update channel is a bi-directional IT-OT bridge. I=4: critical dependency on 3rd-party update server.
Triton/Trisis: SIS key left in PROGRAM mode	Dragos 2017 / CISA MAR-17-352-01	5	2	3	3	2	1	Unacceptable	C=5: targets Safety Instrumented System directly, threatens catastrophic loss of last line of defense. E=2: SIS is a segmented digital control, still network-reachable via TriStation protocol. D=3: engineering workstation had IP read/write access to SIS. I=3: SIS relies on engineering workstation availability, non-critical under normal ops.
Oldsmar: shared TeamViewer remote access to HMI	FBI/CISA advisory 2021; Guardian 2021	4	1	4	4	4	1	Unacceptable	C=4: attacker changed NaOH setpoint 100x, equipment/chemical dosing outside safe limits. E=1: setpoint is purely software-defined in HMI, no analog override existed. D=4: bi-directional remote access accepted incoming commands. I=4: operator intervention itself depended on the same compromised remote software.
Oldsmar: single shared password, no firewall segmentation	CISA advisory 2021	3	2	4	3	3	1	Unacceptable	C=3: process degraded (dosing anomaly) but caught before harm, within recoverable bound. E=2: minimal segmentation via VPN/TeamViewer, still digitally bypassable. D=4: bi-directional remote access accepted commands from outside plant network. I=3: only auxiliary telemetry/remote-access depended on shared credential, primary loop unaffected.

Table B.1 - continued from previous page

Scenario	Source	C	E	D	I	US	CB	Label	Justification
Stuxnet: Siemens S7 PLC rootkit sabotages centrifuges	Langner 2011 IEEE S&P	5	1	3	3	2	1	Unacceptable	C=5: physical destruction of centrifuges, catastrophic loss of primary process assets. E=1: rootkit executed inside the same PLC logic layer as the process control, zero physical isolation. D=3: infection vector required USB/engineering workstation with IP-segment access to PLC. I=3: centrifuge control relied on the same PLC firmware being manipulated.
German steel mill: blast furnace cyber-physical damage	SANS ICS/BSI 2014	4	2	4	3	2	1	Unacceptable	C=4: uncontrolled shutdown caused physical equipment damage to blast furnace. E=2: plant network had some segmented digital control, but insufficient to stop manipulation. D=4: attackers pivoted from spear-phished office IT into plant network via bi-directional pathways. I=3: furnace control systems had non-critical but exploitable IT dependency.
Ukraine 2015: remote SCADA breaker trip via VPN	SANS ICS & E-ISAC 2016	5	2	4	4	2	1	Unacceptable	C=5: 225,000 customers lost power; safety/critical function of grid lost. E=2: breaker control had some segmented digital protection but was still remotely reachable. D=4: attackers used VPN/RDP - fully bi-directional IT-OT pathway into SCADA. I=4: breaker operation logically depended on remotely-accessible SCADA HMI, a critical enterprise dependency.
Bowman Ave Dam: SCADA remote access via cellular modem	DOJ indictment 2016	3	2	4	3	2	1	Unacceptable	C=3: no physical damage occurred (dam was under maintenance/dry), but full unauthorized SCADA access achieved - moderate/near-miss severity. E=2: modem-based remote access was a segmented but still digitally reachable control. D=4: cellular modem is a bi-directional external connection point. I=3: sluice gate control had auxiliary, non-critical remote-access dependency at the time.

Table B.1 - continued from previous page

Scenario	Source	C	E	D	I	US	CB	Label	Justification
Colonial Pipeline: ransomware forces full pipeline shutdown	CISA 2021	4	2	3	4	3	1	Unacceptable	C=4: entire pipeline halted for days, major economic/operational asset loss. E=2: billing/IT systems were segmented from OT, yet still forced a precautionary OT shutdown. D=3: IT-OT boundary was read/write for billing data feeding OT scheduling systems. I=4: OT scheduling/billing had critical dependency on the compromised IT enterprise network.
Friedberg microgrid: WAN-routed remote PMU feedback, no SLA	Friedberg et al. STPA-SafeSec 2017	4	2	4	3	3	2	Unacceptable	C=4: out-of-sync circuit-breaker reclosure risks equipment damage to generator set. E=2: PMU is a segmented digital device but reachable across WAN. D=4: WAN-routed IP connection is fully bi-directional and outside operator control. I=3: local speed controller has non-critical dependency on remote PMU under normal conditions (local feedback prioritized).
Triton: unauthenticated TriStation UDP engineering protocol	Dragos/Mandiant 2017-2018	4	2	3	3	2	1	Unacceptable	C=4: enabled unauthorized firmware upload to SIS controller, high-impact equipment risk. E=2: SIS remains a segmented digital control, not immune to protocol-level exploitation. D=3: engineering workstation had IP read/write access, segmented but not air-gapped. I=3: SIS firmware integrity had a non-critical dependency on engineering workstation trust.
AMMD/VFD replacing hardwired motor starter	CIE Implementation Guide, INL 2023	4	2	4	3	3	2	Unacceptable	C=4: loss of hardwired starter's inherent fail-safe risks equipment damage on VFD fault. E=2: VFD control logic is software-configurable, a segmented digital control replacing a hardwired analog one. D=4: VFD now accepts bi-directional setpoint commands from the OT network. I=3: motor operation gains a non-critical but real dependency on VFD firmware/network availability.

Table B.1 - continued from previous page

Scenario	Source	C	E	D	I	US	CB	Label	Justification
Legacy unpatched Windows 7 HMI in OT network	Oldsmar CISA lessons-learned 2021	3	1	4	3	3	1	Unacceptable	C=3: process degradation risk from unpatched vulnerabilities being exploited, bounded by lack of confirmed damage. E=1: unpatched general-purpose OS provides negligible physical resilience. D=4: HMI accepted bi-directional remote-access software (TeamViewer). I=3: HMI functions had non-critical dependency on OS/software patch state.
Direct internet-facing PLC, no segmentation (Shodan-exposed)	ICS-CERT/Shodan exposure reports	4	1	5	4	3	1	Unacceptable	C=4: exposed PLCs are directly manipulable, risking equipment damage. E=1: PLC logic is purely software, no physical isolation. D=5: direct external/cloud connectivity is the maximum-exposure end of the scale. I=4: PLC operation is critically dependent on internet-facing management interface remaining uncompromised.
Hardwired instrumentation replacing networked sensor	CIE Implementation Guide, INL 2023	1	4	1	1	3	4	Acceptable	C=1: no OT physical-state alteration possible via cyber means - IT-boundary-confined at most. E=4: hardwired analog sensor/relay cannot be altered via network commands. D=1: total air-gap, zero remote attack surface. I=1: fully autonomous, no external dependency to function.
Physical + digital interlock on circuit breaker	Friedberg et al. STPA-SafeSec 2017 (mitigation)	1	3	2	1	3	3	Acceptable	C=1: localized/negligible impact, interlock prevents hazardous states from reaching physical process. E=3: hybrid physical+digital redundancy requiring both a command and a mechanical action. D=2: unidirectional telemetry only, physically limited by hardware. I=1: interlock operates autonomously off local measurements, no external dependency.
NGFW + DMZ segmentation at IT/OT boundary	CIE Implementation Guide / NIST SP800-82	2	2	3	2	3	3	Acceptable	C=2: recoverable OT disruption bounded by DMZ containment if breached. E=2: NGFW is a segmented digital control (software-based, still bypassable by APTs). D=3: DMZ permits IP-based read-only polling but restricts write access. I=2: OT segment has localized dependency on DMZ infrastructure, contained within trusted boundary.

Table B.1 - continued from previous page

Scenario	Source	C	E	D	I	US	CB	Label	Justification
Managed switch replacing legacy unmanaged hub	CIE Implementation Guide, INL 2023	2	2	3	2	3	3	Acceptable	C=2: minor OT disruption risk bounded by managed-switch access control lists. E=2: managed switch is a segmented digital control (VLAN/ACL based). D=3: segmented IP with read-only/restricted polling typical of managed switch ACL configs. I=2: localized OT dependency, contained to the same trusted network segment.
Read-only local data diode/cache for HMI telemetry	CIE Implementation Guide, INL 2023	1	5	2	1	4	4	Acceptable	C=1: negligible - physically cannot alter OT state, output-only telemetry. E=5: hardware data diode is a purely physical/mechanical enforcement of one-way traffic. D=2: unidirectional outbound-only connection, inbound commands physically impossible. I=1: HMI cache operates autonomously off local buffered data.
SIS/BPCS independence per IEC 61511 maintained	IEC 61511 / Triton post-incident lessons	1	4	2	1	3	4	Acceptable	C=1: negligible - SIS cannot be reached from BPCS compromise if independence enforced. E=4: hardwired analog trip logic independent of programmable BPCS. D=2: unidirectional communication from SIS to BPCS only (status reporting). I=1: SIS operates autonomously, self-sufficient safety function by design.
MFA + role-based access on engineering workstation	NIST SP800-82 / Oldsmar lessons-learned 2021	2	2	3	2	4	4	Acceptable	C=2: minor OT disruption risk bounded by requiring compromised credentials plus a second factor. E=2: MFA is a segmented digital control layered on the engineering workstation. D=3: workstation retains IP connectivity but access is restricted/authenticated. I=2: localized dependency on internal authentication server within the trusted segment.

B.2 Monte Carlo Simulation Details

In order to run an effective Monte Carlo simulation in Python a simple pipeline has been built. The following page contains a Sequence Digram that illustrates the pipeline for obtaining the reported numbers and graphs in Sec. 4.2.3. The diagram also shows the core libraries used in each stage and the CSV handoffs between scripts; this operationalizes the method described in Sec. 4.2.3.4. Moreover it annotates as well that, in order to keep the reproducibility, the *numpy* library's has been used with the random function using a fixed seed (42).

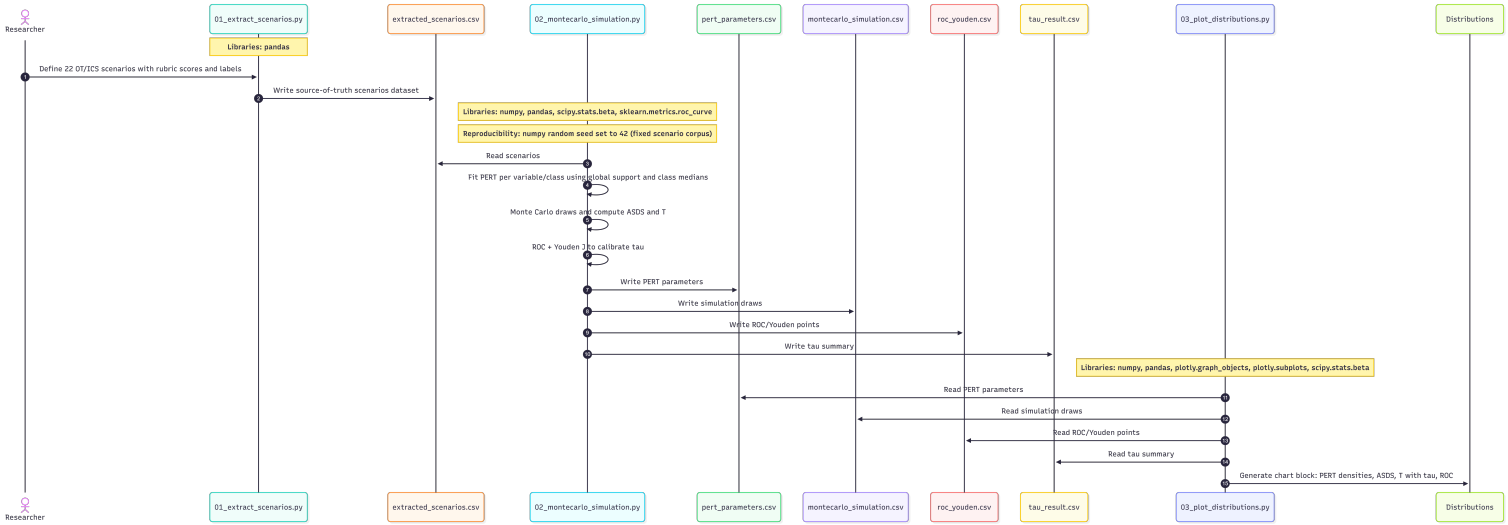


Figure B.1: Sequence diagram of the three-stage τ calibration workflow: scenario extraction, PERT-based Monte Carlo simulation, and final distribution plotting.

B.3 AHP Questionnaire Template

Purpose

This questionnaire calibrates the four weights (w_1, w_2, w_3, w_4) used in the CCIM Attack Surface Delta Score (ASDS) formula:

$$\text{ASDS} = w_1 \cdot C + w_2 \cdot \left(\frac{1}{E+1}\right) + w_3 \cdot D + w_4 \cdot I \tag{B.1}$$

These weights encode how much relative importance an organization places on each of the four risk dimensions when evaluating a proposed OT engineering change. Different Critical National Infrastructure (CNI) sectors are expected to weigh these dimensions differently. For example, a nuclear facility may prioritize Consequence Exposure far more heavily than a general manufacturing plant would. This questionnaire uses Saaty's Analytic Hierarchy Process (AHP) pairwise comparison method to derive these weights systematically from expert judgment.

Instructions for the Respondent

Please complete this questionnaire twice: once from the perspective of a Subject Matter Expert (SME) responsible for a **nuclear power facility**, and once from the perspective of an SME responsible for a **general manufacturing plant**. There are no right or wrong answers; the goal is to capture how your professional judgment of relative risk priority would genuinely differ (or not) between these two contexts.

Variable Definitions

Part 1: Pairwise Comparison Scale

For each pair of variables below, indicate how much more important one variable is than the other when deciding whether a proposed OT change is acceptable, using Saaty's Fundamental Scale. If the row variable is less important than the column variable, use the reciprocal (e.g., $1/3, 1/5, 1/7, 1/9$). For example, if C is less important than E, write $1/3$ in the box.

Variable	Name	What It Measures
C	Consequence Exposure	The worst-case physical or operational consequence if the OT component's digital controls are compromised (e.g., minor sensor fault vs. loss of a safety function).
E	Engineered Controls	The physical/mechanical strength and isolation level of the control protecting the process (e.g., a purely software-based interlock vs. a hardwired mechanical relay). Note: E acts as a risk-reducing dampening factor; a stronger E lowers the ASDS score.
D	Digitalization	The level of digital connectivity and network routability of the OT device (e.g., air-gapped serial connection vs. bi-directional, IP-routable, cloud-connected).
I	Interdependency	The degree to which the OT device relies on external services (e.g., Active Directory, NTP, remote vendor diagnostics) to continue functioning.

Table B.2: CCIM ASDS Variable Definitions

Value	Meaning
1	Equal importance
3	Moderate importance of one over the other
5	Strong importance of one over the other
7	Very strong / demonstrated importance of one over the other
9	Extreme importance of one over the other
2, 4, 6, 8	Intermediate values between the above judgments

Table B.3: Saaty's AHP Scale

Part 2A: As a Nuclear Facility SME

Please fill in the six pairwise comparisons below, considering the operational and safety priorities of a nuclear power facility.

Comparison	**Your Judgment**	**Brief Rationale (1–2 sentences)**
Consequence Exposure (C) vs. Engineered Controls (E)		
Consequence Exposure (C) vs. Digitalization (D)		
Consequence Exposure (C) vs. Interdependency (I)		
Engineered Controls (E) vs. Digitalization (D)		
Engineered Controls (E) vs. Interdependency (I)		
Digitalization (D) vs. Interdependency (I)		

Table B.4: Pairwise Comparison Matrix: Nuclear Facility SME

Part 2B: As a Manufacturing Plant SME

Please repeat the same exercise, this time considering the operational and commercial priorities of a general manufacturing plant (non-safety-critical, but CNI-adjacent).

Comparison	**Your Judgment**	**Brief Rationale (1-2 sentences)**
Consequence Exposure (C) vs. Engineered Controls (E)		
Consequence Exposure (C) vs. Digitalization (D)		
Consequence Exposure (C) vs. Interdependency (I)		
Engineered Controls (E) vs. Digitalization (D)		
Engineered Controls (E) vs. Interdependency (I)		
Digitalization (D) vs. Interdependency (I)		

Table B.5: Pairwise Comparison Matrix: Manufacturing Plant SME

B.4 CR Validation

Nuclear-facility profile

The nuclear profile gives the greatest relative importance to consequence exposure, followed by engineered controls, digitalisation exposure, and interdependency risk. The reciprocal pairwise-comparison matrix is:

$$\mathbf{A}_N = \begin{pmatrix} 1 & 5 & 4 & 5 \\ 1/5 & 1 & 3 & 3 \\ 1/4 & 1/3 & 1 & 2 \\ 1/5 & 1/3 & 1/2 & 1 \end{pmatrix} \tag{B.2}$$

The column sums are:

$$\mathbf{s}_N = (1.65,\ 6.6667,\ 8.5,\ 11.0). \tag{B.3}$$

Dividing each matrix entry by the sum of its column gives:

$$\mathbf{A}_{normN} \approx \begin{pmatrix} 0.6061 & 0.7500 & 0.4706 & 0.4545 \\ 0.1212 & 0.1500 & 0.3529 & 0.2727 \\ 0.1515 & 0.0500 & 0.1176 & 0.1818 \\ 0.1212 & 0.0500 & 0.0588 & 0.0909 \end{pmatrix} \tag{B.4}$$

The row averages produce the normalized priority vector:

$$\mathbf{w}_N = \begin{pmatrix} 0.5703 \\ 0.2242 \\ 0.1252 \\ 0.0802 \end{pmatrix} \qquad \sum_i w_{N,i} = 1.0000 \tag{B.5}$$

For the consistency calculation, multiplication of the original matrix by the priority vector gives:

$$\mathbf{A}_N \mathbf{w}_N \approx \begin{pmatrix} 2.5933 \\ 0.9542 \\ 0.5028 \\ 0.3316 \end{pmatrix} \tag{B.6}$$

The component-wise ratios are:

$$\frac{(\mathbf{A}_N \mathbf{w}_N)_i}{w_{N,i}} \approx (4.5477,\ 4.2580,\ 4.0164,\ 4.1335) \tag{B.7}$$

Therefore:

$$\lambda_{\max,N} = \frac{1}{4}\sum_{i=1}^{4}\frac{(\mathbf{A}_N\mathbf{w}_N)_i}{w_{N,i}} \approx 4.2389 \tag{B.8}$$

Using the definitions in Sec. 4.2.1.5:

$$CI_N = \frac{\lambda_{\max,N} - n}{n-1} = \frac{4.2389 - 4}{3} \approx 0.0796 \tag{B.9}$$

For $n = 4$, the Random Index used in the CCIM calculation is $RI = 0.90$. Consequently:

$$CR_N = \frac{CI_N}{RI} = \frac{0.0796}{0.90} \approx 0.0885. \tag{B.10}$$

Because $CR_N = 0.0885 < 0.10$, the nuclear profile satisfies the consistency criterion specified in Sec. 4.2.1.5. The profile is therefore accepted for the worked demonstration, subject to the important qualification that consistency validates the internal coherence of the pairwise judgements; it does not demonstrate that the judgements are objectively correct or that they represent a population of nuclear experts.

Manufacturing-plant profile

The manufacturing profile gives greater relative importance to consequence exposure and digitalisation exposure, while assigning lower priority to engineered controls and interdependency risk than the nuclear profile. Its reciprocal matrix is:

$$\mathbf{A}_M = \begin{pmatrix} 1 & 3 & 2 & 2 \\ 1/3 & 1 & 1/2 & 1 \\ 1/2 & 2 & 1 & 2 \\ 1/2 & 1 & 1/2 & 1 \end{pmatrix} \tag{B.11}$$

The column sums are:

$$\mathbf{s}_M = (2.3333,\ 7.0,\ 4.0,\ 6.0) \tag{B.12}$$

The normalized matrix is:

$$\mathbf{A}_{normM} \approx \begin{pmatrix} 0.4286 & 0.4286 & 0.5000 & 0.3333 \\ 0.1429 & 0.1429 & 0.1250 & 0.1667 \\ 0.2143 & 0.2857 & 0.2500 & 0.3333 \\ 0.2143 & 0.1429 & 0.1250 & 0.1667 \end{pmatrix} \tag{B.13}$$

Row averaging gives:

$$\mathbf{w}_M = \begin{pmatrix} 0.4226 \\ 0.1443 \\ 0.2708 \\ 0.1622 \end{pmatrix} \qquad \sum_i w_{M,i} = 1.0000 \tag{B.14}$$

The matrix-vector product and component-wise ratios are:

$$\mathbf{A}_M \mathbf{w}_M \approx \begin{pmatrix} 1.7129 \\ 0.5828 \\ 1.0952 \\ 0.6549 \end{pmatrix} \tag{B.15}$$

$$\frac{(\mathbf{A}_M \mathbf{w}_M)_i}{w_{M,i}} \approx (4.0739,\ 4.0378,\ 4.0440,\ 4.0275) \tag{B.16}$$

Thus:

$$\lambda_{\max,M} = \frac{1}{4} \sum_{i=1}^{4} \frac{(\mathbf{A}_M \mathbf{w}_M)_i}{w_{M,i}} \approx 4.0458 \tag{B.17}$$

The Consistency Index is:

$$CI_M = \frac{\lambda_{\max,M} - 4}{3} = \frac{4.0458 - 4}{3} \approx 0.0153 \tag{B.18}$$

Using the same $RI = 0.90$ for a four-criterion matrix:

$$CR_M = \frac{CI_M}{RI} = \frac{0.0153}{0.90} \approx 0.0170. \tag{B.19}$$

Because $CR_M = 0.0170 < 0.10$, the manufacturing profile also satisfies the consistency criterion specified in Sec. 4.2.1.5. It is accepted for the worked demonstration. As with the nuclear profile, this result indicates internal consistency rather than empirical validation of the judgement values.

Interpretive limitation. The two matrices are worked examples constructed to demonstrate the complete calculation and the effect of organisational risk priorities. A consistency ratio below 0.10 does not establish that a profile is representative of nuclear or manufacturing practitioners. Empirical claims about sector-specific priorities would require completed questionnaires from suitably qualified SMEs and an appropriate aggregation procedure for multiple responses.

References

Adams, Anne and M. Angela Sasse (Dec. 1999). "Users are not the enemy". In: *Commun. ACM* 42.12, pp. 40–46. ISSN: 0001-0782. DOI: 10.1145/322796.322806.

Anderson, Robert S. et al. (2017). *Cyber-Informed Engineering*. Technical Report INL/EXT-16-40099-Rev000. Idaho Falls, ID, United States: Idaho National Laboratory / U.S. Department of Energy, Office of Nuclear Energy. URL: https://www.osti.gov/servlets/purl/1369373.

Beautement, Adam, M. Angela Sasse, and Mike Wonham (2008). "The compliance budget: managing security behaviour in organisations". eng. In: *Proceedings of the 2008 New Security Paradigms Workshop*. New York, NY, USA: ACM, pp. 47–58. ISBN: 9781605583419.

Bridewell (Mar. 2024). *Where, if Anywhere, Is the Greatest Pressure to Improve Cyber Maturity Coming From? [Graph]*. Statista. https://www.statista.com/statistics/1468531/top-reasons-to-improve-cyber-maturity-uk/.

Cherdantseva, Yulia et al. (2016). "A review of cyber security risk assessment methods for SCADA systems". In: *Computers & Security* 56, pp. 1–27. DOI: 10.1016/j.cose.2015.09.009. URL: https://doi.org/10.1016/j.cose.2015.09.009.

CISA, FBI, EPA, and MS-ISAC (Feb. 2021). *Compromise of U.S. Water Treatment Facility*. Joint Cybersecurity Advisory AA21-042A. Cybersecurity and Infrastructure Security Agency. URL: https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-042a.

Cox, Anthony Louis Jr (2008). "What's Wrong with Risk Matrices". eng. In: *Risk analysis* 28.2, pp. 497–512. ISSN: 0272-4332.

Cybersecurity and Infrastructure Security Agency (2025). *Foundations for OT Cybersecurity: Asset Inventory Guidance for Owners and Operators*. https://www.cisa.gov/resources-tools/resources/foundations-ot-cybersecurity-asset-inventory-guidance-owners-and-operators.

Davies, Julie L. and Oliver H. Turnbull (2011). "Affective bias in complex decision making: Modulating sensitivity to aversive feedback". eng. In: *Motivation and emotion* 35.2, pp. 235–248. ISSN: 0146-7239.

Devarajan, Yuvarajan et al. (2026). "A Review of Model Uncertainty, Cyber-Physical Threats and Assurance Frameworks for Safety-Critical AI in Process Industries". In: *IET Cyber-Physical Systems: Theory & Applications* 11, e70062. DOI: 10.1049/cps2.70062.

Dragos Inc. (2017). *TRISIS: Analyzing Safety System Targeting Malware*. Technical Report. Archived copy; original vendor link offline. Dragos Inc. URL: https://web.archive.org/web/20171215000000/https://dragos.com/blog/trisis/TRISIS-01.pdf.

Eggers, Shannon L. and Robert S. Anderson (2022). "Cyber-Informed Engineering for Nuclear Reactor Digital Instrumentation and Control". In: *Nuclear Reactors: Spacecraft Propulsion, Research Reactors, and Reactor Analysis Topics*. Ed. by Chad L. Pope. IntechOpen. DOI: 10.5772/intechopen.101807. URL: https://doi.org/10.5772/intechopen.101807.

European Commission (2026). *Industry 5.0*. Research and Innovation, European Commission. Online; accessed 28 August 2026. URL: https://research-and-innovation.ec.europa.eu/research-area/industrial-research-and-innovation/industry-50_en.

Fawcett, Tom (2006). "An introduction to ROC analysis". In: *Pattern Recognition Letters* 27.8, pp. 861–874. DOI: 10.1016/j.patrec.2005.10.010.

Fenton, Norman and James Bieman (2015). *Software Metrics: A Rigorous and Practical Approach, Third Edition*. eng. 3rd ed. Milton: CRC Press. ISBN: 9781439838228.

Freeman, Sarah G., Nathan Hill Johnson, and Curtis P. St. Michel (2019). *Consequence-driven Cyber-informed Engineering (CCE)*. Tech. rep. Accessed: 2026-02-03. INL, U.S. Department of Energy. URL: https://inl.gov/national-security/cce/.

Friedberg, Ivo et al. (2017). "STPA-SafeSec: Safety and security analysis for cyber-physical systems". In: *Journal of Information Security and Applications* 34.2, pp. 183–196. DOI: 10.1016/j.jisa.2016.05.008. URL: https://doi.org/10.1016/j.jisa.2016.05.008.

Gordon, Lawrence A. and Martin P. Loeb (Nov. 2002). "The economics of information security investment". In: *ACM Trans. Inf. Syst. Secur.* 5.4, pp. 438–457. ISSN: 1094-9224. DOI: 10.1145/581271.581274. URL: https://doi-org.ezproxy.lancs.ac.uk/10.1145/581271.581274.

Hevner, Alan R. et al. (2004). "Design Science in Information Systems Research". In: *MIS Quarterly* 28.1, pp. 75–105. DOI: 10.2307/25148625. URL: https://doi.org/10.2307/25148625.

Hopkins, Andrew (2011). "Risk-management and rule-compliance: Decision-making in hazardous industries". In: *Safety Science* 49.2, pp. 110–120. ISSN: 0925-7535. DOI: https://doi.org/10.1016/j.ssci.2010.07.014. URL: https://www.sciencedirect.com/science/article/pii/S092575351000202X.

Hubbard, Douglas W. and Richard Seiersen (2023). *How to Measure Anything in Cybersecurity Risk*. eng. Hoboken, NJ.

IEC 61508:2010 (2010). *IEC 61508: Functional Safety of Electrical/Electronic/Programmable Electronic Safety-Related Systems*. 2.0. Parts 1–7. International Electrotechnical Commission.

IEC 62443-3-3:2013 (2013). *Industrial communication networks – Network and system security – Part 3-3: System security requirements and security levels*. IEC 62443-3-3:2013. International Electrotechnical Commission.

ISO/IEC 27002:2022 (2022). *Information security, cybersecurity and privacy protection – Information security controls*. 3rd. ISO/IEC 27002:2022. International Organization for Standardization.

ISO/IEC 27001:2022 (2022). *Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. 3rd. ISO/IEC 27001:2022. Amended by ISO/IEC 27001:2022/Amd 1:2024. International Organization for Standardization.

ISO/IEC 20000-1:2018 (2018). *Information technology – Service management – Part 1: Service management system requirements*. ISO/IEC 20000-1:2018. International Organization for Standardization.

ISO/IEC TS 20000-11:2021 (2021). *Information technology – Service management – Part 11: Guidance on the relationship between ISO/IEC 20000-1 and service management frameworks: ITIL*. ISO/IEC TS 20000-11:2021. International Organization for Standardization.

ISA Global Cybersecurity Alliance (June 2025). *Applying ISO/IEC 27001, ISO/IEC 27002 and the ISA/IEC 62443 Series for Operational Technology Environments*. Tech. rep. International Society of Automation.

Kagermann, Henning, Wolfgang Wahlster, and Johannes Helbig (2013). *Recommendations for Implementing the Strategic Initiative INDUSTRIE 4.0: Final Report of the Industrie 4.0 Working Group*. Tech. rep. acatech – National Academy of Science and Engineering.

KPMG International and CS2AI (Mar. 2024). *Main Actors Involved in Control System Cybersecurity (CS)^2 Attacks Worldwide from 2020 to 2023 [Graph]*. Statista. https://www.statista.com/statistics/1469579/top-threat-actors-in-cs-2-attacks-globally/.

Krantz, David H. and Patrick Suppes (1971). *Foundations of measurement*. eng. New York.

Kulakowski, Konrad (2021). *Understanding the Analytic Hierarchy Process*. eng. 1st. Chapman & Hall/CRC Series in Operations Research. Boca Raton: CRC Press. ISBN: 1138032328.

Lampe, Benjamin (2026). *Improving Cyber Risk Management for Industrial Control*. Tech. rep. NIST. URL: https://csrc.nist.gov/csrc/media/Presentations/2026/cyber-informed-engineering-for-industrial-control/images-media/20260520Lampe-Improving-Cyber-Risk-Management-Industrial-Control.pdf.

Lee, Jay, Hanqi Su, Marco Macchi, et al. (2026). "2026 roadmap on artificial intelligence and machine learning for smart manufacturing". In: *Machine Learning: Engineering* 2, p. 022001. DOI: 10.1088/3049-4761/ae5967.

Leveson, Nancy G (2012). *Engineering a Safer World: Systems Thinking Applied to Safety*. eng. 1st ed. Engineering Systems. Cambridge: MIT Press. ISBN: 0262016621.

Manadhata, P K and J M Wing (2011). "An Attack Surface Metric". eng. In: *IEEE transactions on software engineering* 37.3, pp. 371–386. ISSN: 0098-5589.

Menezes, Thiago et al. (Aug. 2023). "A Survey on the Application of Phasor Measurement Units to the Protection of Transmission and Smart Distribution Systems". In: *Electric Power Components and Systems* 52, pp. 1379–1396. DOI: 10.1080/15325008.2023.2240320.

NIST (Sept. 2023). *Guide to Operational Technology (OT) Security*. Tech. rep. NIST SP 800-82r3. National Institute of Standards and Technology. DOI: 10.6028/NIST.SP.800-82r3.

— (Feb. 2024). *The NIST Cybersecurity Framework (CSF) 2.0*. Tech. rep. NIST CSWP 29. National Institute of Standards and Technology. DOI: 10.6028/NIST.CSWP.29.

Office for Nuclear Regulation (2022). *Security Assessment Principles (SyAPs) for the Civil Nuclear Industry*. Tech. rep. ONR. URL: https://www.onr.org.uk/publications/regulatory-guidance/regulatory-assessment-and-permissioning/security-assessment-principles-syaps/security-assessment-principles-syaps.

Peffers, Ken et al. (2007). "A Design Science Research Methodology for Information Systems Research". In: *Journal of Management Information Systems* 24.3, pp. 45–77. DOI: 10.2753/MIS0742-1222240302. URL: https://doi.org/10.2753/MIS0742-1222240302.

Reason, J. (Apr. 1990). "The contribution of latent human failures to the breakdown of complex systems". In: *Philosophical Transactions of the Royal Society of London. B, Biological Sciences* 327.1241, pp. 475–484. ISSN: 0080-4622. DOI: 10.1098/rstb.1990.0090. eprint: https://royalsocietypublishing.org/rstb/article-pdf/327/1241/475/82000/rstb.1990.0090.pdf. URL: https://doi.org/10.1098/rstb.1990.0090.

Rinaldi, S.M., James Peerenboom, and T.K. Kelly (Jan. 2001). "Identifying, understanding, and analyzing critical infrastructure interdependencies". In: *Control Systems, IEEE* 21, pp. 11–25. DOI: 10.1109/37.969131.

Saaty, Thomas L. (1980). *The Analytic Hierarchy Process: Planning, Priority Setting, Resource Allocation*. New York: McGraw-Hill. ISBN: 978-0070543713.

SANS ICS and E-ISAC (Mar. 2016). *Analysis of the Cyber Attack on the Ukrainian Power Grid*. Tech. rep. Defense Use Case. SANS Institute, Electricity Information Sharing, and Analysis Center (E-ISAC). URL: https://nsarchive.gwu.edu/sites/default/files/documents/3891751/SANS-and-Electricity-Information-Sharing-and.pdf (visited on 07/09/2026).

IEC 62443-2-1:2024 (2024). *Security for industrial automation and control systems – Part 2-1: Security program requirements for IACS asset owners*. 2nd. IEC 62443-2-1:2024. International Electrotechnical Commission.

IEC 62443-2-4:2023 (2023). *Security for industrial automation and control systems – Part 2-4: Security program requirements for IACS service providers*. IEC 62443-2-4:2023. International Electrotechnical Commission.

IEC 62443-4-1:2018 (2018). *Security for industrial automation and control systems – Part 4-1: Secure product development lifecycle requirements*. IEC 62443-4-1:2018. International Electrotechnical Commission.

IEC 62443-4-2:2018 (2018). *Security for industrial automation and control systems – Part 4-2: Technical security requirements for IACS components*. IEC 62443-4-2:2018. International Electrotechnical Commission.

Slay, Jill and Michael Miller (Mar. 2007). "Lessons Learned from the Maroochy Water Breach". In: *Critical Infrastructure Protection*. Vol. 253, pp. 73–82. ISBN: 978-0-387-75461-1. DOI: 10.1007/978-0-387-75462-8_6.

Statista (2024). *Topic: Operational Technology (OT) Cybersecurity*. https://www.statista.com/topics/12355/operational-technology-ot-cybersecurity/. Accessed 24 August 2026.

— (2025). *Cybersecurity skills gaps (see Page 9-10)*. Tech. rep. Statista. URL: https://www.statista.com/study/163561/cybersecurity-skills-gaps/.

Steinberg, Sean, Adam Stepan, and Kyle Neary (2021). *NotPetya: A Columbia University Case Study*. Case Study SIPA-21-022.1. Accessed: 2026-02-02. School of International and Public Affairs (SIPA), Columbia University. URL: https://www.sipa.columbia.edu/sites/default/files/2022-11/NotPetya%5C%20Final.pdf.

Stevens, S. S. (1946). "On the Theory of Scales of Measurement". eng. In: *Science (American Association for the Advancement of Science)* 103.2684, pp. 677–680. ISSN: 0036-8075.

Wright, Virginia L et al. (Sept. 2023). *Cyber-Informed Engineering Implementation Guide*. URL: https://www.osti.gov/biblio/1995796.

Zhao, Xiaoning et al. (2025). "Applications of machine learning in real-time control systems: a review". In: *Measurement Science and Technology* 36, p. 012003. DOI: 10.1088/1361-6501/ad8947.